

Cognitive Security

A Systems Science of
Cognitive Defense and Resilience



Ya-Ting Yang Linan Huang Quanyan Zhu

Cognitive Security

A Systems Science of Cognitive Defense and Resilience

Ya-Ting Yang

National Taiwan University

Linan Huang

Tsinghua University

Quanyan Zhu

New York University

Contents

Preface	vii
Notation	xi
 I Foundations	 1
1 The Cognitive Domain as a Security Frontier	3
1.1 From Data Security to Decision Security	4
1.2 Cognition as the Control Layer of Socio-Technical Systems	6
1.3 Influence, Manipulation, Attack, and Warfare	8
1.4 Cognitive Security and Adjacent Fields	10
1.5 Beyond the Weakest-Link Model	12
1.6 The Frameworks of This Book	15
1.7 The MERIDIAN Running Example and Reading Paths	22
1.8 Ethics and Limits	24
1.9 Summary	26
Exercises	26
Notes and Further Reading	28
 2 Cognitive Systems and Assets: Humans, Machines, Teams, and Institutions	 31
2.1 The Individual as a Cognitive System	32
2.2 Situation Awareness and Its Breakdowns	35
2.3 Distributed and Organizational Cognition	38
2.4 Artificial and Joint Human-AI Cognitive Systems	41
2.5 Trust as a System Property	44
2.6 Cognitive Assets and Trusted Boundaries	47
2.7 Dependencies and the Propagation of Impairment	52
2.8 Ethics and Limits	57
2.9 Summary	59
Exercises	59
Notes and Further Reading	61
 3 Cognitive Vulnerabilities, Threats, and the Cognitive Attack Chain	 63
3.1 Vulnerability as Exploitable Regularity	65
3.2 Levers of Influence	70
3.3 Systemic Vulnerabilities	72
3.4 Threat Actors	75
3.5 The Cognitive Attack Chain	78
3.6 The Attack Chain as an Absorbing Markov Chain	81

3.7	Dissent, Ethics, and Limits	86
3.8	Summary	89
	Exercises	89
	Notes and Further Reading	91
4	Cognitive Security Objectives, Risk, and Resilience Metrics	93
4.1	Security Objectives for Cognitive Systems	94
4.2	Tensions Among Objectives	97
4.3	Cognitive Risk	100
4.4	Decision Quality as a Performance Function	103
4.5	The Resilience Curve and the Resilience Functional	107
4.6	Stochastic and Risk-Averse Resilience	111
4.7	Measurement Validity	118
4.8	Ethics and Limits	122
4.9	Summary	123
	Exercises	124
	Notes and Further Reading	126
	Index	137

Preface

“The human is the weakest link” is among the most repeated sentences in security. Operators make mistakes during routine operations, employees reuse passwords or leave them unchanged for years, and a well-crafted phishing message persuades someone to click, to share a credential, or to approve a payment. For decades, practitioners and researchers have recognized that human vulnerabilities are a leading cause of security failures in computing systems and in the infrastructure that depends on them. Our understanding of those vulnerabilities, however, remains limited, and the sentence itself has too often served as a conclusion rather than as the beginning of an analysis. A vulnerability that is attributed to people, and left there, cannot be engineered.

Part of the difficulty is that the subject spans many fields: psychology, cognitive and neural science, computer science, engineering, the social sciences, law, and ethics. Each field brings its own questions and its own style of work. Psychology builds knowledge through controlled human-subjects experiments. The social sciences, ethics, and law advance through narrative, argument, and the analysis of institutions. Engineering and computer science rely on measurement, modeling, and design. Each style is valuable, and each has shaped what is known about how people perceive, trust, decide, and err under adversarial pressure. Yet without system-level quantitative methods that connect them, the results are difficult to combine into a field in which researchers understand one another’s language. A system designer who wishes to use a finding from psychology may have to repeat the human experiments that produced it, adapted to a new interface, a new organization, or a new threat. Repeated for each design decision, this approach becomes prohibitive. The same fragmentation makes the area hard to enter: students and early-career researchers find it challenging to identify research problems that are both scientifically meaningful and technically tractable.

This book aims to address that gap. It develops a system-level understanding of cognitive security and provides methods to model, analyze, and design for it. We treat cognition as a decision-producing function of coupled human, machine, and institutional systems, one that can be attacked, measured, defended, and made resilient. Rather than placing blame on a weakest link, we ask where in a system perception, belief, judgment, and action can be manipulated, how the effects propagate across individuals, teams, organizations, artificial agents, and society, and which combinations of technical, procedural, and organizational controls restore decision quality. A small set of frameworks organizes the book: the Cognitive Security Stack of five levels of cognition, the cognitive loop of sensing, modeling, deciding, acting, and learning, the Cognitive Security Cube that combines them with the phases of resilience, the cognitive attack and defense chains, and a resilience functional that measures decision quality over time.

Around these frameworks we develop the quantitative tools the field needs: Bayesian inference and detection, choice models and bounded rationality, Markov and partially observable models, game theory and information design, mechanism design, queueing, network diffusion, control, and the experimental and causal methods required to test claims about people.

Our own journey into this subject began with Linan Huang, then a doctoral student at New York University, who had the daring to make the modeling of human vulnerabilities the final part of his dissertation. At the time, most work treated human factors either as a matter of training and awareness or as an unmodeled source of error. Linan explored instead how attention, risk perception, and reasoning could be represented as system components with inputs, outputs, and dynamics, and how defenses could be designed against them: an adaptive mechanism that guides a user's visual attention to prevent phishing [1], and alert and attention management for security operations centers under informational denial-of-service attacks [2]. That system-scientific approach, a departure from much of the literature, became the SpringerBrief *Cognitive Security: A System-Scientific Approach* [3], the seed from which the present book grew.

The next adventure came with Ya-Ting Yang, also a doctoral student at New York University at the time, who looked at the same vulnerabilities from the opposite side. If human cognition can be exploited, so can the cognition of attackers. Her work asked how defenders might use the cognitive vulnerabilities of adversaries, their biases, their sunk costs, and their beliefs about what they observe, to delay, reveal, or redirect attacks through deception and game-theoretic design. This line of research was supported by the IARPA program Reimagining Security with Cyberpsychology-Informed Network Defenses (ReSCIND) [4], which was instrumental in bringing cyberpsychology, deception, and quantitative modeling into a common research agenda.

As we worked on the subject, it became increasingly relevant and kept changing. Deepfakes turned impersonation into a routine instrument of fraud, and coordinated disinformation showed how the beliefs of whole populations can be shaped. We also live in an age of information avalanche: people and organizations receive far more messages, alerts, and claims than they can examine, and attention itself has become a scarce resource that adversaries can exhaust or misdirect. Artificial intelligence has extended the subject further. AI systems have cognitive vulnerabilities of their own, in perception, memory, reasoning, and goals, and humans and AI agents now make decisions together, so that a manipulation of one can propagate to the other. The vulnerabilities of human-AI interaction are becoming as important as those of either party alone. Attacks and defenses in this space evolve quickly, and methods that seem sufficient today may need revision within a few years.

Over the years we have attended workshops and conferences in many communities, including security, artificial intelligence, human factors, psychology, automation and control, and systems engineering. No single venue yet serves this topic, and no single department owns it; the questions arise in schools of engineering, computer science, psychology, public policy, business, and law. We wrote this book to serve as a reference and a textbook for students and early-career

researchers from these different backgrounds, and for practitioners in industry and government who wish to begin working in this emerging field together.

The book is organized in seven parts. Part I lays the conceptual foundations, and Part II develops the models and the engineering of defenses. Parts III and IV address individual cognition and organizational and societal cognition. Part V turns cognitive mechanisms to defensive advantage, and Part VI treats artificial and hybrid cognition, closing with humans and AI in the control loop of cyber-physical systems. Part VII covers evaluation, governance, and research frontiers. A notional utility called MERIDIAN serves as a running example throughout, so that the models of different chapters can be compared in one setting. Each chapter is written to be read on its own and includes worked examples, case studies, an ethics and limits section, exercises, and a computational lab with companion code. Appendix A collects the frameworks, standards, and terms used across the book, and Appendix B provides test case scenarios and a survey of benchmarks, including benchmarks for agentic AI, so that the defenses discussed here can be evaluated in reproducible ways. [Chapter 1](#) suggests reading paths for courses on cognitive security, human factors and security operations, AI security and human-AI teaming, game theory and deception, security studies, and professional training.

We have tried to be precise about what is known and candid about what is not. The field has more open problems than settled methods, and the questions it raises about autonomy, privacy, and legitimate influence are as important as its technical ones. We hope that this book helps readers find those problems, speak across disciplinary boundaries, and bring the rigor of systems science to the protection of human and machine cognition. It is an area in which new talent is needed, and we look forward to seeing what our readers will contribute.

Acknowledgments

Much of the research behind this book was carried out with collaborators whose ideas and questions shaped it. We are grateful to Emily Balcetis and Rae Zimmerman, whose work with Quanyan Zhu joined social psychology, infrastructure systems, and security engineering in the study of how people perceive and misperceive cyber risks and how they can be engaged in the collective defense against phishing. We also thank our coauthors on work related to cognitive security, deception, and human decision-making: Tamer Başar, Edward Colbert, Emily B. Cox, Yezekael Hayel, Yunhan Huang, Shumeng Jia, Tao Li, Shutian Liu, Anh Tung Nguyen, Jeffrey Pawlick, André M. H. Teixeira, Tao Zhang, and Yuhan Zhao. We thank as well the participants of the workshops and conferences where early versions of this material were presented and debated. The icons in the figures are from Font Awesome Free 5, used under the Creative Commons Attribution 4.0 license.

Part of the research reported in this book was supported by the U.S. National Science Foundation under award 1720230, “EAGER: Behavior-Based Incentive Mechanism Design for Crowd Defense against Phishing Attacks,” with Quanyan Zhu as principal investigator and Emily Balcetis as co-principal investigator, and

award 2122060, “EAGER: SAI: Understanding Misperceptions of Cyber Risks to Model and Secure Transportation Infrastructures,” with Emily Balcetis as principal investigator and Rae Zimmerman and Quanyan Zhu as co-principal investigators, and by the Intelligence Advanced Research Projects Activity (IARPA) through the ReSCIND program. The opinions, findings, and conclusions expressed in this book are those of the authors and do not necessarily reflect the views of the National Science Foundation, the Office of the Director of National Intelligence, IARPA, or the U.S. Government.

Ya-Ting Yang
Taipei

Linan Huang
Beijing

Quanyan Zhu
New York

September 2026

Notation

This section collects the symbols used in more than one chapter with a single meaning. Each chapter lists only the additional symbols specific to it. A symbol is also defined where it first appears in the text, so each chapter can be read on its own.

Scalars are italic (x), vectors bold lower case ($\mathbf{b}$), matrices bold upper case ($\mathbf{P}$), and sets calligraphic ($\mathcal{A}$, $\mathcal{W}$). Subscripts that are labels are upright (P_{FA}); subscripts that are indices are italic (b_k). A hat marks an estimate, a bar a bound or average, a tilde a manipulated quantity, and a star an optimal or equilibrium value.

Probability and inference

Symbol	Meaning
$\mathbb{P}(\cdot), \mathbb{E}[\cdot]$	probability; expectation
$\text{Var}(\cdot), \text{Cov}(\cdot, \cdot)$	variance; covariance
$\mathbb{1}\{E\}$	indicator of the event E
$\mathbb{R}$	real numbers
$\mathbf{v}^\top$	transpose of a vector or matrix
$\Delta(\mathcal{X})$	set of probability distributions on a set $\mathcal{X}$ (finite unless stated otherwise)
$\mathbf{b}, b(x)$	belief: a distribution over hidden states
$\mathbf{b}_0$	prior belief
$P_{\text{D}}, P_{\text{FA}}$	probability of detection; probability of false alarm
ρ	base rate (prior probability of the adversarial class)

Frameworks of the book

Symbol	Meaning
$\ell \in \{1, \dots, 5\}$	level of the Cognitive Security Stack (L1 individual to L5 society)
$Q(t), Q_0$	decision quality at time t ; nominal decision quality
$R(\mathcal{A}, \pi; \mathcal{W})$	resilience functional, $\inf_{w \in \mathcal{W}} \frac{1}{T} \int_0^T Q(t)/Q_0 \, dt$
$\mathcal{A}$	socio-technical architecture
$\mathcal{W}, w$	manipulation set; a manipulation in it
π	defender policy
T	evaluation horizon

Decisions and games

Symbol	Meaning
$\mathcal{N}$	set of players
$a_i, \mathcal{A}_i$	action of player i ; action set (context: game models)
σ_i	mixed strategy of player i
u_i	utility of player i
θ, Θ	type; type space
λ_{QR}	precision of a quantal response

Stochastic models

Symbol	Meaning
P	transition matrix of a Markov chain (rows sum to one)
φ	stationary distribution of a Markov chain (row vector)
λ, μ	arrival rate; service rate
ϱ	utilization of a queue
γ	discount factor

Part I

Foundations

The Cognitive Domain as a Security Frontier

Learning Objectives

- ▶ Explain why the protected object of security extends from data and machines to the processes that turn information into judgments and actions.
- ▶ Describe cognition as the control layer of socio-technical and cyber-physical systems, and trace how a manipulated perception can produce a physical or financial effect without a technical breach.
- ▶ Distinguish influence, persuasion, manipulation, cognitive attack, and cognitive warfare by consent, deception, intent, and harm, and apply the distinction to documented incidents.
- ▶ Place a cognitive-security problem in the Cognitive Security Cube by its level in the Cognitive Security Stack, its stage in the cognitive loop, and its resilience phase.
- ▶ Compute a two-stage chain success probability and the resilience functional R for a piecewise-linear decision-quality curve.
- ▶ Use the MERIDIAN running example and the reading paths to plan a course through the book.

This chapter states the problem of the book and the frameworks used to organize it. [Sections 1.1 to 1.5](#) move the security boundary from data to decisions, separate manipulation from legitimate influence, and replace the weakest-link model with a system-level unit of analysis; [Sections 1.6 to 1.8](#) introduce the book's frameworks, the MERIDIAN running example, and the limits that bind the field.

MERIDIAN Running Example

MERIDIAN is a notional regional utility that supplies electricity and water to about 2.0 million residents; it is a teaching construct and is not modeled on a real organization. It runs grid and water control rooms and a security operations center (SOC) supported by an AI triage copilot.

	Sense	Model	Decide	Act	Learn
L5 Society					
L4 Organization					
L3 Human-AI team					
L2 AI agent					
L1 Individual					

Figure 1.1. Level map for Chapter 1. Rows are the five levels of the Cognitive Security Stack and columns are the five stages of the cognitive loop. Every cell is lightly shaded because this chapter motivates the whole grid and treats no single cell in depth; later chapters shade the cells they develop.

On a winter evening a storm cuts power to 310,000 customers. Within the hour the SOC queue triples, the customer call center is saturated, and a message that appears to come from the chief financial officer asks the finance office to expedite an emergency payment to a restoration contractor. At the same time, a post claiming that tap water is unsafe begins to circulate among the utility’s 240,000 social media followers. No firewall rule fails and no server is compromised. Whether MERIDIAN serves its customers well that night depends on what its analysts notice, what its finance staff believe, what its copilot recommends, and what the public trusts. The chapters that follow return to this night from each of those vantage points.

1.1 From Data Security to Decision Security

Consider three incidents that share a structure. In the first, a finance employee at a multinational firm joins a video conference, sees and hears colleagues including the chief financial officer, and executes a series of transfers; the colleagues were synthetic, and the firm later stated that its internal systems had not been compromised [5, 6]. In the second, an analyst working a well-filtered alert queue misses a genuine intrusion, because an effective upstream filter has made true threats rare in the stream that reaches the analyst [7, 8]. In the third, a language-model assistant retrieves a document containing text addressed to the assistant rather than about the document’s subject, and the assistant then issues a tool call with authority its user delegated for a different purpose [9].

In each case the classical properties of data security held for the stored records. Credentials were valid, servers were not implanted, and records were not altered. The decisive failure occurred in the passage from information to belief, from belief to priority, and from priority to authorized action. Those transitions are the object of this book.

1.1.1 Moving the Security Boundary

Conventional cybersecurity draws its boundary around data, computation, and communication. It protects confidentiality, integrity, and availability of those assets, and it treats the interpretation of data as lying outside the boundary, in a region labeled “the user.” That program remains necessary. The incidents above show that it is incomplete in a specific way: the security of a system also depends on the processes that convert information into decisions, and those processes can be attacked while every protected record stays intact.

Figure 1.2 redraws the boundary. Data security protects the evidence as a stored object; decision security protects the loop that senses evidence, forms a model, decides, acts, and learns. The figure marks where an adversary can enter the loop without breaching the smaller boundary, and the control family that attaches at each stage.

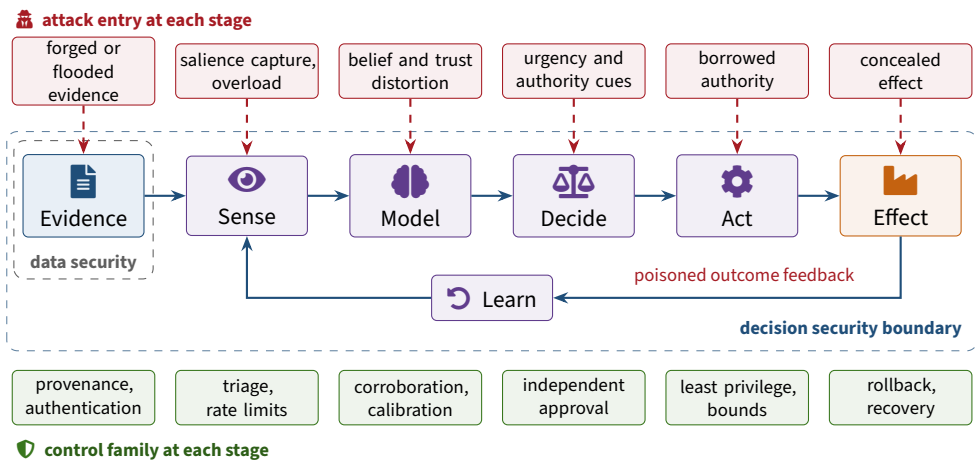


Figure 1.2. The decision loop under attack. Red boxes show where adversarial influence reaches the loop without breaching the data boundary, and green boxes show the control family attaching at each stage.

We define the field functionally, so that a single definition covers a person, a workflow, and an AI agent.

Definition 1.1 (Cognitive security). *Cognitive security* is the protection of decision-relevant information-processing capabilities, states, and couplings of human, artificial, and institutional systems against unauthorized manipulation, degradation, extraction, or coercive control, together with the capacity of those systems to keep deciding well under such pressure and to recover when it succeeds.

Three features of Definition 1.1 structure the book. It is functional: an artificial system counts as a cognitive asset because it performs perception, inference, memory, planning, or action selection, and no argument here depends on whether it understands or is conscious. It names three protected objects: a *capability* is a capacity to process, such as attention; a *state* is a current condition, such as a belief, a trust level, or an agent’s task representation; and a *coupling* is a relationship

through which one component's state constrains another's, such as the authority a workflow grants to an agent's output. Couplings are often the cheapest to attack and the least instrumented. Finally, it turns on the word *unauthorized*, because cognition is influenced continuously and legitimately; [Section 1.3](#) gives that word content.

1.1.2 Decision Assurance Rather Than Correct Belief

A field that protects belief formation invites the misreading that its goal is to make people believe correct things, which would license an authority to decide which beliefs are correct. The achievable objective is instead *decision assurance*: evidence traceable to its source, trust that tracks reliability, explicit and bounded authority, and the ability to contest and reverse high-impact conclusions. A decision-assurance architecture accepts that human and machine reasoning are fallible and limits the capacity of a single manipulation, forged cue, or overloaded operator to produce an irreversible consequence.

The framing also separates cognitive security from two neighbors. Safety engineering addresses harm whether caused by accident or adversary, and cognitive security reuses its redundancy, interlocks, and incident learning. Reliability, the second neighbor, is compared with security in [Section 1.4](#).

1.2 Cognition as the Control Layer of Socio-Technical Systems

A power grid, a water utility, a payment system, and a public health response are feedback systems. Sensors report the state of a process, software aggregates and displays the reports, and someone or something decides what to do. In most consequential systems that someone is a person, a team, or an institution, and increasingly it is an AI agent acting with delegated authority. Cognition in this sense is the *control layer*: the stage at which estimates of the system state are formed and control actions are chosen [3, 10].

1.2.1 The Layered View

[Figure 1.3](#) draws a cyber-physical utility as four coupled layers. The physical plant (substations, pumps, lines) is observed by sensors whose readings travel through supervisory control and data acquisition (SCADA) systems to operator displays and to an AI copilot. The operator combines the display, the copilot's recommendation, and organizational procedures into a decision, which travels back down as a command to actuators. The organization above sets procedures and authority and receives reports. Each upward arrow is a sensing path and each downward arrow is a control path; the operator and the copilot sit at the point where the two meet.

The control-theoretic reading has two consequences. First, a manipulated state estimate is as damaging as a manipulated actuator: a correct control law applied to a false estimate produces the wrong action. Langner's technical analysis of Stuxnet reports that, during one of its two attack routines, the malware recorded 21

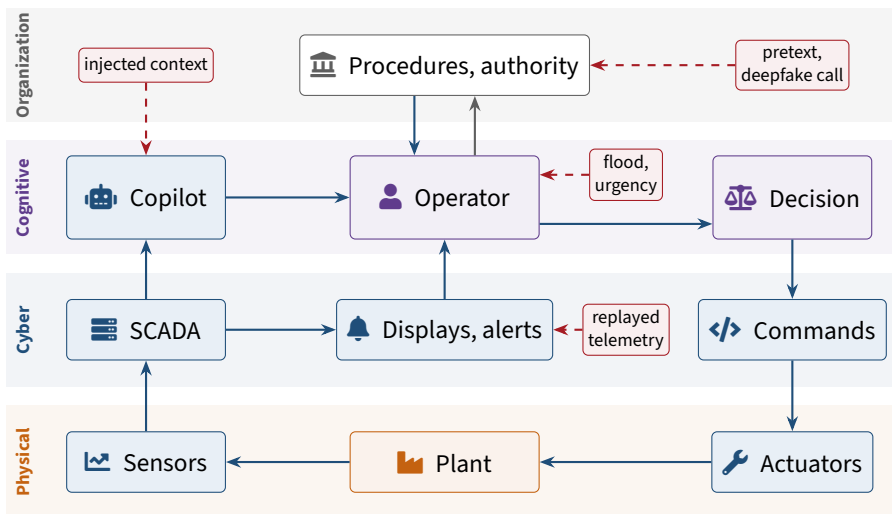


Figure 1.3. Cognition as the control layer of a cyber-physical utility. Upward arrows carry sensing and downward arrows carry control; the operator and the AI copilot form the state estimate and choose the action. Red annotations mark adversarial inputs that act on the control layer without compromising a controller.

seconds of sensor values and replayed them in a loop, so that control-room screens and software alarm routines showed normal operation [11]. Second, the capacity of the control layer is finite, and an adversary who raises its load degrades control without falsifying a single report. In the December 2015 attack on Ukrainian distribution companies, the joint analysis by the Electricity Information Sharing and Analysis Center (E-ISAC) and the SANS Institute reports a telephone denial of service against call centers alongside the disconnection of substations [12].

1.2.2 Two Directions of Propagation

Cognitive attacks cross layers in both directions, and the two directions call for different defenses. In the *cognitive-first* direction, the adversary manipulates a stimulus, such as a message, a call, or a synthetic video, and the resulting belief or approval gives access to a technical or financial system that the adversary could not reach directly. Social engineering and business email compromise follow this path, and defenses that address only the technical layer arrive after the decisive event.

In the *technical-first* direction the order reverses. The adversary generates feint activity that raises legitimate alerts, the technical layer behaves as designed, and the compromise is of attention: the analyst working the resulting queue slows, errs, and misses the alerts that matter. Huang and Zhu model this pattern as informational denial of service and design adaptive alert and attention management against it [2]. A cognitive attack therefore need not involve deception, which is why [Definition 1.1](#) names degradation alongside manipulation.

The layered view also supplies a defensive resource. Physical dynamics and independent sensors provide ground truth against which a manipulated

perception can be tested, such as a reported flow that violates conservation or a display quieter than the substation meters. Chapter 20 develops this co-design of cognitive, cyber, and physical defenses.

1.3 Influence, Manipulation, Attack, and Warfare

Definition 1.1 protects cognition against *unauthorized* influence, and the field depends on giving that word content. Without it, cognitive security expands to cover advertising, teaching, management, and disagreement, and a discipline that covers every change of mind constrains none. This section fixes five terms and the criteria that separate them.

1.3.1 Five Terms and Four Criteria

We distinguish the terms by four criteria. *Consent* asks whether influence engages the target's capacity to evaluate and refuse or works around it; *deception* asks whether it relies on false statements, false identities, or concealment of source or purpose; *intent* asks whether the influencing party is an adversary pursuing ends the target or its principal would reject; and *harm* asks whether it damages, or is designed to damage, a protected objective such as a safe operation, a lawful payment, or a population's capacity to form beliefs on evidence.

Definition 1.2 (Influence, persuasion, manipulation). *Influence* is a process by which one agent changes another agent's beliefs, priorities, or actions. *Persuasion* is influence that offers reasons, evidence, or appeals that the target can recognize and evaluate, and that leaves the target able to refuse. *Manipulation* is influence that works by circumventing the target's capacity to evaluate, typically through concealment, deception, or exploitation of predictable cognitive or situational vulnerabilities.

The definition of manipulation follows the account of Susser, Roessler, and Nissenbaum, who characterize it as hidden influence that exploits a target's vulnerabilities and thereby undermines autonomy [13]. Two features of this account matter for security. Manipulation does not require a false statement: a true but selectively ordered set of facts, a manufactured deadline, or a flood of legitimate alerts can bypass evaluation without a lie. Conversely, a message that is unwelcome, emotional, or wrong is not manipulation if it engages rather than circumvents the target's judgment.

Definition 1.3 (Cognitive attack). A *cognitive attack* is manipulation or degradation of a cognitive asset by an adversary that exploits vulnerabilities in the asset's information processing, or in its environment, in order to produce an unauthorized effect on a protected objective.

Each clause of **Definition 1.3** excludes a case. Requiring an adversary excludes accidents and honest error. Requiring exploitation excludes a target that changed its mind on the evidence. Requiring an effect on a protected objective excludes manipulations that succeed psychologically but reach no objective that the defender is charged to protect. The word *degradation* keeps attacks that exhaust

attention without deceiving a person inside the definition.

Definition 1.4 (Cognitive warfare). *Cognitive warfare* is the conduct of cognitive attacks at strategic scale and with persistence, by a state or organized actor pursuing political or military objectives against the decision capacity of a population, an institution, or a government.

Cognitive warfare differs from cognitive attack in objective, scale, and persistence rather than mechanism; doctrinal usage of the term varies across countries and alliances, and Definition 1.4 is the working definition of this book.

Figure 1.4 arranges the five terms against the criteria and scale. Each term to the right adds a required criterion, and the brackets record the nesting. Treating marketing as warfare, or a state influence operation as ordinary persuasion, is the same equivocation between rungs made in opposite directions.

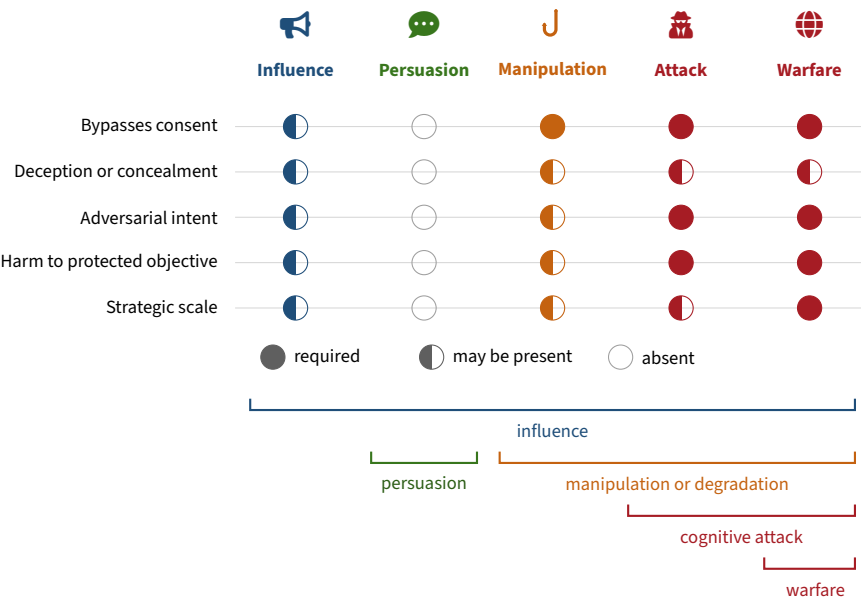


Figure 1.4. Influence, persuasion, manipulation, attack, and warfare distinguished by consent, deception, intent, harm, and scale. Each term to the right adds a required criterion, and the brackets show the nesting. Deception is optional even for attack and warfare, because degradation of attention can bypass evaluation without a false statement.

1.3.2 When the Security Framing Applies

Not every error, inaccurate belief, or poor decision is a cognitive-security incident. The security framing is warranted when four elements can be named: a cognitive asset whose processing matters to a protected objective, an adversary, an exploited vulnerability, and a consequential effect or a credible path to one. The adversary separates cognitive security from the sciences of cognition, reliability, and decision quality, which study the same mechanisms without one. The test cuts both ways: it removes much of what is loosely called cognitive attack, and it shows that

authority, repetition, social proof, defaults, and personalization become attack primitives when an adversary uses them to bypass evaluation at scale.

A boundary condition follows, and the book holds to it throughout. Dissent, minority views, and unconventional beliefs are not cognitive vulnerabilities and are not evidence of compromise. The security question is whether a belief or action was induced by manipulating the information environment or by defeating verification, not whether an analyst shares the belief. This is the origin of the pluralism constraint attached to the resilience functional in [Section 1.6](#).

Cognitive Security in Practice: The 2013 Hijacking of a News Agency Account

On 23 April 2013, shortly after 1 p.m. Eastern time, the Twitter account of the Associated Press (AP) posted a false report that explosions at the White House had injured the President [14]. AP staff stated within minutes that the account had been compromised, the White House press secretary said that the President was unharmed, and the account was suspended. In the few minutes before the correction spread, the Dow Jones Industrial Average fell by about 143 points and then recovered; Bloomberg reported that the drop briefly erased about \$136 billion in the value of the S&P 500 index [15]. A group calling itself the Syrian Electronic Army claimed responsibility; the claim was reported but not adjudicated in the sources cited here.

Figure 1.5 shows the sequence and the levels it crossed. Commentary at the time attributed the speed of the drop partly to automated trading that reacts to headlines [15], and the harm was bounded by how quickly authoritative correction reached the same audience.

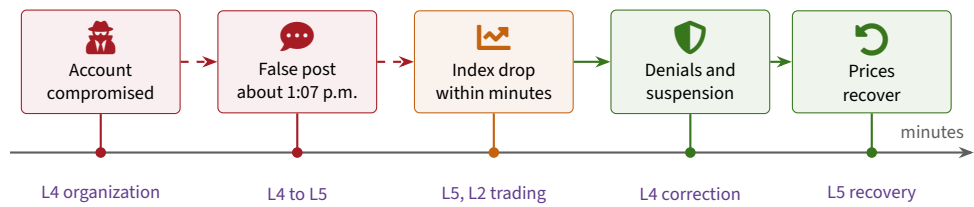


Figure 1.5. The 2013 AP account hijacking as a cross-level sequence. An organizational compromise produced a false report to which the market reacted within minutes, and authoritative correction bounded the loss. The horizontal axis is schematic.

1.4 Cognitive Security and Adjacent Fields

Cognitive security overlaps several established fields without reducing to one of them. Each neighbor protects a different object and models the adversary to a different degree, so each counts different events as incidents.

1.4.1 Six Neighbors

Cybersecurity protects systems, networks, data, and services against unauthorized access, modification, and denial. Its knowledge bases, such as MITRE ATT&CK for enterprise intrusions and MITRE ATLAS for attacks on machine-learning systems, catalog adversary techniques in detail [16, 17]. It models the adversary rigorously, but its incident ends where controls held: an approval that was valid in form but induced by a synthetic video lies outside its boundary.

Information integrity and the study of mis- and disinformation protect the quality and provenance of information ecosystems. Wardle and Derakhshan's framework of information disorder distinguishes misinformation, disinformation, and malinformation by falsity and intent to harm [18], and large-scale measurement has shown that false news can spread farther and faster than true news on a major platform [19]. The field centers on content. True information deployed to mislead, and attacks on attention that involve no false content, fall at or beyond its edges.

Human factors engineering studies human performance, error, workload, situation awareness, and reliance on automation [20, 21, 22]. Much of the toolkit of cognitive security comes from it. Its classical framing, however, designs against a distribution of operating conditions rather than against an adversary who chooses those conditions.

AI safety and AI security study failures of AI systems. Safety research addresses accidents such as reward hacking, unsafe exploration, and distribution shift [23]; security research addresses adversarial inputs, data poisoning, and prompt injection [9]. Both focus on the model or agent. The coupling between an AI output and a human decision, including the authority an organization grants that output, is often outside their unit of analysis.

Cognitive warfare and information operations studies address strategic manipulation of populations and institutions by states and organized actors [24]. The field is rich in doctrine and case history, largely descriptive, and oriented to the organizational and societal levels; it seldom addresses the design of individual workflows or AI agents.

Neurosecurity protects neural devices and neural data against adversaries who would alter, block, or eavesdrop on neural signals [25]. It addresses the physical substrate of cognition, a component of the broader problem that becomes more pressing as brain-computer interfaces mature.

Figure 1.6 compares the six fields with cognitive security; the ratings are this book's judgment of typical emphasis, not a measurement. Several neighbors protect a component of the loop and model the adversary to some degree, but the coupled loop, where human cognition, AI outputs, and organizational authority combine into an action, is central in none of them. That is where cognitive security draws its boundary, borrowing from each neighbor to supply the segment of an attack path that none describes.

1.4.2 Reliability and Security of Cognition

One further distinction prevents a category error. *Cognitive reliability* is the capacity of a cognitive system to sustain its mission under stated conditions of uncertainty,

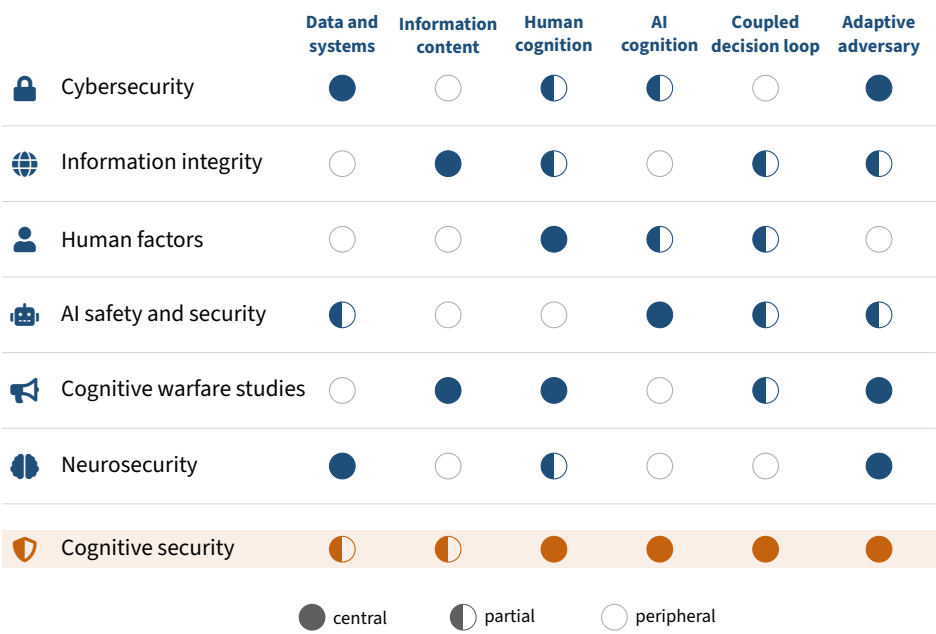


Figure 1.6. Cognitive security and its neighbors, rated by typical emphasis as judged in this book. The coupled decision loop is central only in the bottom row, which is where cognitive security draws its boundary.

disturbance, and error; *cognitive security* is the capacity to do so when an adversary exploits cognitive vulnerabilities [3]. Crossing the presence of an adversary with the involvement of cognitive vulnerabilities gives four regimes, shown in Figure 1.7. System reliability and conventional cybersecurity occupy the top row; human reliability analysis and usable design occupy the lower left. The lower right is the subject of this book. Much of the lower-left toolkit transfers to it. What does not transfer is the assumption of an indifferent environment, because an adversary’s first move is to leave the stated conditions under which a reliability control was validated.

1.5 Beyond the Weakest-Link Model

The most repeated proposition in security awareness is that the human is the weakest link. It supplies a simple causal story and a simple remedy: train, monitor, or remove the person. We examine it because the errors it produces are systematic, and because the alternative is not that people perform well regardless of conditions but a different unit of analysis.

1.5.1 A Category Error About Cause

The metaphor treats a person as a defective component attached to an otherwise sound architecture. It collapses the proximate action into the system cause. If a workflow makes the secure action slow, socially costly, or incompatible with finishing the task, then bypassing it is the predictable response of the system, and

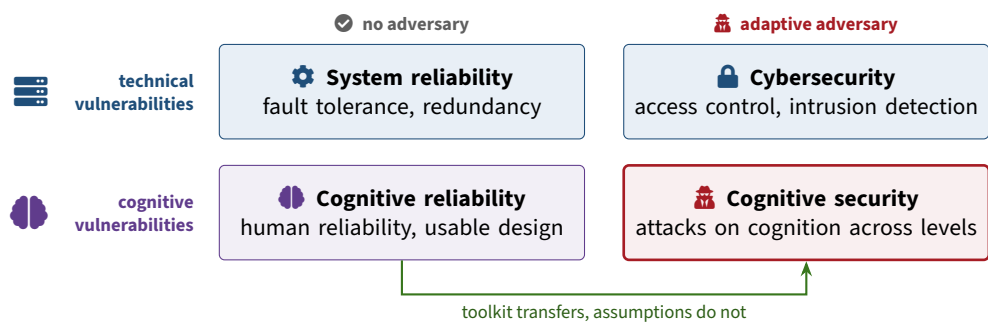


Figure 1.7. Four regimes defined by the presence of an adversary and the involvement of cognitive vulnerabilities. Cognitive security occupies the lower right. The arrow indicates that methods from cognitive reliability carry over, while their assumption of a non-adversarial environment does not.

the design that produced it is the finding. Human-factors research reached this conclusion in other domains decades ago: recurring error is evidence about the conditions under which work is done, and Reason’s analysis separates the active failures of individuals from the latent conditions in the system that make those failures likely [20].

Figure 1.8 states the reframing as a controlled comparison. The same employee receives the same urgent request in two workflows; in one the transfer executes and in the other it is held. The person did not change, so a stable trait of the person cannot explain the difference.

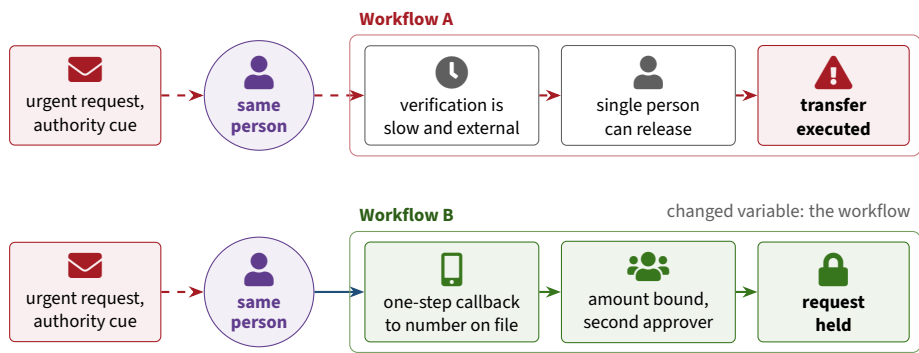


Figure 1.8. A counterfactual test of the weakest-link claim. The same person faces the same request in both rows; only the workflow changes, and with it the outcome. The defensible unit of analysis is the person in a workflow under a stated threat model.

1.5.2 Three Findings That Break the Metaphor

The first finding is the *prevalence effect*: observers miss rare targets far more often than common ones [7], and Sawyer and Hancock argue that effective automated filtering creates this condition in security operations, because a better filter makes the true threats reaching the analyst rarer [8]. The remedy is queue design

and adaptive automation that budget human attention [1, 2], and the problem becomes a security problem when an adversary manipulates prevalence, timing, or workload.

The second finding is that *trust should be calibrated, not maximized or minimized*. The design goal for reliance on automation is that reliance track the automation's actual reliability in context [26]; both misuse (over-reliance) and disuse (under-reliance) degrade performance [22]. The weakest-link framing sees only over-trust and therefore recommends blanket skepticism. An adversary whose goal is paralysis, delay, or the rejection of accurate warnings would recommend the same.

The third finding is that *heuristics exploit regularities*. Heuristics are generally useful and occasionally produce systematic error [27], and bounded rationality reflects limited information, attention, and computation rather than a defect [28]. Deferring to authority and acting on urgency are sensible where those cues track genuine need; they become attack vectors when an adversary can counterfeit the cue cheaply and the workflow offers no independent check. The remedy is to make such cues costly to counterfeit or insufficient by themselves to authorize a high-impact action.

1.5.3 Asymmetric Friction and the Unit of Analysis

These findings point to a design principle that we call *asymmetric friction*: make verification, reporting, and escalation easy, and make irreversible high-impact actions slower and more deliberate. Secure behavior loses whenever it consistently costs more time or effort than the insecure shortcut, so the intervention changes that comparison rather than restating a policy. Friction is itself a budgeted resource. Applied uniformly, it is spent where it buys little and routed around where it would have mattered.

The same reasoning argues against stable individual risk scores. Susceptibility varies with workload, fatigue, time pressure, available verification tools, and adversary adaptation, so a trait-shaped score misfits a largely state-driven quantity; scoring also leaves the exposing workflow unchanged and can erode the psychological safety on which reporting depends. The unit of analysis that we adopt is the *person in a workflow under a specified threat model*.

The 2024 fraud at Arup, a multinational engineering firm, illustrates the point. A finance employee in its Hong Kong office who initially suspected phishing was reassured by a video conference with a synthetic chief financial officer and colleagues, and then made 15 transfers totaling HK\$200 million, about US\$25.6 million [5]; Arup later confirmed that its internal systems had not been compromised [6]. Individual vigilance operated, but a richer channel manufactured corroboration and the workflow let one person release every transfer without verification outside the adversary's channel, so the controls that would have held were organizational.

1.6 The Frameworks of This Book

1.6.1 The Cognitive Security Stack

Cognitive security names several distinct problems, which we first separate by the level at which the protected cognition is carried out.

Definition 1.5 (Cognitive Security Stack). The *Cognitive Security Stack* consists of five levels indexed by $\ell \in \{1, \dots, 5\}$. Level L1 is the *individual human*, whose protected cognition comprises attention, perception, memory, belief, judgment, and emotion. Level L2 is the *artificial agent*, whose functional cognition comprises perception, context, memory, reasoning, goals, and tool use. Level L3 is the *human-AI team*, whose protected properties are delegation, reliance, shared situation awareness, and explanation. Level L4 is the *organization*, whose cognition resides in procedures, approvals, institutional memory, and command and escalation. Level L5 is *society and the information ecosystem*, whose protected properties are shared beliefs, public trust, and collective sensemaking.

Characteristic threats differ by level: phishing, pretexting, and attentional denial of service (ADoS), in which an adversary exhausts or misallocates attention, at L1; prompt injection, memory poisoning, and collusion among agents at L2; automation bias and *authority laundering*, in which a manipulated input gains authority by passing through an AI recommendation that a person accepts, at L3; business email compromise and insider manipulation at L4; and disinformation and coordinated inauthentic behavior at L5. The ordering reflects scale of aggregation, not importance.

Many consequential attacks enter at one level and take effect at another, and defenses designed for a single level miss them. Figure 1.9 draws seven such *cross-level pathways*. Pathway (a) is the Arup case of Section 1.5 and pathway (d) the AP case of Section 1.3; pathways (f) and (g) are the Stuxnet and Ukraine cases, which reach the physical process [29, 12].

1.6.2 The Cognitive Loop

Within each level, cognition is modeled as a loop with five stages; attacks target a stage, and effects propagate around the loop and across levels.

Definition 1.6 (Cognitive loop). The *cognitive loop* of a cognitive system consists of five stages. *Sense* covers attention and perception of the environment. *Model* covers belief formation, memory, and trust in sources. *Decide* covers judgment and choice among actions. *Act* covers execution, communication, and the exercise of authority. *Learn* covers updating beliefs, trust, and policies from feedback.

Figure 1.10 draws the loop with a characteristic attack at each stage and its reading for an individual, an organization, and an AI agent. Attacks on the forward path from Sense to Act must be repeated for each decision, whereas an attack that reaches Learn changes the loop and persists after the adversarial input stops. The Sense and Model stages also contain the three levels of situation awareness (perception, comprehension, and projection) [21], each a separable

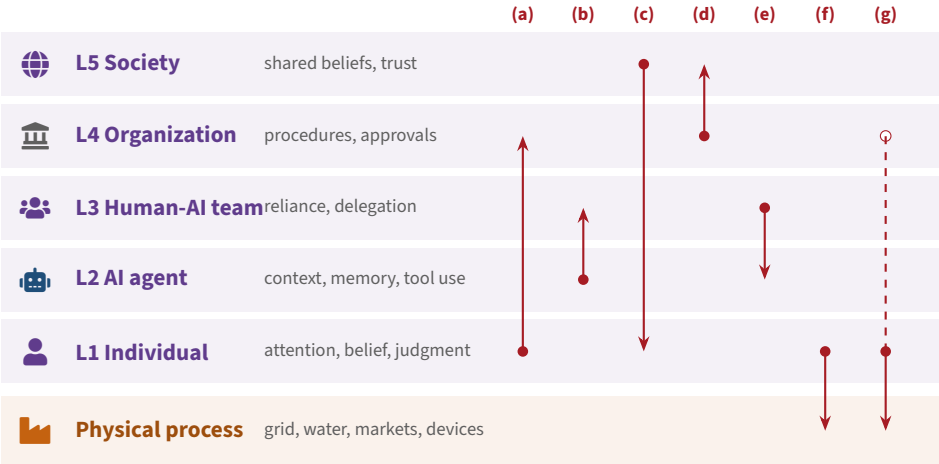


Figure 1.9. The Cognitive Security Stack with cross-level pathways. Each red arrow runs from the level where an attack enters (dot) to the level where it takes effect: (a) deepfake payment fraud; (b) injected document steering a copilot; (c) viral rumor during an outage; (d) compromised official account moving a market; (e) biased feedback shifting a model; (f) falsified operator displays; (g) call-center flooding during a grid attack, passing through the organization (open circle).

target.

1.6.3 The Cognitive Security Cube

A level and a loop stage say where an attack acts. A defender also needs to know *when* in the life of an incident a control operates. We adopt the four resilience goals used in cyber resiliency engineering: to *anticipate* adversity by maintaining preparedness, to *withstand* it by continuing essential functions, to *recover* functions during and after it, and to *adapt* functions and supporting capabilities in response to changes [30].

Definition 1.7 (Cognitive Security Cube). The *Cognitive Security Cube* is the product of three axes: the level ℓ of the Cognitive Security Stack (L1 to L5), the stage of the cognitive loop (Sense, Model, Decide, Act, Learn), and the resilience phase (Anticipate, Withstand, Recover, Adapt). A cognitive-security problem, incident, or control is placed in the Cube by the cell or set of cells it occupies.

Figure 1.11 draws the Cube with 100 cells as four slices, one per resilience phase; each slice has the layout of the level map that opens each chapter. Controls are placed like attacks: callback verification of payments occupies (L4, Act, Withstand), and training for finance staff occupies (L1, Model, Anticipate), so the Cube shows which cells have no control.

Example 1.1 (Placing incidents in the Cube). The problem is to place three incidents in the Cube so that the placement identifies the controls that failed or are needed, given their public descriptions. In the Arup case the decisive failure was the release of 15 transfers without out-of-band verification, so the primary cell is (L4,

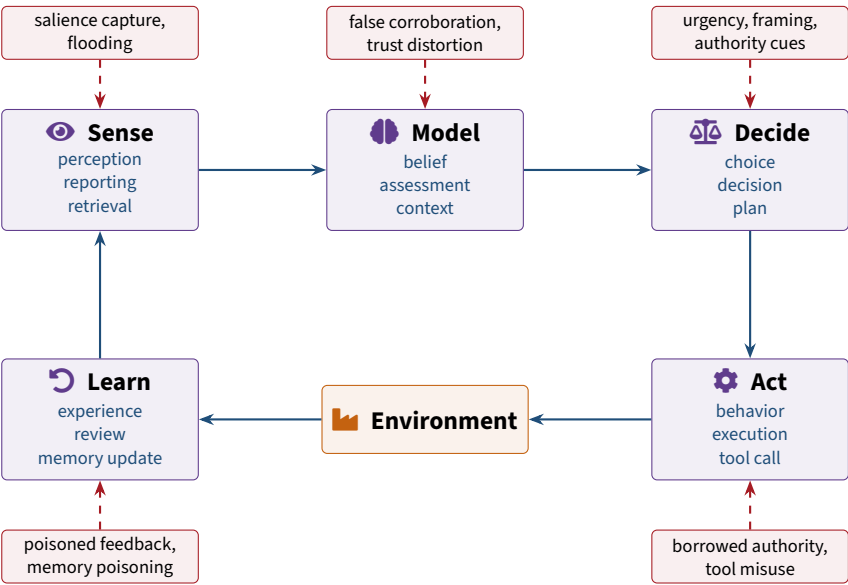


Figure 1.10. The cognitive loop. Red boxes give a characteristic attack at each stage, and the blue lines in each stage box read the stage for an individual, an organization, and an AI agent, in that order. Act reaches the environment, whose feedback enters Learn.

Act, Withstand) and the entry cell is (L1, Model, Withstand), where the video call manufactured corroboration. In the AP case harm was bounded by the speed of correction, so the primary cell is (L5, Model, Recover), with entry at (L4, Act). For an instruction hidden in a retrieved document, the primary cell is (L2, Model, Anticipate), because the control separates retrieved data from instructions before deployment, and the pathway continues to (L3, Decide) when an analyst accepts the recommendation. The conclusion is that each incident spans cells at two or more levels, so a program that audits controls level by level would not find the gap that each case exploited.

1.6.4 The Cognitive Attack Chain and the Cognitive Defense Chain

The Cube places a problem; it does not describe how an attack unfolds. For that we use a staged model in the tradition of the intrusion kill chain, which organizes network defense around the observation that an intrusion must complete a sequence of steps and can be stopped at each [31].

Definition 1.8 (Cognitive attack chain and cognitive defense chain). The *cognitive attack chain* consists of seven stages: (1) reconnaissance and profiling of targets; (2) target and channel selection; (3) pretext and content development; (4) delivery and exposure; (5) cognitive exploitation, comprising attention capture, belief distortion, or decision steering; (6) action and effect; and (7) reinforcement and persistence. The *cognitive defense chain* attaches four families of controls to these stages: *prevention*, which reduces exposure and susceptibility before delivery; *detection*, which senses manipulation during delivery and exploitation; *response*,

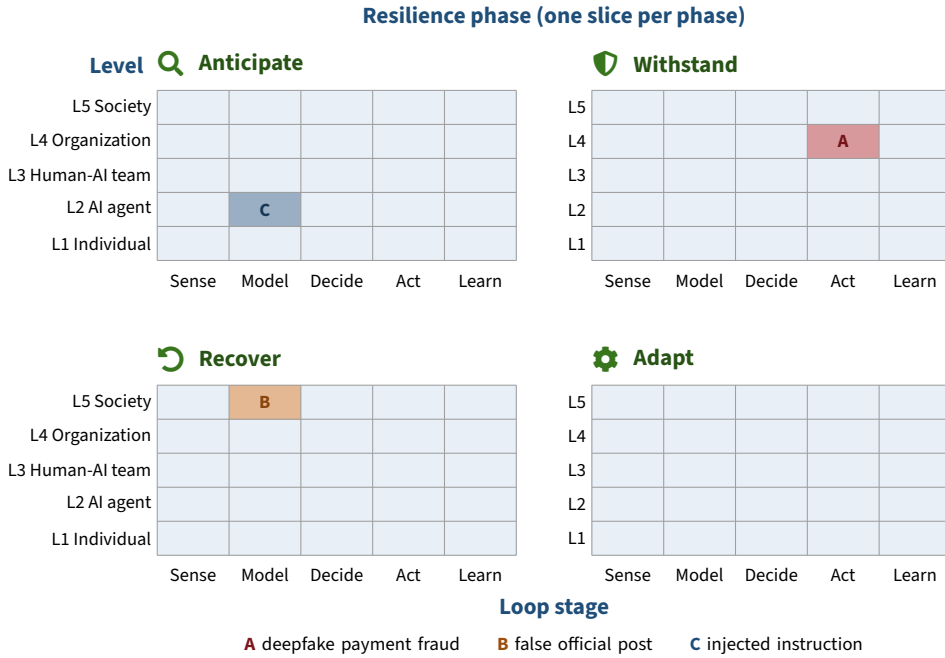


Figure 1.11. The Cognitive Security Cube of level by loop stage by resilience phase, drawn as four slices, one for each resilience phase. Each slice is a level-by-stage grid like the level map that opens each chapter. Shaded cells mark the primary placements in [Example 1.1](#): (A) deepfake payment fraud at (L4, Act, Withstand), (B) a false official post at (L5, Model, Recover), and (C) an injected instruction at (L2, Model, Anticipate).

which interrupts and corrects before or during action; and *recovery*, which restores decision quality and feeds lessons back into prevention.

[Figure 1.12](#) draws the two chains as a ladder. Unlike its network counterpart, the cognitive chain changes level, in the Arup case from L1 to L4 at the action stage, and stage (7) makes it a cycle, because a successful manipulation can alter memory, trust, or procedure so that the next attempt starts further along.

A simple quantitative reading of the chain treats each stage as a trial that the attack must pass. Let $p_s \in [0, 1]$ be the probability that stage s succeeds in the absence of controls, given that the attack has reached it, and let $d_s \in [0, 1]$ be the probability that the defense chain stops at stage s an attack that would otherwise pass it. Write $q_s = p_s(1 - d_s)$ for the probability of passing stage s .

Assumption 1.1 (Stage-wise independence). Conditional on reaching stage s , passing stage s is independent of the outcomes at earlier stages, with probability q_s .

Proposition 1.1 (Chain success and proportional interdiction). *Under Assumption 1.1,*

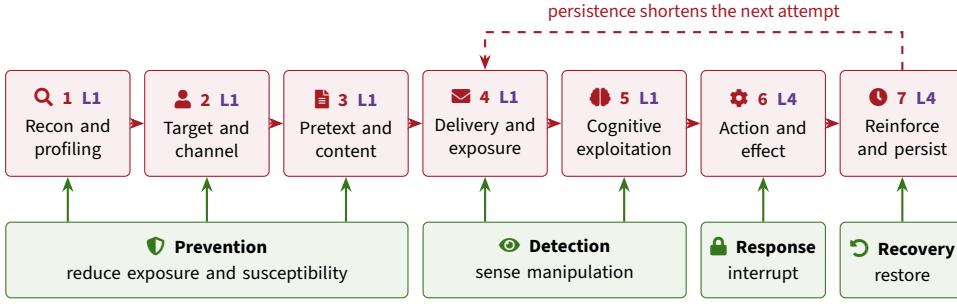


Figure 1.12. The cognitive attack chain (red) and the mirrored defense chain (green). Green arrows show the control family acting on each stage, and purple labels give the level of each stage in the Arup case. The return path from stage 7 shows that persistence lets a later attempt begin at delivery.

the probability that an attack starting at stage 1 completes stage S is

$$P_S = \prod_{s=1}^S p_s(1 - d_s). \quad (1.1)$$

Moreover, (i) P_S is nondecreasing in each p_s and nonincreasing in each d_s ; (ii) a control that multiplies q_s by a factor $\kappa \in [0, 1]$ multiplies P_S by κ , whichever stage s it acts on; and (iii) controls at k distinct stages that each multiply their stage's pass probability by κ multiply P_S by κ^k .

Proof. Let E_s be the event that the attack passes stage s . The attack completes stage S exactly when $E_1 \cap \dots \cap E_S$ occurs. By the chain rule of probability, $\mathbb{P}(E_1 \cap \dots \cap E_S) = \prod_{s=1}^S \mathbb{P}(E_s | E_1 \cap \dots \cap E_{s-1})$, and by [Assumption 1.1](#) each factor equals $q_s = p_s(1 - d_s)$, which gives (1.1). For (i), every factor lies in $[0, 1]$, so $\partial P_S / \partial p_s = (1 - d_s) \prod_{r \neq s} q_r \geq 0$ and $\partial P_S / \partial d_s = -p_s \prod_{r \neq s} q_r \leq 0$. For (ii), replacing q_s by κq_s in the product replaces P_S by κP_S because multiplication is commutative, so the position of s does not matter. For (iii), applying (ii) once for each of the k distinct stages gives the factor κ^k . $\square$

Part (ii) says that a proportional reduction is worth the same wherever it is achieved, and part (iii), the case for defense diversity, holds only under [Assumption 1.1](#), because controls that fail together do not multiply.

Example 1.2 (A two-stage cross-level chain at MERIDIAN). The problem is to estimate MERIDIAN's annual expected loss from deepfake-supported payment fraud with and without callback verification. MERIDIAN requires callback verification to a number on file for bank-detail changes and for payments at or above \$50,000. For this example we assume 20 fraudulent high-value requests per year with a mean of \$400,000, a probability $p_5 = 0.30$ that the approver is persuaded (stage 5, L1), and a probability $d_6 = 0.90$ that an independent callback to a number on file stops a forged request (stage 6, L4), with stages 1 to 4 already passed, no control at stage 5 ($d_5 = 0$), and no intrinsic failure at stage 6 ($p_6 = 1$).

For the solution, without callback verification the success probability is 0.30 and the expected annual loss is $20 \times 0.30 \times \$400,000 = \2.4 million. With callback verification, [Theorem 1.1](#) gives $0.30 \times (1 - 0.90) = 0.03$ and an expected loss of \$240,000.

The conclusion is that the organizational control reduces expected loss by a factor of ten when its failures are independent of the persuasion stage. If the adversary can also control the callback channel, for example through an earlier change of the number on file, much of that reduction is lost; Chapter 7 quantifies this common-mode penalty.

1.6.5 Decision Quality and the Resilience Functional

The last framework measures outcomes. Cognitive attacks rarely produce a single event that is either prevented or not; they degrade the quality of decisions over a period, and defenses shorten that period or reduce its depth. We therefore measure the protected system by a performance function over time.

Definition 1.9 (Decision quality and resilience functional). Let $\mathcal{A}$ denote the socio-technical architecture, π the defender policy, $\mathcal{W}$ the manipulation set considered, and $w \in \mathcal{W}$ a manipulation. The *decision quality* $Q(t; \mathcal{A}, \pi, w) \geq 0$ is a performance measure of the protected decision process at time $t \in [0, T]$, and $Q_0 > 0$ is its nominal value. The *resilience functional* is

$$R(\mathcal{A}, \pi; \mathcal{W}) = \inf_{w \in \mathcal{W}} \frac{1}{T} \int_0^T \frac{Q(t; \mathcal{A}, \pi, w)}{Q_0} dt. \quad (1.2)$$

Decision quality is chosen for the level at hand: the probability of a correct decision for an individual, the fraction of true alerts handled within deadline for a SOC, or the fraction of a population holding accurate safety-relevant beliefs during an outage. When $Q(t) \leq Q_0$ throughout, $R = 1$ means that nominal quality was maintained, except on a set of times of measure zero, under every manipulation in $\mathcal{W}$, and $1 - R$ is the worst-case normalized loss area; if quality can exceed Q_0 , gains above nominal offset losses in the integral. The integral form follows the resilience-triangle tradition in infrastructure engineering [32]; the infimum adds the adversary.

Two constraints specific to cognition accompany R throughout the book. Let Π be the set of feasible defender policies. The *autonomy constraint* restricts Π to policies that do not covertly manipulate or coerce the protected population, and the *pluralism constraint* restricts it further to policies that do not treat dissent or unconventional belief as compromise. Writing $\Pi_{AP} \subseteq \Pi$ for the policies that satisfy both, cognitive defense design is the constrained problem

$$\max_{\pi \in \Pi_{AP}} R(\mathcal{A}, \pi; \mathcal{W}). \quad (1.3)$$

Without these constraints, the maximization would favor belief control: a defender who covertly steers what a population believes, or suppresses minority views as noise, could raise a measured $Q(t)$ while destroying the property the measure was meant to protect.

Figure 1.13 shows a decision-quality curve with the four phases. Anticipation sets starting conditions; prevention and detection set the depth and duration of the Withstand phase; response sets the rate of recovery; and in the Adapt phase quality can settle above its earlier level.

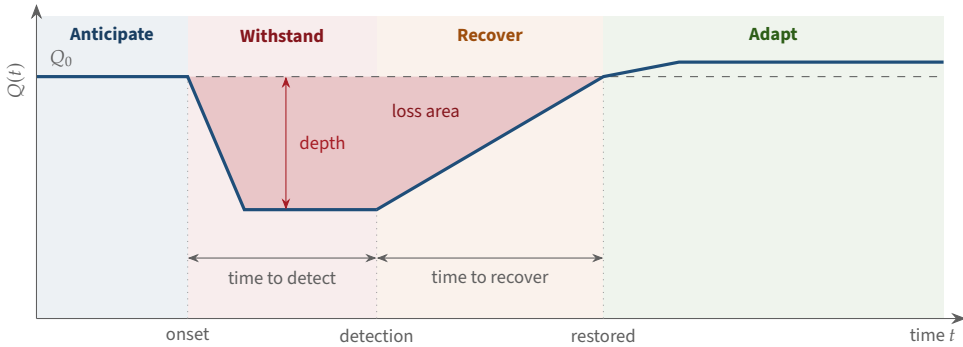


Figure 1.13. The decision-quality resilience curve. Quality falls after onset (Withstand), returns after detection (Recover), and can settle above its earlier level (Adapt). Depth, time to detect, and time to recover determine the shaded loss area that R normalizes.

Example 1.3 (Resilience of MERIDIAN SOC triage). The problem is to compute R for the MERIDIAN SOC over a horizon of $T = 24$ hours against a manipulation set of two campaigns, and to see how improving detection of one campaign changes the result. Decision quality is the fraction of true incidents triaged within the 30-minute deadline, with nominal value $Q_0 = 0.95$ (an assumption for this example). The given campaigns are modeled by piecewise-linear curves of Q/Q_0 . Campaign w_1 is a feint flood: quality is nominal until hour 4, falls linearly to $0.40 Q_0$ (that is, $Q = 0.38$) by hour 5, stays there until detection and surge staffing at hour 7, and returns linearly to Q_0 by hour 12. Campaign w_2 is a low-and-slow campaign of misleading low-priority alerts: quality falls from hour 1 to $0.70 Q_0$ ($Q = 0.665$) at hour 2, stays there until detection at hour 14, and recovers by hour 18.

For the solution, each loss area is the area of a trapezoid below Q_0 . For w_1 , it is $0.60 \times (0.5 + 2 + 2.5) = 3.00$ hours and the time-averaged ratio is $1 - 3.00/24 = 0.875$. For w_2 , it is $0.30 \times (0.5 + 12 + 2) = 4.35$ hours and $1 - 4.35/24 \approx 0.819$. Hence $R = \min\{0.875, 0.819\} \approx 0.819$, attained by the shallower but longer campaign w_2 . If an improved detector for w_2 moves its detection to hour 6 with recovery by hour 10, its loss area falls to $0.30 \times (0.5 + 4 + 2) = 1.95$ hours and its ratio rises to about 0.919; the infimum is then attained by w_1 , and R rises to 0.875. Figure 1.14 shows the three curves.

The conclusion is that duration matters as much as depth, and that mitigating one campaign changes the binding manipulation, so the next investment should target w_1 .

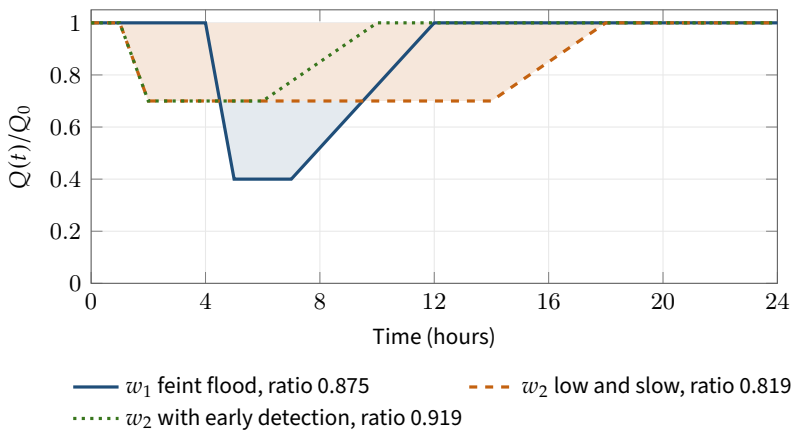


Figure 1.14. Decision-quality curves for Example 1.3. The shaded loss areas of w_1 (blue) and w_2 (orange) show that the shallower campaign has the larger area. With early detection of w_2 (dotted), w_1 becomes binding.

1.7 The MERIDIAN Running Example and Reading Paths

A book that spans individual attention, AI agents, organizations, and public information needs a common setting in which the levels interact.

1.7.1 MERIDIAN

MERIDIAN is a notional regional utility created for teaching; it is not modeled on a real organization, and its name is a placeholder. It supplies electricity and water to a region of about 2.0 million residents, with 1.2 million electricity accounts and 0.5 million water accounts. It employs 4,800 staff, has about 1,500 contractors with on-site or remote access and 220 active vendors, earns annual revenue of \$3.1 billion, and spends \$38 million a year on security, of which \$3.2 million funds a cognitive-security program of training, verification procedures, human-factors engineering, and monitoring of influence campaigns.

Figure 1.15 shows the architecture. The operational-technology column is supervised from grid and water control rooms on 12-hour shifts. The enterprise column runs MERIDIAN Assist, an AI assistant with access to email, tickets, and documents. Between them a security operations center (SOC) receives correlated alerts through an AI triage copilot, and above sits the public, reached through social media accounts and a call center.

Table 1.1 collects the values used in this chapter and its exercises.

1.7.2 A Systems-Science Perspective

The book treats cognition as a decision-producing function of coupled human, machine, and institutional systems that can be modeled, attacked, measured, defended, and made resilient [3]. Four features of this view matter in MERIDIAN. An input-output view characterizes a component by its responses without committing to contested internal mechanisms. Modularity lets an analyst model

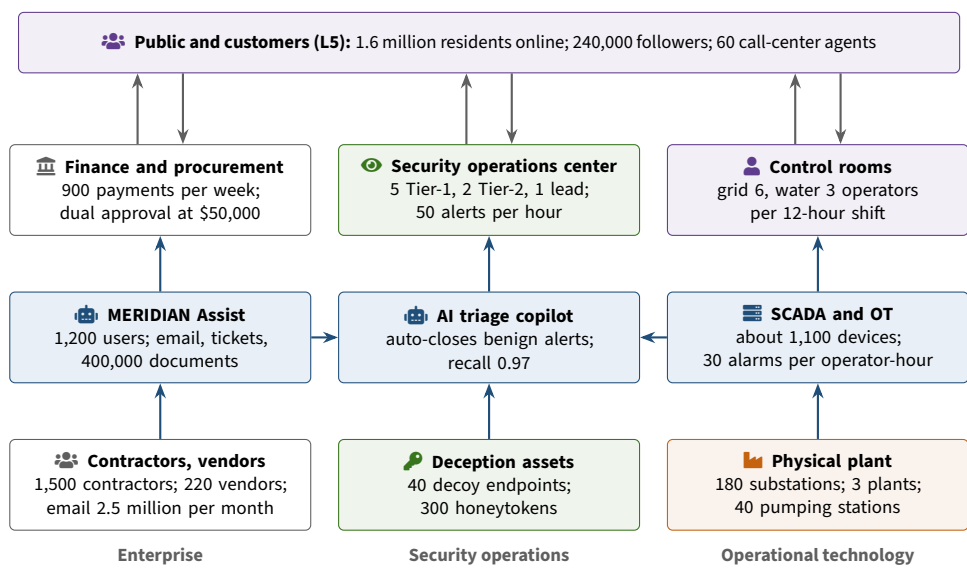


Figure 1.15. Architecture of the notional MERIDIAN utility: enterprise (left), security operations (center), and operational technology (right), below the public. Values follow the book’s MERIDIAN specification.

the SOC queue in detail while abstracting the grid, or the reverse. Emergence is made explicit: the coupling of MERIDIAN Assist, the finance office, and the vendor portal creates attack paths that no component possesses alone, and a system model writes that coupling down. Strategic interaction is modeled directly, because attacker and defender act on predictions about each other [10].

The methods follow from these features: Bayesian inference and detection for hidden states under low base rates, choice models for bounded decision-makers, Markov and partially observable models for evolving states, games and information design for adaptive adversaries, queueing for attention, network diffusion for society, and experimental methods for evaluation. Each is introduced where it is first applied.

1.7.3 Reading Paths

The book has 22 chapters in seven Parts. Part I (Chapters 1 to 4) lays foundations and Part II (Chapters 5 to 7) develops models and defense engineering. Parts III to VI follow the Stack: individual cognition (Chapters 8 to 11), organizational and societal cognition (12 to 14), cognitive mechanisms for defensive advantage (15 and 16), and artificial and hybrid cognition (17 to 20), closing with cognitive-cyber-physical security. Part VII (21 and 22) covers evaluation, governance, and frontiers. Parts III to VI can each be read after Parts I and II. Figure 1.16 shows seven suggested paths, from a graduate overview to a professional short course and a research seminar.

Table 1.1. MERIDIAN values used in this chapter (notional).

Component	Parameter	Value
SOC	Tier-1 analysts per shift	5
SOC	Alert arrivals (per hour)	50
SOC	Tier-1 service rate (per analyst-hour)	15
SOC	True-incident fraction of alerts	2%
SOC	Triage deadline for true incidents (minutes)	30
Email	Phishing messages reaching inboxes (per month)	600
Email	Click rate, baseline and after training	8%, 4%
Finance	Vendor payments (per week)	900
Finance	Dual-approval threshold (USD)	50,000
Finance	Bank-detail change requests (per month)	40
Finance	Callback verification time (minutes)	6
Organization	Loaded staff cost (USD per hour)	60
Public	Customers without power, storm scenario	310,000

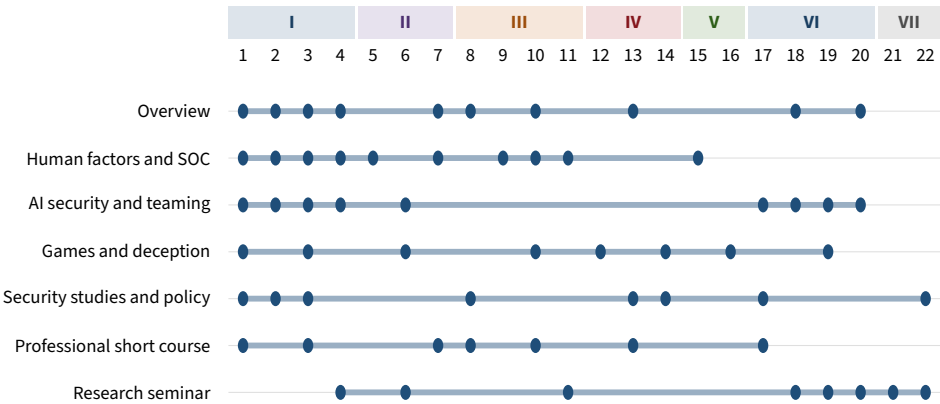


Figure 1.16. Reading paths through the book. Each row is a suggested course, dots mark the chapters it uses, and the column headers group chapters into Parts.

1.8 Ethics and Limits

Cognitive security studies manipulation in order to defeat it, and its defenses act on the attention, beliefs, and decisions of people. Both facts create risks that are specific to the field. A defense that monitors attention can become workplace surveillance; a defense against disinformation can become censorship; a defense that shapes beliefs can itself become manipulation. This section states the harms that the frameworks of this chapter can produce, the conditions under which their use is legitimate, and the limits of what the frameworks can establish.

1.8.1 Harms of Cognitive Defenses

Four harms recur. *Surveillance*: measuring decision quality or susceptibility invites monitoring, and indicators of attention, stress, or trust are inferences about mental states that the monitored person cannot easily contest. *Censorship and chilling*

effects: at L5, interventions against false narratives can remove or demote lawful speech, with errors falling unevenly across communities and viewpoints. *Covert steering*: a defender who uses an attacker’s levers without disclosure violates the autonomy that [Definition 1.1](#) protects, even when the intended belief is accurate. *False positives and bias*: detectors applied to people err, their errors can correlate with role, language, age, or disability, and a false accusation of compromise damages trust and reporting.

The frameworks carry their own risks. Operational descriptions of manipulation would assist attackers, so this book describes mechanisms at the level of the published literature. A program that optimizes a poorly chosen $Q(t)$ can suppress dissent or inconvenient reports because they lower the metric, which makes measurement validity an ethical requirement as well as a scientific one.

1.8.2 Conditions for Legitimate Use

The autonomy and pluralism constraints of (1.3) express these concerns formally. [Figure 1.17](#) places representative defenses in the space of defender policies. Defenses that act on channels, workflows, and authority, and training delivered with disclosure and consent, lie inside both constraints; covert nudging violates autonomy, and removal of content because it expresses a minority position violates pluralism, whatever their effect on a measured $Q(t)$.

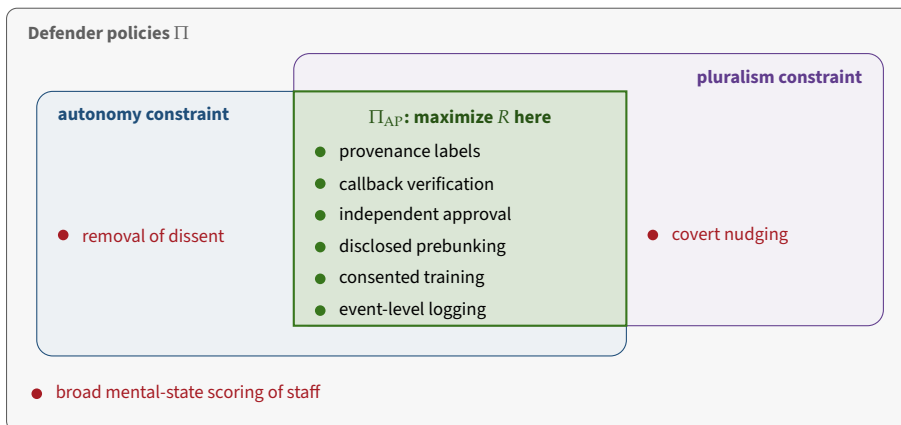


Figure 1.17. Feasible defenses under the autonomy and pluralism constraints. The green intersection Π_{AP} contains defenses that act on channels, workflows, and authority, or influence people with disclosure and consent. Red examples violate pluralism (removal of dissent), autonomy (covert nudging), or both (broad mental-state scoring of staff).

Legitimate use also requires proportionality between intrusiveness and threat; transparency toward those affected; minimization, collecting event structure (who approved which payment) before inferences about mental states; contestability of findings about people and accounts; and independent oversight of programs that act at the society level. Research that deceives participants to measure susceptibility requires human-subjects review, informed consent or a justified waiver, and debriefing.

1.8.3 Limits of the Frameworks

The frameworks of this chapter are organizing devices and approximations. The levels of the Stack have porous boundaries, and the five-stage loop simplifies processes that run in parallel. The chain model of [Theorem 1.1](#) relies on stage-wise independence. The resilience functional requires a measurable decision quality and a stated manipulation set, and an adversary outside $\mathcal{W}$ is not covered by the resulting number. These limits require that each numerical claim in this book state its assumptions. Chapter 22 treats the law, governance, and research ethics of the field in depth.

1.9 Summary

This chapter argued that security must protect how information is perceived, trusted, and turned into action, and not only the data and machines that carry it. In the Arup fraud, the 2013 AP account hijacking, and prompt injection against AI assistants, data security held while the decision process failed. We defined cognitive security as the protection of decision-relevant capabilities, states, and couplings of human, artificial, and institutional systems against unauthorized manipulation, degradation, extraction, or coercive control, with decision assurance as its achievable objective, and we described cognition as the control layer of socio-technical and cyber-physical systems, where attacks cross layers in both directions.

We distinguished influence, persuasion, manipulation, cognitive attack, and cognitive warfare by consent, deception, intent, harm, and scale, and held that dissent is not a vulnerability. Comparison with adjacent fields located the distinctive object of cognitive security in the coupled decision loop under an adaptive adversary, and the prevalence effect, trust calibration, and the adaptive role of heuristics replaced the weakest-link model with the person in a workflow under a specified threat model.

The book's frameworks followed: the Cognitive Security Stack and its cross-level pathways, the cognitive loop, the Cognitive Security Cube, the seven-stage attack chain with its mirrored defense chain, and the resilience functional R over decision quality $Q(t)$ under autonomy and pluralism constraints. [Theorem 1.1](#) showed that proportional interdiction is position-independent under stage-wise independence, and [Example 1.3](#) showed that a shallow, long campaign can set the worst case. MERIDIAN, the reading paths, and the ethical limits of cognitive defense complete the foundation for the remaining chapters.

Exercises

Exercise 1.1 [C] Place each of the following on the ladder of [Figure 1.4](#) and state which criterion decides the placement: (a) a disclosed utility campaign asking customers to reduce demand during a heat wave; (b) a purchase countdown timer that resets on reload; (c) a message spoofing the finance director's address that requests a change of vendor bank details; (d) a multi-year network of inauthentic

accounts run by an organized actor to erode confidence in an election authority. For (d), state the evidence needed to justify the placement.

Exercise 1.2 [C] The 2013 AP incident is sometimes described as a case of misinformation. Using [Definition 1.3](#), explain why it is a cognitive attack, identify the protected objective, and name the element of the security framing test of [Section 1.3](#) that a description as misinformation omits.

Exercise 1.3 [C] Choose one adjacent field from [Figure 1.6](#). Describe an incident that the field would record and analyze well, and a second incident, involving the coupled decision loop, that falls outside its boundary. State which cell or cells of the Cognitive Security Cube the second incident occupies.

Exercise 1.4 [C] A help desk resets passwords and multi-factor enrollment after a telephone call in which the caller gives an employee's name, identifier, and manager. Redesign the workflow using the principle of asymmetric friction. Identify the stage of the cognitive attack chain at which each change acts, and state one cost that the redesign imposes on legitimate callers.

Exercise 1.5 [A] Generalize [Example 1.2](#). Suppose stage 5 succeeds with probability p , and stage 6 is a control that detects with probability d but, with probability c , fails whenever stage 5 succeeds because the adversary controls its channel. (a) Show that the success probability is $p[c + (1 - c)(1 - d)]$. (b) Show that as $d \rightarrow 1$ the success probability tends to pc , and interpret this floor. (c) Find the value of d at which the success probability with $c = 0.2$ equals the success probability with $c = 0$ and $d = 0.9$, or show that no such d exists.

Exercise 1.6 [A] A business email compromise chain at MERIDIAN has stage pass probabilities without controls $(p_1, \dots, p_7) = (0.9, 0.9, 0.8, 0.6, 0.3, 0.5, 0.7)$ and stage-wise stopping probabilities $(d_1, \dots, d_7) = (0, 0, 0, 0.5, 0.2, 0.6, 0)$. (a) Compute P_6 , the probability of reaching and completing the action stage. (b) The defender can raise one d_s by 0.2 (capped at 1). Which choice minimizes P_6 ? (c) Explain the answer with part (ii) of [Theorem 1.1](#), noting that raising d_s by a fixed amount is not a fixed proportional reduction of q_s .

Exercise 1.7 [A] Let $Q(t)/Q_0$ be the trapezoidal curve of [Example 1.3](#), with depth δ , onset t_a , time of minimum t_m , detection time t_d , and restoration time $t_r = t_d + \tau_r$, all within $[0, T]$. (a) Derive the loss area $\delta[(t_m - t_a)/2 + (t_d - t_m) + \tau_r/2]$. (b) With τ_r fixed, show that the time-averaged ratio decreases in t_d with slope $-\delta/T$. (c) For the campaign w_2 of the example, with a recovery duration of 4 hours, find the detection time at which w_2 and w_1 give the same ratio.

Exercise 1.8 [A] Add to the manipulation set of [Example 1.3](#) a third campaign w_3 that lowers quality to $0.85 Q_0$ from hour 0 to hour 24 without detection. (a) Compute its time-averaged ratio and the new value of R . (b) Explain why enlarging $\mathcal{W}$ cannot raise R . (c) Suppose that after recovery from w_1 quality settles at $1.05 Q_0$; discuss whether ratios above 1 should be allowed or capped at 1.

Exercise 1.9 [A] Replace the linear recovery of [Example 1.3](#) with exponential recovery: after detection at t_d , $Q(t)/Q_0 = 1 - \delta e^{-(t-t_d)/\tau}$. Compute the loss area

contributed by recovery over $[t_d, \infty)$, and find τ such that it equals the recovery loss of a linear recovery lasting 5 hours. Explain why the exponential model has no finite restoration time and how that affects a reported “time to recover.”

Exercise 1.10 [A] Using the MERIDIAN values in Table 1.1, compute the nominal utilization of the Tier-1 pool and the utilization when a feint campaign raises alert arrivals to 70 per hour. Suppose the AI triage copilot auto-closes 60% of benign alerts before they reach Tier 1 and 2% of alerts are true incidents. Compute the arrival rate reaching Tier 1 with the copilot under the campaign, assuming the added alerts are benign, and discuss what the copilot does to the prevalence of true incidents in the analysts’ queue.

Exercise 1.11 [P] Write a Python function that computes the time-averaged ratio $\frac{1}{T} \int_0^T Q(t)/Q_0 dt$ for a piecewise-linear curve given as a list of breakpoints, and the resilience functional as the minimum over a list of curves. Reproduce the values 0.875, 0.819, and 0.919 of Example 1.3 by numerical integration and by the closed form, and plot the ratio of w_2 as a function of its detection time from hour 2 to hour 16, marking the detection time at which the binding campaign changes.

Exercise 1.12 [P] *Lab: placing incidents in the Cube.* Build a table of ten incidents, each with a primary cell and an entry cell in the Cube and a one-sentence justification: the three incidents of Example 1.1, the Stuxnet and Ukraine pathways of Figure 1.9, and five incidents from the public record or the MERIDIAN storm scenario (for example, a false boil-water rumor, a help-desk reset obtained by pretext, a flood of low-priority alerts, biased analyst feedback to a triage model, and a synthetic voice call to a control room). Write Python code that (a) draws counts by level and stage as a 5×5 heatmap, (b) lists cross-level pathways as pairs of levels, and (c) given MERIDIAN controls and the cells they cover, reports incident cells that no control covers. Discuss which placements were contested.

Exercise 1.13 [C] Choose one defense discussed in this chapter, for example monitoring of analysts’ attention, labeling of social media posts during an outage, or prebunking for finance staff. Argue whether it lies in the feasible set Π_{AP} of Figure 1.17, state the conditions of proportionality, transparency, minimization, and contestability it would need to meet, and describe a false positive that it could produce and who would bear its cost.

Notes and Further Reading

Origins of the term. Waltzman’s 2017 testimony to the United States Senate named cognitive security as a discipline concerned with the manipulation of beliefs through social media and information operations [24]. Andrade and Yoo survey a different usage, in which cognitive science and cognitive computing are applied to cybersecurity operations [33]. The system-scientific formulation of Huang and Zhu treats human cognition as a component of human-cyber-physical systems, classifies innate and acquired cognitive vulnerabilities, and develops attention-enhancement and informational denial-of-service defenses [3, 1, 2]; this book extends that formulation to AI agents, human-AI teams, organizations, and society.

Cognition as a control layer. The treatment of attackers and defenders across cyber and physical layers as nested games is developed by Zhu and Başar [10]. For Stuxnet and the 2015 Ukrainian grid attack, see Langner [29] and the E-ISAC and SANS analysis [12]. Hutchins’s study of how a cockpit crew and its instruments jointly remember critical speeds is a classic demonstration that cognition can reside in a system of people and artifacts [34]; it underlies the organizational level of the Stack.

Manipulation and information disorder. Susser, Roessler, and Nissenbaum develop the account of manipulation as hidden influence that exploits vulnerabilities, and discuss its implications for autonomy in digital environments [13]. Wardle and Derakhshan’s report introduced the distinction among misinformation, disinformation, and malinformation that many policy documents use [18]. Vosoughi, Roy, and Aral measured the diffusion of true and false news on Twitter from 2006 to 2017 [19]; their findings concern a single platform and period and should be generalized with care.

Human factors. Reason summarizes the person and system approaches to error [20]. Endsley’s theory of situation awareness [21], Parasuraman and Riley’s taxonomy of automation use [22], and Lee and See’s review of trust in automation [26] are standard starting points for the human-AI team level. The prevalence effect was reported by Wolfe and colleagues [7] and connected to security operations by Sawyer and Hancock [8]; Simon [28] and Tversky and Kahneman [27] frame the decision stage, and later chapters discuss replication debates in the broader behavioral literature.

Adjacent fields. MITRE ATT&CK and ATLAS catalog adversary techniques against enterprise systems and machine-learning systems [16, 17]. Amodei and colleagues framed concrete accident risks in machine learning [23], and Greshake and colleagues demonstrated indirect prompt injection against applications that integrate large language models [9]. Denning, Matsuoka, and Kohno introduced neurosecurity as security and privacy for neural devices [25].

Chains and resilience. The intrusion kill chain of Hutchins, Cloppert, and Amin is the model for the staged view of attacks used here [31]. The four resilience phases follow the cyber resiliency goals of NIST SP 800-160 Volume 2 [30], and the integral measure of resilience follows the framework of Bruneau and colleagues for the seismic resilience of communities [32]. Formal properties of the resilience functional, risk-averse variants, and measurement validity are developed later in the book.

Incidents. Facts about the Arup case follow CNN’s reports of the Hong Kong police briefing in February 2024 and of Arup’s confirmation in May 2024 [5, 6]. Facts about the 2013 AP account hijacking follow same-day reports by NPR and Bloomberg [14, 15]; reported market-value figures are approximate.

Cognitive Systems and Assets: Humans, Machines, Teams, and Institutions

Learning Objectives

- ▶ Describe the individual as a bounded cognitive system and state the evidence status of each construct.
- ▶ Diagnose decision failures with the three levels of situation awareness and compute them under alarm load.
- ▶ Explain how organizations and artificial agents carry out cognitive functions, and model a joint human-AI system.
- ▶ Treat trust as a system property and quantify the calibration gap of transferred trust.
- ▶ Define cognitive assets and trusted boundaries, and represent an organization as an asset-dependency graph.
- ▶ Model impairment as an independent cascade, prove its threshold behavior, and compute cascade sizes for MERIDIAN.

This chapter answers two questions that precede the defense of cognition: what exactly is protected, and through which dependencies it can be reached. [Sections 2.1 to 2.5](#) describe cognitive systems from the individual operator to organizations, artificial agents, and the trust relations that couple them. [Sections 2.6 and 2.7](#) define cognitive assets and trusted boundaries, represent their dependencies as a graph, and model how impairment propagates along it; [Section 2.8](#) states the limits of inventories that include people.

MERIDIAN Running Example

MERIDIAN is a notional regional utility that supplies electricity and water to about 2.0 million residents; it is a teaching construct and is not modeled on a real organization. It employs 4,800 staff and about 1,500 contractors, works with 220 active vendors, and runs grid and water control rooms on 12-hour shifts.

	Sense	Model	Decide	Act	Learn
L5 Society					
L4 Organization					
L3 Human-AI team					
L2 AI agent					
L1 Individual					

Figure 2.1. Level map for Chapter 2. The chapter spans all five levels of the Cognitive Security Stack and concentrates on the Sense, Model, and Decide stages of the cognitive loop (dark cells), where cognitive assets hold their protected states. The Act stage of teams and organizations is lightly shaded because delegated authority couples a judgment to an action.

The chief information security officer has been asked to extend the asset inventory. The inventory lists 1,100 operational technology devices, servers, and accounts, but a recent audit of a near-miss payment found that no listed asset failed. A vendor portal authenticated a vendor account correctly, an accounts-payable clerk trusted the portal, a drafting assistant summarized the request faithfully, and two approvers relied on the summary. The audit concluded that the protected object was the chain of judgments, and that the inventory contained none of its links. The security team now has to decide what belongs in a cognitive asset inventory, how the links depend on one another, and how far an impairment at one link can travel. This chapter builds the tools for that task.

2.1 The Individual as a Cognitive System

Cognitive security protects the decision-relevant *capabilities* (capacities to process, such as attention), *states* (current conditions, such as a belief or a level of trust), and *couplings* (relationships through which one component’s state constrains another’s) of human, artificial, and institutional systems against unauthorized manipulation, degradation, extraction, or coercive control. This section describes the smallest unit that carries cognition, the individual human.

Background: The Cognitive Security Stack, the cognitive loop, and the Cube

The *Cognitive Security Stack* has five levels indexed by $\ell \in \{1, \dots, 5\}$: L1 the individual human, L2 the artificial agent, L3 the human-AI team, L4 the organization, and L5 society and the information ecosystem. Within each level, cognition runs as a *cognitive loop* of five stages. *Sense* covers attention and perception; *Model* covers belief formation, memory, and trust in sources; *Decide* covers judgment and choice; *Act* covers execution, communication, and the exercise of authority; and *Learn* covers updating beliefs, trust, and

policies from feedback. The *Cognitive Security Cube* places a problem on three axes: level, loop stage, and resilience phase (Anticipate, Withstand, Recover, Adapt).

Outcomes are measured by a decision quality $Q(t)$ with nominal value Q_0 , for example the probability of a correct decision or the fraction of true alerts handled within a deadline. This chapter mostly concerns the Sense, Model, and Decide stages at every level, because those stages hold the states that cognitive assets must protect.

2.1.1 Components of Individual Cognition

The account of individual cognition used in this book is functional: it names components by what they do in a decision and states how firmly the evidence supports each. [Figure 2.2](#) arranges the components along the Sense, Model, and Decide stages of the loop.

Attention selects which of the available stimuli receive further processing. Kahneman's capacity account treats attention as a limited and allocable resource whose supply varies with arousal and whose allocation follows both enduring dispositions and momentary intentions [35]. The limit has visible consequences. In the inattentive blindness experiments of Simons and Chabris, many observers who were counting passes between players failed to notice a person in a gorilla costume walking through the scene [36]. For security the lesson is that what is not attended is, for practical purposes, not perceived, and an adversary who controls salience controls the input to every later stage.

Perception turns attended stimuli into structured interpretations: a sender name, a voice, a trend on a display. Perception is inferential, combining the stimulus with expectations, which is why a familiar logo or a plausible caller identification can substitute for evidence that was not checked.

Working memory holds and manipulates the small amount of information in current use. Miller's classic estimate of about seven items [37] was later revised by Cowan, who argued that, when rehearsal and chunking are controlled, the capacity of the focus of attention is closer to about four chunks [38]. For security the existence of a small bound matters more than its exact value.

Long-term memory stores knowledge, skills, and expectations. It supplies the schemas against which perception is interpreted and the patterns that make expert recognition fast [39]. It is also a target, because repeated exposure to a claim raises its familiarity, and familiarity is read as a cue to truth.

2.1.2 Judgment, Emotion, and Bounded Rationality

Judgment is commonly described by *dual-process* theories. In the formulation of Evans and Stanovich, Type 1 processes are autonomous and do not require working memory, whereas Type 2 processes require working memory and support hypothetical thinking; speed, associativity, and bias are typical correlates of the distinction rather than its defining features [40]. Kahneman's popular exposition calls the two modes System 1 and System 2 [41]. The distinction is useful for

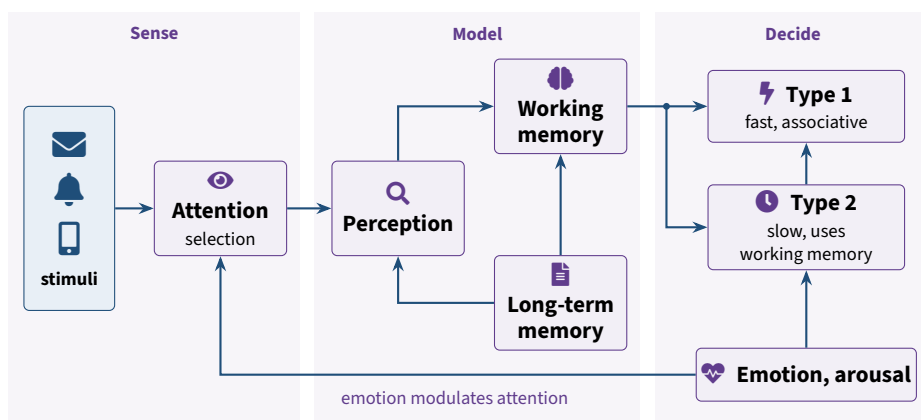


Figure 2.2. The individual as a cognitive system, arranged along the Sense, Model, and Decide stages of the cognitive loop. Emotion and arousal act on attention and on judgment, which is why urgency is a common manipulation cue.

security because many manipulation techniques aim to keep a decision in the fast mode: urgency shortens the time available for deliberation, and authority or familiarity supplies a cue that makes deliberation seem unnecessary. The heuristics involved, such as judging frequency by the ease of recall or anchoring on an initial value, are adaptive in environments where the cues correlate with the truth [27]. They become vulnerabilities when an adversary can produce the cue cheaply and the workflow offers no independent check.

Emotion is not an interruption of cognition but one of its regulators. Studies of the human amygdala show that emotional significance modulates attention, perception, and memory consolidation [42], and a review by Lerner and colleagues concludes that emotions shape decisions both through the emotion felt about the choice and through incidental emotion carried over from unrelated events [43]. An adversary who induces fear of a missed deadline changes the decision environment even when every factual claim in a message is checked.

All of these components are bounded. Simon’s account of bounded rationality describes a decision maker who has limited information, limited computational capacity, and costly search, and who therefore adopts satisficing rules rather than global optimization [28]. It is the default model of the individual in this book, and its security reading is that the bounds are resources that an adversary can consume. An attention budget can be exhausted by flooding, working memory can be saturated by a complex pretext, and deliberation time can be removed by an artificial deadline.

2.1.3 Evidence Status and the State-Trait Distinction

The constructs above do not rest on evidence of equal strength, and a security architecture built on them should know which parts are firm. Figure 2.3 grades each construct used in this chapter. The capacity limits of attention and working memory are among the most replicated findings in experimental psychology, although the numerical capacity depends on the task and on how chunks are

counted. The dual-process distinction is established as a descriptive framework but remains contested as a claim about two separable systems [40]. Effects of emotion on attention and memory are well supported, but specific emotion-to-choice effects depend on the setting [43]. A large multilaboratory replication of ego depletion found an effect close to zero [44], so defenses that assume self-control is a depletable reservoir need direct measurement in the setting of use.

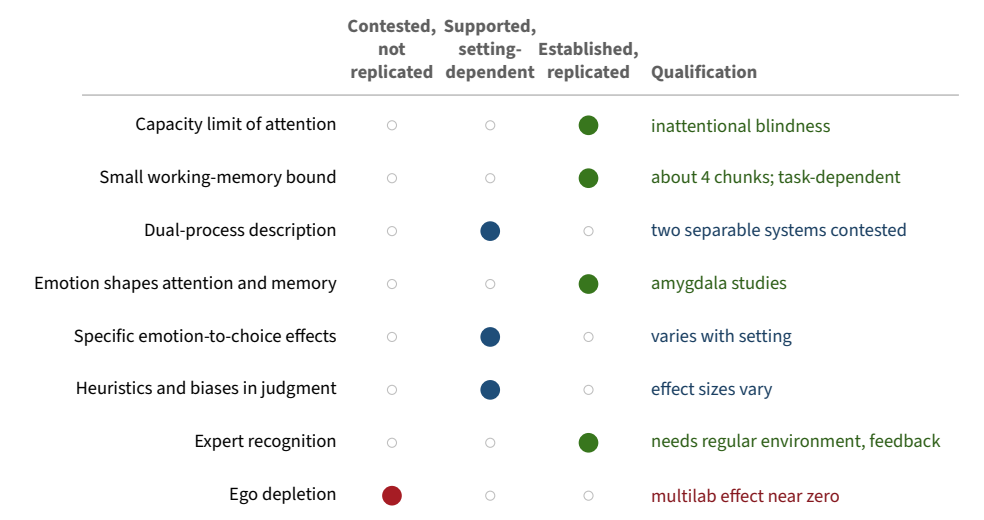


Figure 2.3. Evidence status of the constructs of individual cognition used in this book. Each dot marks our reading of the literature cited in the text; green marks findings that are established and replicated, blue marks findings that are supported but depend on task or setting, and red marks a finding that did not survive a large replication. Defenses should lean on the right-hand column.

A second distinction matters as much as evidence strength. Exposure to manipulation depends far more on *state* than on stable *trait*. The same analyst presents a different risk at the start of a shift and after eleven hours, under an alarm flood and in a quiet period, and when a deadline is real or manufactured. Expertise helps only where the environment is regular enough and feedback fast enough for valid intuition to form [39]; a finance officer who processes 900 payments a week receives almost no feedback on the rare forged request. For this reason the book does not classify people as strong or weak links. It models the conditions under which a given person’s cognitive state becomes exploitable, and it designs the surrounding system so that no single state of a single person determines a high-impact outcome.

2.2 Situation Awareness and Its Breakdowns

Operators of dynamic systems must maintain an up-to-date picture of a changing process from many streams at once. Situation awareness, the construct that organizes this task in human factors engineering, gives a precise vocabulary for where that picture can be corrupted.

2.2.1 Three Levels of Situation Awareness

Definition 2.1 (Situation awareness). Following Endsley, *situation awareness* (SA) is the perception of the elements in the environment within a volume of time and space, the comprehension of their meaning, and the projection of their status in the near future [21]. *Level 1 SA* is perception of the status, attributes, and dynamics of relevant elements. *Level 2 SA* is comprehension, the synthesis of perceived elements into an understanding of the current situation relative to goals. *Level 3 SA* is projection, the ability to anticipate the future states of the elements.

The levels are cumulative. Comprehension is built on perceived elements, and projection on a comprehended situation, so a failure at a lower level propagates upward. In a utility control room, Level 1 SA is noticing that three breakers in one area have opened and that a line flow is rising; Level 2 SA is recognizing that the pattern indicates a fault, an equipment malfunction, or a malicious command; and Level 3 SA is anticipating that the rising flow will overload a neighboring line within minutes unless load is shed [3]. Level 1 SA depends mainly on attention and perception, Level 2 on working memory and the schemas of long-term memory, and Level 3 on mental models of the process dynamics. SA is a state of knowledge and is distinct from the decision and the action it informs: an operator can have accurate SA and still choose poorly, and can choose well by chance with poor SA.

SA can be measured. The Situation Awareness Global Assessment Technique freezes a simulation at random times and compares operators' answers about the current and projected state with the true state, level by level [45], which separates what an adversary changed in an operator's knowledge from what the operator then did.

Figure 2.4 draws the levels as a pipeline in which each level is a separable target calling for a different defense.

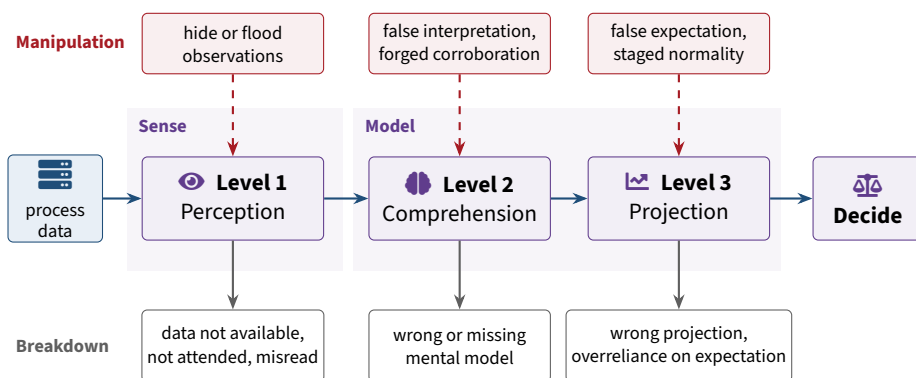


Figure 2.4. The three levels of situation awareness as a pipeline in the Sense and Model stages of the cognitive loop. Gray boxes below each level name its typical breakdown; red boxes above name the manipulation that produces it. Because the levels are cumulative, a Level 1 failure caused by flooding also removes Levels 2 and 3.

2.2.2 Where Situation Awareness Breaks Down

Empirical work places most SA failures at the lowest level. Jones and Endsley classified SA errors in reports from the Aviation Safety Reporting System and found that 76.3% were Level 1 errors, failures to perceive needed information; 20.3% were Level 2 errors, failures to comprehend it; and 3.4% were Level 3 errors, failures to project [46]. Within Level 1 the largest single category was a failure to monitor or observe information that was available. The proportions describe voluntary aviation reports rather than control rooms, but the ordering suggests that a manipulation controlling what reaches attention is cheaper than one that must defeat an expert's interpretation.

The link between attention and Level 1 SA can be written down. Suppose an operator must perceive s of K critical alarms to comprehend an event, the alarms arrive among N alarms in a review window, and the operator can read at most $c < N$ alarms in that window. If reading order carries no information about criticality, the alarms read form a uniformly random subset of size c , and the number of critical alarms read is hypergeometric:

$$P_1(N) = \mathbb{P}[\text{at least } s \text{ of } K \text{ read}] = \sum_{j=s}^K \frac{\binom{K}{j} \binom{N-K}{c-j}}{\binom{N}{c}}, \quad N > c. \quad (2.1)$$

For $N \leq c$ every alarm is read and $P_1 = 1$. If Level 2 SA follows Level 1 with conditional probability p_2 and Level 3 follows Level 2 with conditional probability p_3 , then the probability of full SA is $P_1 p_2 p_3$. The multiplicative structure explains why Level 1 dominates: no improvement in expertise, which raises p_2 and p_3 , can recover what was not perceived.

Example 2.1 (Situation awareness of a MERIDIAN grid operator during an alarm burst). MERIDIAN's grid control room staffs 6 operators per shift. The nominal alarm load is 30 alarms per operator per hour, or 5 per 10 minutes, and the flood threshold is 10 alarms per operator per 10 minutes. For this example we assume that during a storm an operator's area produces a burst of $N = 60$ alarms in 10 minutes, that the operator can read and assess $c = 12$ alarms in that window (about 50 seconds each), and that $K = 3$ of the alarms, breaker trips on adjacent lines, indicate the developing overload. Comprehension requires reading at least $s = 2$ of them. We further assume $p_2 = 0.9$ and $p_3 = 0.8$.

At the nominal load, $N = 5 \leq c$, so $P_1 = 1$ and full SA has probability $0.9 \times 0.8 = 0.72$. In the burst, (2.1) gives $P_1(60) = \left[\binom{3}{2} \binom{57}{10} + \binom{3}{3} \binom{57}{9} \right] / \binom{60}{12} = 0.099$, so Level 2 SA has probability 0.089 and full SA 0.071, a tenfold reduction. If the alarm system suppresses consequential alarms and ranks the three breaker trips first, as alarm management practice recommends [47], then $P_1 = 1$ and full SA returns to 0.72 at the same load. Figure 2.5 plots P_1 against the alarm count. The conclusion is that the most effective control acts on the order in which information reaches the operator, not on expertise.

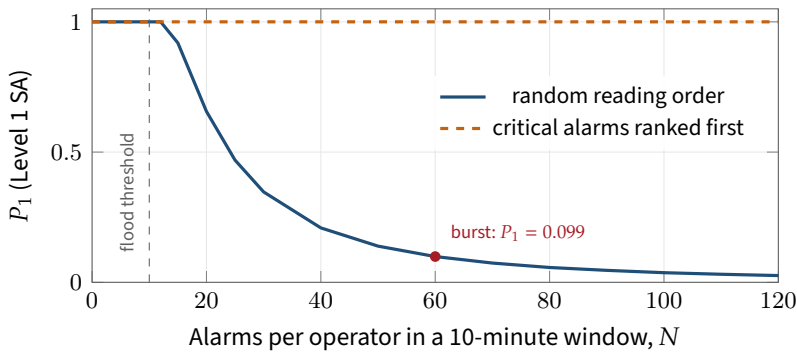


Figure 2.5. Probability of Level 1 situation awareness for a MERIDIAN grid operator who can read 12 alarms per 10 minutes and must see 2 of 3 critical alarms (Example 2.1). With random reading order, P_1 falls steeply once the load exceeds reading capacity.

2.2.3 Shared and Distributed Situation Awareness

Operators rarely hold SA alone. A shift lead, a neighboring control room, and a field crew each hold part of the picture, and handoffs, displays, and summaries move it between them. Reviews of SA models for teams distinguish *team SA*, the SA each member needs for an assigned role, *shared SA*, the overlap that members need in common, and *distributed SA*, in which awareness is held by the system of agents and artifacts rather than by a single person [48]. The distinction produces security-relevant failure modes that no individual measure reveals. A team can lose shared SA while each member remains individually correct, for example when two operators hold consistent but different pictures because a shared display was altered for one of them. A handoff can transmit comprehension without the perceptions that grounded it, so that a false interpretation, once written into a shift log, acquires the authority of a colleague's judgment.

2.3 Distributed and Organizational Cognition

Most consequential decisions in a utility, a bank, or a ministry are not made inside one head. They are produced by people, documents, displays, and procedures that together perceive, remember, and decide. This section treats such arrangements as cognitive systems in their own right, which can be attacked without deceiving a single person.

2.3.1 Distributed Cognition

Hutchins studied navigation on a naval vessel and argued that the computation of a ship's position is carried out by a system of people, instruments, charts, and practices whose cognitive properties differ from those of each participant [49]. In a companion study of an airline cockpit, he showed that the memory of the correct approach speeds resides partly in the pilots and partly in speed cards and the positions of physical markers on the airspeed indicator, so that the cockpit as a unit remembers its speeds [34]. Hollan, Hutchins, and Kirsh extended the

approach to processes distributed across group members, between internal and external structure, and through time [50].

Definition 2.2 (Distributed cognitive system). A *distributed cognitive system* is a set of human agents, artificial agents, and representational artifacts, together with the coordination practices that link them, that jointly performs at least one stage of the cognitive loop (Sense, Model, Decide, Act, Learn) for a shared task. Its *cognitive state* at time t is the collection of the internal states of its agents and the contents of its artifacts that bear on the task.

The definition makes an artifact part of the protected system when it holds task-relevant state. A shift log, a vendor master file, and an alarm list are not merely data stores in this view; they are components of the organization's memory and perception, and a change to them is a change to what the organization knows. When an approval workflow accepts a request, an organizational inference has occurred whether or not a person endorsed the content.

2.3.2 Routines, Roles, and Institutional Memory

Organizations stabilize distributed cognition through routines, roles, and memory. Feldman and Pentland distinguish the *ostensive* aspect of a routine, the abstract pattern that participants understand, from its *performative* aspect, the specific actions taken at specific times; the gap between them is a source of flexibility and change [51]. The same gap is an exposure. An adversary who knows the ostensive routine for a bank-detail change, and the exception paths that performers use under time pressure, can shape a request to fit the performance rather than the rule.

Roles allocate cognitive functions: who perceives which signals, who is authorized to interpret them, and who may commit the organization to an action. A role therefore bundles a capability with an authority, and impersonating a role borrows both. Walsh and Ungson describe *organizational memory* as stored information from an organization's history that can be brought to bear on present decisions, retained in individuals, culture, standard procedures, and external archives, among other locations [52]. Each retention location has its own integrity and availability properties: a procedure encoded in software is hard to alter but also hard to question, whereas a practice held only by two senior staff disappears when they leave.

2.3.3 Transactive Memory and Team Cognition

A group also needs to know who knows what. Wegner defined a *transactive memory system* as the combination of the knowledge held by individual members with a shared awareness of the members' areas of expertise, which lets the group encode, store, and retrieve more than a single member could [53]. In field teams, Lewis measured transactive memory by three components (specialization, credibility, and coordination) and validated the scale against team performance [54].

Transactive memory has a direct security reading. The directory of who knows

what, and the credibility assigned to each member's expertise, is a trust structure. A request that invokes the right expert ("the treasury lead confirmed the new account") exploits the directory, not the memory, because members retrieve by delegation and do not re-verify what the directory says an expert holds. Figure 2.6 draws the MERIDIAN finance office as a distributed cognitive system in which the routine, the roles, the retention locations, and the directory of expertise each carry protected state.

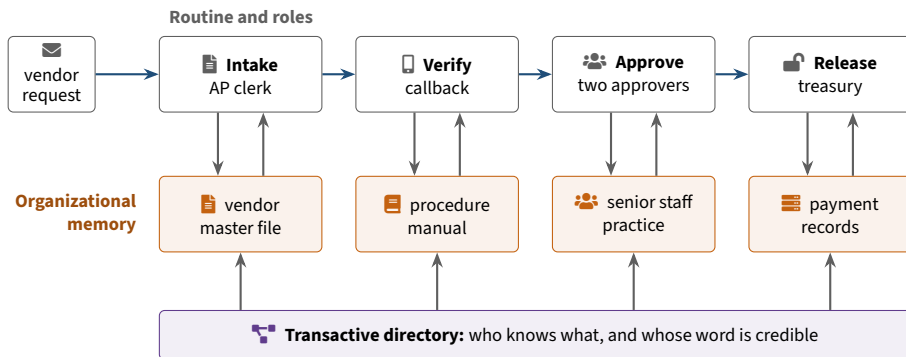


Figure 2.6. The MERIDIAN finance office as a distributed cognitive system. The routine (gray) passes a request through roles; each step reads and writes a retention location of organizational memory (orange); and the transactive directory (purple) tells members whose knowledge to rely on. A change to the vendor master file or to the directory's credibility assignments changes what the organization believes without deceiving the clerk.

2.3.4 Organizational Failure Modes and Correlated Judgment

Two properties distinguish organizational cognition as an object of attack. The first is that it can be attacked through its structure: the exception path, the ordering of a queue, the cost of escalation, or an incentive attached to throughput. Anderson observed that information security failures are often better explained by misaligned incentives than by technical ignorance [55], and the observation carries over to procedures whose designers and performers face different costs. The second is that redundancy in an organization protects only to the extent that its members' judgments are independent. Two approvers who read the same forged summary, consult the same altered master file, or defer to the same expert in the transactive directory are not two independent checks.

Example 2.2 (Dual approval with common-mode reliance). MERIDIAN requires two approvers for payments at or above \$50,000. For this example we assume that a fraudulent request is presented and that each approver, judging independently from independent evidence, detects it with probability $d = 0.6$. With probability c both approvers instead rely on a single shared artifact, such as the same assistant-drafted summary, in which case their judgments coincide and the pair detects the fraud with probability d . The problem is to find the probability $M(c)$ that the fraud passes both approvers.

With independent evidence the fraud passes only if both miss, with probability $(1 - d)^2 = 0.16$. With common-mode reliance it passes with probability $1 - d = 0.4$. By total probability,

$$M(c) = c(1 - d) + (1 - c)(1 - d)^2 = 0.16 + 0.24c. \quad (2.2)$$

At $c = 1$, $M = 0.40$, the miss probability of a single approver. The protected property of a dual-approval control is therefore the independence of the approvers' evidence, not the number of signatures.

The organizational level thus contributes three protected states with no individual counterpart: the integrity of routines, the integrity of retention locations, and the independence of redundant judgments.

2.4 Artificial and Joint Human-AI Cognitive Systems

Artificial agents now read email, triage alerts, retrieve documents, and draft decisions inside the routines of [Section 2.3](#), and a person and an agent working together form one cognitive system whose properties differ from those of either part.

2.4.1 Artificial Agents as Functional Cognitive Systems

In the standard account of artificial intelligence, an *agent* is a system that perceives its environment through sensors and acts on it through actuators, and an agent's behavior is described by an agent function that maps the history of percepts to an action [56]. We adopt this functional description and add the internal states that matter for security.

Definition 2.3 (Functional cognitive system). A *functional cognitive system* is a system that implements at least the Sense, Model, and Decide stages of the cognitive loop: it selects and encodes inputs, maintains an internal state that summarizes past inputs and bears on future choices, and selects outputs from that state. The system is classified by the functions it performs; the classification makes no claim about understanding, intention, or consciousness.

For a language-model agent the stages have concrete counterparts, from retrieval (Sense) and the context window (Model) to tool calls executed with the agent's permissions (Act), which [Figure 2.7](#) aligns with those of an individual and an organization.

Artificial cognition fails in ways that are distributed differently from human cognition. An agent has no biological fatigue, but it has a finite context, finite memory, and an input channel in which data and instructions share one medium. Indirect prompt injection exploits this last property: instructions placed in content that an application retrieves can steer a model that processes the content [9]. When many deployments share a model version, a system prompt, and a tool configuration, a manipulation that works once can work at scale, so errors across instances may be strongly correlated. A fluent output also carries markers of competence into human judgment whether or not the content is reliable. An

agent inside a workflow therefore occupies three roles at once: it is a *target* whose processing can be corrupted, a *tool* that an adversary can wield, and a *cognitive asset* on which the organization relies.

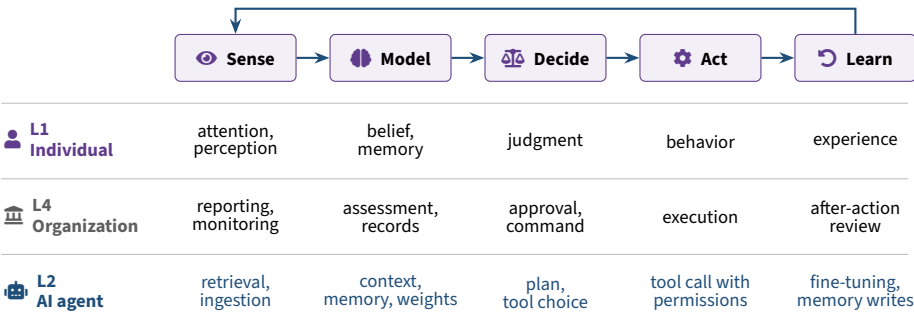


Figure 2.7. One cognitive loop, three readings. Each column is a stage of the cognitive loop and each row gives its counterpart for an individual, an organization, and an artificial agent. The agent row (blue) shows why retrieval, context, and tool permissions are the agent’s counterparts of perception, belief, and authority, and hence its principal attack surfaces.

2.4.2 Joint Human-AI Cognitive Systems

Cognitive systems engineering argues that a person and the technology they work with should be analyzed as a *joint cognitive system*, a unit that maintains control of a task in its environment, rather than as a human operator plus a machine [57]. The argument has become practical as agents take over parts of the loop. Parasuraman, Sheridan, and Wickens describe automation by four functions (information acquisition, information analysis, decision and action selection, and action implementation), each of which can be automated to a different level [58]. The four functions correspond to the Sense, Model, Decide, and Act stages of the cognitive loop, so a joint system can be specified by the level of automation at each stage and by who holds authority over the transition between stages.

Joint systems acquire failure modes that belong to neither part. Bainbridge noted the *ironies of automation*: designers automate the tasks that are easy to specify and leave the operator the tasks that are hard, and the operator who rarely performs a task loses the skill and the current picture needed to take over when automation fails [59], an out-of-the-loop problem that grows as automation becomes more reliable [60]. *Automation bias* is the use of an automated cue as a heuristic replacement for vigilant information seeking; it produced errors of omission and commission in experienced crews [61], and Parasuraman and Manzey report that it and complacency occur in experts as well as novices and are not prevented by simple instructions [62].

These findings define a coupling that the adversary can exploit. When an organization grants a recommendation from an agent the authority to shorten a person’s verification, a manipulated input that steers the agent acquires that authority when the person accepts the recommendation. We call this *authority laundering*. The protected property of the joint system is therefore not the accuracy

of the agent or the vigilance of the person alone, but the relationship between the agent's output and the authority the workflow assigns to it. Figure 2.8 draws the MERIDIAN security operations center (SOC) as a joint cognitive system with this coupling marked.

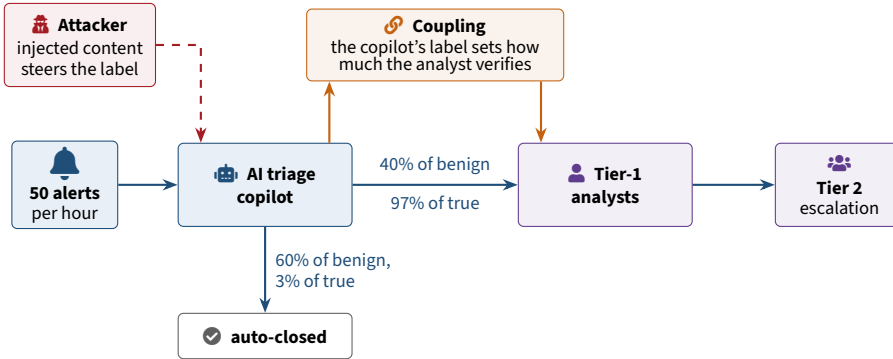


Figure 2.8. The MERIDIAN SOC as a joint human-AI cognitive system. The orange coupling is the protected property: a label that shortens verification carries authority, so an input that steers the label (red) is laundered into an analyst's decision.

Example 2.3 (Decision quality of the joint SOC). The MERIDIAN SOC receives 50 alerts per hour after correlation, of which 2% are true incidents, so 1 true incident and 49 benign alerts arrive per hour. The copilot auto-closes 60% of benign alerts, cutting the utilization of five Tier-1 analysts serving 15 alerts per hour each from $50/75 = 0.67$ to about $20.6/75 = 0.27$, and has recall 0.97 on true incidents. For this example we assume that an analyst who sees a true incident detects it with probability $d_a = 0.9$, the same value as for analysts working alone at utilization 0.67, whose miss probability is therefore 0.10. The problem is to find the joint probability that a true incident is missed.

A true incident is missed if the copilot auto-closes it or the analyst misses it after it is shown, so the joint miss probability is

$$m_j = (1 - 0.97) + 0.97(1 - d_a) = 0.03 + 0.97 \times 0.1 = 0.127. \quad (2.3)$$

Over a 12-hour shift with 12 true incidents, the expected number missed is 1.52. If automation bias lowers analyst detection on shown alerts to $d_a = 0.8$, the joint miss probability rises to 0.224 and the expected misses per shift to 2.69; if the lighter load raises it to 0.95, the figures are 0.0785 and 0.94. Analysts working alone miss 0.10 of true incidents, or 1.2 per shift, so at the assumed $d_a = 0.9$ the joint system is worse than the analysts alone, because the copilot's auto-closures add misses without a gain in analyst detection. Since $m_j = 1 - 0.97 d_a$, the joint system matches the analysts alone when $0.97 d_a = 0.9$, that is, at the break-even detection $d_a = 0.9/0.97 \approx 0.928$. The copilot therefore lowers the miss probability only if the lighter load raises analyst detection on shown alerts above 0.928, that is, by more than about 2.8 percentage points above the unassisted baseline of 0.90; if the lighter load alone would raise detection to 0.95, automation bias may subtract less than about 2.2 percentage points before the copilot stops helping.

The joint system's decision quality depends on the analyst's state as much as on the copilot's recall.

The security of agents as targets is treated in depth in Chapter 18.

2.5 Trust as a System Property

Every coupling described so far runs on trust, from an operator's trust in a display to a clerk's trust in a vendor portal. For security it is useful to treat trust as a property of the system: a set of relations between trusters and trustees, each attached to a class of claims, more or less aligned with the trustee's reliability, and able to pass along chains of reliance.

2.5.1 Trust, Reliance, and Calibration

Lee and See define trust in automation as the attitude that an agent will help achieve an individual's goals in a situation characterized by uncertainty and vulnerability, and distinguish trust, an attitude, from reliance, a behavior [26]. Experiments by Dzindolet and colleagues show that observed automation errors reduce trust and reliance, and that providing reasons for errors can restore reliance even when the aid is imperfect [63].

The central concept for security is calibration. Lee and See describe *calibration* as the correspondence between a person's trust and the capabilities of the automation [26]. *Overtrust* is trust that exceeds capability and leads to misuse; *distrust* is trust that falls short of capability and leads to disuse. Figure 2.9 draws these regions. Both are costly, and they are costly in different currencies: overtrust admits manipulated inputs, while distrust wastes capability and invites workarounds that bypass controls.

Definition 2.4 (Trust relation and calibration gap). Let i be a truster, j a trustee, and C a class of claims or actions, such as “bank-detail changes submitted through the portal.” The *trust* $\tau_{ij}(C) \in [0, 1]$ is the probability with which i acts as if a claim of class C from j is correct, measured behaviorally as the fraction of such claims accepted without independent verification. The *reliability* $r_j(C) \in [0, 1]$ is the probability that a claim of class C from j is in fact correct. The *calibration gap* is $g_{ij}(C) = \tau_{ij}(C) - r_j(C)$; the relation is *overtrusting* if $g_{ij} > 0$ and *distrusting* if $g_{ij} < 0$.

The behavioral measure in Definition 2.4 reflects reliance, which is what an adversary exploits and a defender can observe, although attitude and behavior can diverge under time pressure [26].

2.5.2 Trust Transfer

Trust is rarely formed about the claim that finally matters. It is formed about something nearby and then carried over. A person who trusts that a message came from a colleague's account extends that trust to the claim that the colleague wrote it and to the claim that its content is correct. A clerk who trusts that a vendor portal authenticates accounts extends that trust to the claim that a bank-detail

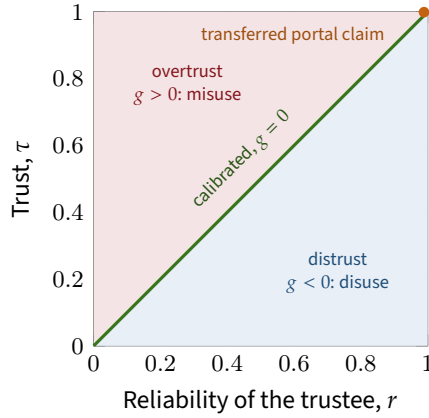


Figure 2.9. Calibration of trust. The diagonal marks calibrated trust; above it, trust exceeds reliability and admits misuse, and below it, trust falls short and produces disuse. The orange point is the transferred trust of [Example 2.4](#), just above the diagonal.

change is genuine. We call this carrying-over *trust transfer*, and it is the mechanism by which authentication, a technical property, becomes authority, a cognitive one.

Definition 2.5 (Relay path and proximate transfer). A claim reaches truster i along a *relay path* $i = j_0 \leftarrow j_1 \leftarrow \dots \leftarrow j_n$, where j_n is the source and each j_k with $1 \leq k < n$ relays the claim toward i . Let F_k be the event that hop k , from j_k to j_{k-1} , is faithful, meaning that j_k passes on a correct claim when it receives one (for $k = n$, that the source's claim is correct), with $r_k = \mathbb{P}(F_k)$. Truster i applies *proximate transfer* if it sets its trust in the claim equal to its calibrated trust in the nearest hop, $\tau = r_1$.

Assumption 2.1 (No error correction on the path). The claim received by i is correct if and only if every hop is faithful, and the events $F_1, \dots, F_n$ are independent.

Proposition 2.1 (Calibration gap of proximate transfer). Under [Assumption 2.1](#), the reliability of the claim received by i is $r = \prod_{k=1}^n r_k$, and the calibration gap of proximate transfer is

$$g = r_1 \left(1 - \prod_{k=2}^n r_k \right) \geq 0, \quad (2.4)$$

with equality if and only if $r_1 = 0$ or $r_k = 1$ for every $k \geq 2$. The gap is nondecreasing in the path length: appending a hop with reliability $r_{n+1} \in [0, 1]$ does not decrease g .

Proof. By [Assumption 2.1](#), the claim is correct exactly on the event $\bigcap_{k=1}^n F_k$, and by independence $r = \mathbb{P}(\bigcap_k F_k) = \prod_{k=1}^n r_k$. Proximate transfer sets $\tau = r_1$, so $g = \tau - r = r_1 - r_1 \prod_{k=2}^n r_k = r_1 (1 - \prod_{k=2}^n r_k)$, with the empty product equal to 1 when $n = 1$. Each factor lies in $[0, 1]$, so $\prod_{k=2}^n r_k \leq 1$ and $g \geq 0$. The product of the two nonnegative factors is zero if and only if $r_1 = 0$ or $\prod_{k=2}^n r_k = 1$, and a product of numbers in $[0, 1]$ equals 1 if and only if every factor equals 1. Appending a hop

multiplies $\prod_{k \geq 2} r_k$ by $r_{n+1} \leq 1$, which does not increase the product and hence does not decrease g . $\square$

Assumption 2.1 is conservative for the defender, because a path on which a later hop can correct an earlier error has higher reliability than the product. The defensive implication is to attach trust to the claim class that matters and to verify at the hop where reliability is lowest, which is often not the hop that is easiest to check.

2.5.3 Trust Networks

Across an organization, trust relations form a directed, weighted *trust network* whose nodes are people, agents, artifacts, and external parties, and whose edges carry $\tau_{ij}(C)$ for a claim class. Two structural properties of this network matter for security. The first is concentration: when many relations point to one trustee, such as a single identity provider, a widely used copilot, or a senior expert in the transactive directory, the reliability of that trustee becomes a common mode for many decisions, which is the correlated-judgment effect of [Example 2.2](#) at network scale. The second is asymmetry of repair. Trust is built from experience and lost after observed errors [63], so an adversary who causes a visible failure in a reliable system can move a relation from calibrated to distrusting and push users toward less controlled channels.

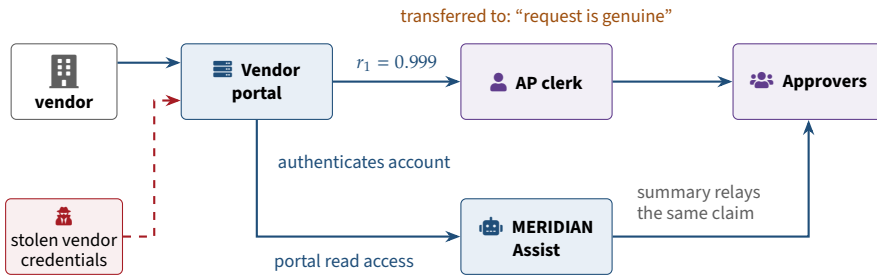


Figure 2.10. Trust transfer through the MERIDIAN vendor portal. The clerk, the assistant’s summary, and the approvers treat reliable authentication ($r_1 = 0.999$) as evidence that the request is genuine; when the account is taken over, the claim that matters has lower reliability than the hop that was checked ([Theorem 2.1](#)).

Example 2.4 (Trust transfer through the MERIDIAN vendor portal). MERIDIAN receives 40 vendor bank-detail change requests per month and requires a callback verification of 6 minutes of staff time for each, at a loaded staff cost of \$60 per hour. For this example we assume that the portal authenticates the vendor account with reliability $r_1 = 0.999$, that a fraction $\rho = 0.01$ of change requests come from a taken-over vendor account, so the second hop has reliability $r_2 = 0.99$, and that an undetected fraudulent change diverts three median payments of \$12,000, or \$36,000. The problem is to find the calibration gap of proximate transfer and the loss it exposes.

By [Theorem 2.1](#), the claim “the request is genuine” has reliability $r = 0.999 \times 0.99 = 0.989$, and a clerk who trusts it at $\tau = r_1 = 0.999$ has gap $g = 0.999 \times (1 - 0.99) = 0.010$. The expected number of fraudulent changes is $40 \times 0.01 = 0.4$ per month, exposing $0.4 \times \$36,000 = \$14,400$ per month if all are accepted. A calibration gap of one percentage point, invisible to the clerk, therefore carries a large expected loss, and the callback is worth its cost because it verifies the hop with the lowest reliability rather than the hop that is easiest to check.

Trust thus links the levels: it is held by people, attaches to agents and artifacts, and is transferred along the routines of the organization.

2.6 Cognitive Assets and Trusted Boundaries

The objects that cognitive security protects, from a person’s attention to the independence of two approvers and the calibration of a trust relation, are more varied than the data, systems, and services of classical security. This section gathers them into one category and defines the boundaries through which influence may legitimately reach them.

2.6.1 Cognitive Assets and Protected Properties

Definition 2.6 (Cognitive asset). A *cognitive asset* is a human, artificial, organizational, or hybrid component whose information-processing capabilities, states, or couplings contribute materially to a protected objective. A *protected property* of a cognitive asset is a condition on those capabilities, states, or couplings whose violation can degrade decision quality Q with respect to that objective.

The operative phrase is *contributes materially*. A sensor feed is part of a cognitive system although it does not reason, because corrupting it distorts every downstream inference. An approval queue is a cognitive asset although no member holds the whole picture, because its ordering determines what receives scrutiny. Conversely, a component that processes information but whose state cannot reach a protected objective is out of scope, and saying so keeps the category from expanding without limit.

[Figure 2.11](#) lists representative assets, protected properties, and threats at each level of the Cognitive Security Stack. A single campaign often traverses several rows while each component behaves within its specification, so the loss arises in the couplings and a single-level inventory misses it.

2.6.2 Trusted Boundaries and Authorized Influence

The term *trusted boundary* comes from network security, where it separates components with different trust levels. It needs qualification before it can be applied to cognition. People and agents are influenced continuously by colleagues, media, interfaces, training, and incentives, and a boundary that excluded influence would also exclude learning. The design problem is therefore *selective permeability*: legitimate influence should cross through channels whose identity, purpose, provenance, and authority are understood, while unauthorized influence is constrained, without making the organization closed to new information.

Level	Cognitive assets	Protected properties	Representative threats
 L5 Society	shared beliefs, public trust	accurate safety beliefs, pluralism	disinformation, coordinated inauthenticity
 L4 Organization	routines, roles, records, transactive directory	procedural integrity, independent checks	email compromise, exception-path abuse
 L3 Human-AI team	reliance, delegation, shared SA	appropriate reliance, bounded authority	automation bias, authority laundering
 L2 AI agent	context, memory, tool permissions	context integrity, least privilege	prompt injection, memory poisoning
 L1 Individual	attention, SA, trust, judgment	calibrated trust, agency	phishing, flooding, coercion

Figure 2.11. Cognitive assets, protected properties, and representative threats across the five levels of the Cognitive Security Stack. Rows are not ranked by importance; a single campaign often enters at one row and produces loss at another.

Definition 2.7 (Trusted boundary and authorized influence). A *trusted boundary* around a cognitive asset is a set of conditions under which information that crosses into the asset may change its protected states or trigger its actions. An influence is *authorized* with respect to the boundary if it crosses through a channel whose source identity, purpose, and provenance are established to the degree the boundary requires, and if the change it causes lies within the authority granted to that channel. An influence that changes a protected state or triggers an action without meeting these conditions is *unauthorized*, whether or not its content is true.

The definition places the boundary on state transitions, not on information flow, which makes it designable: the strongest architectures demand provenance, independent confirmation, and reversibility specifically for high-impact transitions and leave ordinary transitions unencumbered. The last clause of the definition matters for pluralism: a true statement delivered through a forged channel is unauthorized, and an unwelcome statement delivered through a legitimate channel is authorized. Authorization concerns the channel and the authority, not agreement with the content.

Boundaries come in several kinds, and a defensible architecture layers them because their failure modes are weakly correlated. Figure 2.12 draws six kinds around a single high-impact state transition. *Technical* boundaries are authentication and tool permissions. *Procedural* boundaries are dual approval and separation of duties. *Social* boundaries are trusted roles and sanctioned refusal, the recognized right to decline an unusual request. *Epistemic* boundaries are standards of evidence and requirements for corroboration. *Temporal* boundaries are cooling-off intervals and mandatory delays. *Physical* boundaries govern sensory access to displays, rooms, and devices.

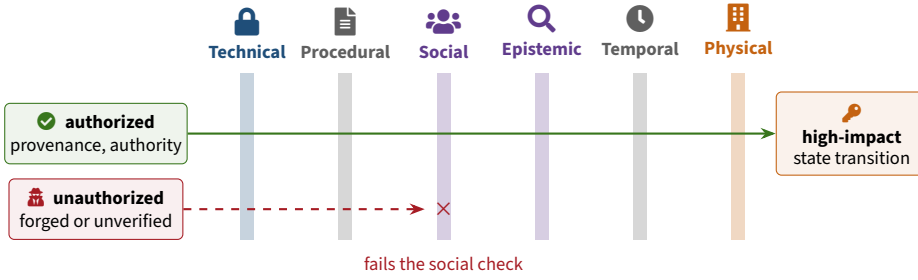


Figure 2.12. Six kinds of trusted boundary layered around a high-impact state transition, such as a change of vendor bank details. The boundaries admit authorized influence (green), which crosses with established provenance and within granted authority, and stop unauthorized influence (red) at the first boundary whose condition it fails. Ordinary transitions need not pass all six.

2.6.3 The Asset-Dependency Graph

An inventory lists assets; a defender also needs to know how they depend on one another. Infrastructure research distinguishes physical, cyber, geographic, and logical interdependencies among infrastructures [64]. For cognitive assets we use four *dependency surfaces*. A *technological* dependency exists when one asset's state is set by a system that another controls, as when an assistant reads a portal. An *informational* dependency exists when one asset's belief is formed from a record or message that another produces. A *social* dependency exists when one asset relies on another's judgment or authority, as in the transactive directory. An *organizational* dependency exists when a rule makes one asset's action conditional on others, as in dual approval. The following definition makes these dependencies a graph.

Definition 2.8 (Asset-dependency graph). An *asset-dependency graph* is a finite directed acyclic graph $G = (V, E)$ with the following labels. Each node $v \in V$ is a cognitive asset with a level $\ell(v) \in \{1, \dots, 5\}$, a gate $\omega(v) \in \{\text{OR}, \text{AND}\}$, and a direct compromise cost $\kappa_0(v) \in (0, \infty]$, the adversary's cost of impairing v directly, with $\kappa_0(v) = \infty$ if direct impairment is infeasible. An edge $(u, v) \in E$ means that v depends on u , and carries a dependency surface $s(u, v) \in \{\text{technological}, \text{informational}, \text{social}, \text{organizational}\}$. For a set $S \subseteq V$ of directly impaired nodes, the set $I(S)$ of *impaired* nodes is defined in topological order: $v \in I(S)$ if $v \in S$, or if v has at least one parent and, for $\omega(v) = \text{OR}$, some parent of v lies in $I(S)$, or, for $\omega(v) = \text{AND}$, every parent of v lies in $I(S)$. A node t is a *mission node*, and S is a *compromise set* for t if $t \in I(S)$.

The OR gate models a belief or action that is corrupted when at least one of its inputs is corrupted, which is the default for a person or agent that combines inputs without independent checks. The AND gate models a control that requires every input to be corrupted, such as a release rule that needs two approvals. The *minimum compromise cost* of t is $\kappa^*(t) = \min\{\sum_{v \in S} \kappa_0(v) : t \in I(S)\}$. Computing it exactly is a combinatorial search on a general graph, but a simple recursion gives

an upper bound that is exact when no asset feeds two branches.

Proposition 2.2 (Compromise-cost recursion). *On an asset-dependency graph, define $\hat{\kappa}$ in topological order by $\hat{\kappa}(v) = \kappa_0(v)$ if v has no parents, and otherwise*

$$\hat{\kappa}(v) = \begin{cases} \min\left\{\kappa_0(v), \min_{u:(u,v) \in E} \hat{\kappa}(u)\right\} & \text{if } \omega(v) = \text{OR}, \\ \min\left\{\kappa_0(v), \sum_{u:(u,v) \in E} \hat{\kappa}(u)\right\} & \text{if } \omega(v) = \text{AND}. \end{cases} \quad (2.5)$$

Then (i) $\kappa^(v) \leq \hat{\kappa}(v)$ for every $v \in V$, and (ii) if every node has at most one child (the graph is an in-forest), then $\kappa^*(v) = \hat{\kappa}(v)$ for every $v \in V$.*

Proof. Two facts about [Definition 2.8](#) are used. *Monotonicity:* if $S \subseteq S'$ then $I(S) \subseteq I(S')$, which follows by induction in topological order because each gate condition is preserved when more parents are impaired. *Locality:* whether $v \in I(S)$ depends only on $S \cap A(v)$, where $A(v)$ is the set consisting of v and its ancestors, again by induction in topological order, since the rule for v refers only to v and its parents.

(i) We show by induction in topological order that for each v with $\hat{\kappa}(v) < \infty$ there is a set S_v with $v \in I(S_v)$ and cost $\sum_{w \in S_v} \kappa_0(w) \leq \hat{\kappa}(v)$; if $\hat{\kappa}(v) = \infty$ the bound is trivial. If $\hat{\kappa}(v) = \kappa_0(v)$, take $S_v = \{v\}$. If $\omega(v) = \text{OR}$ and the minimum is attained by a parent u , take $S_v = S_u$; then $u \in I(S_u)$ and the OR rule gives $v \in I(S_u)$, with cost at most $\hat{\kappa}(u) = \hat{\kappa}(v)$. If $\omega(v) = \text{AND}$ and the minimum is the sum over parents, take $S_v = \bigcup_u S_u$. By monotonicity each parent u lies in $I(S_v)$, so $v \in I(S_v)$ by the AND rule, and the cost of a union is at most the sum of the costs, $\sum_u \hat{\kappa}(u) = \hat{\kappa}(v)$. Hence $\kappa^*(v) \leq \hat{\kappa}(v)$.

(ii) Suppose every node has at most one child. We show $\kappa^*(v) \geq \hat{\kappa}(v)$ by induction in topological order. Let S be a compromise set for v of minimum cost. If $v \in S$, the cost is at least $\kappa_0(v) \geq \hat{\kappa}(v)$. Otherwise v has parents and its gate condition holds in $I(S)$. If $\omega(v) = \text{OR}$, some parent u lies in $I(S)$, so S is a compromise set for u and its cost is at least $\kappa^*(u) = \hat{\kappa}(u) \geq \hat{\kappa}(v)$ by the induction hypothesis. If $\omega(v) = \text{AND}$, every parent u lies in $I(S)$, and by locality $S \cap A(u)$ is a compromise set for u , with cost at least $\hat{\kappa}(u)$. In an in-forest the ancestor sets $A(u)$ of distinct parents of v are disjoint, because a node in $A(u) \cap A(u')$ would have directed paths to v through both u and u' , and the first node at which the two paths separate would have two children. The cost of S is therefore at least $\sum_u \hat{\kappa}(u) \geq \hat{\kappa}(v)$. Combining with (i) gives equality. $\square$

The gap between $\hat{\kappa}$ and κ^* has a direct security meaning. The recursion adds the costs of the inputs to an AND gate as if they were separate assets; when the inputs share an ancestor, one impairment can satisfy the gate, and the true cost is lower. Shared ancestors of redundant checks are the graph-theoretic form of the common-mode reliance of [Example 2.2](#), and $\hat{\kappa}(t) - \kappa^*(t)$ measures how much of a control's apparent redundancy they remove.

Example 2.5 (The MERIDIAN finance approval chain as an asset-dependency graph). We model the release of a \$60,000 payment, above MERIDIAN's \$50,000 dual-approval threshold, to a vendor whose bank details were changed that week. The

directly impairable nodes and their assumed costs, in units of adversary effort, are a vendor account takeover at the portal (P, cost 1), deceiving the accounts-payable clerk directly (cost 1), subverting the callback directly (cost 2), an insider altering the vendor master file (cost 3), and deceiving each approver individually (cost 1 each). The clerk (OR) accepts a change from P; the master-file change (AND) needs both the clerk and a passed callback; MERIDIAN Assist's summary (OR) reads the master file and, in the current design, also the portal request; each approver (OR) relies on the summary; and the release (AND) needs both approvers. In the current design the callback (OR) dials a number taken from the change request, so it also depends on P. The problem is to find the minimum compromise cost κ^* of the release, compare it with the recursion $\hat{\kappa}$ of [Theorem 2.2](#), and evaluate two design changes.

[Figure 2.13](#) draws the current design. The recursion gives $\hat{\kappa}(\text{clerk}) = 1$, $\hat{\kappa}(\text{callback}) = \min\{2, 1\} = 1$, $\hat{\kappa}(\text{master file}) = \min\{3, 1 + 1\} = 2$, $\hat{\kappa}(\text{summary}) = \min\{1, 2\} = 1$, $\hat{\kappa}(\text{approver}) = 1$ for each, and $\hat{\kappa}(\text{release}) = 1 + 1 = 2$. Exhaustive search over the six directly impairable nodes gives $\kappa^* = 1$, attained by the account takeover alone, because P is a shared ancestor of both approvers through the summary. Dialing an independently held number (design D1) removes the edge from P to the callback and raises $\hat{\kappa}(\text{master file})$ to 3, but κ^* remains 1, since the summary still reads the portal. Restricting the summary to the verified master file as well (design D2) removes the last shared cheap ancestor: the recursion and the exhaustive search then agree at $\kappa^* = \hat{\kappa} = 2$, attained only by deceiving both approvers individually. One technological dependency of the assistant defeated both dual approval and callback, and the fix is to change what the assistant reads, not to add a third approver.

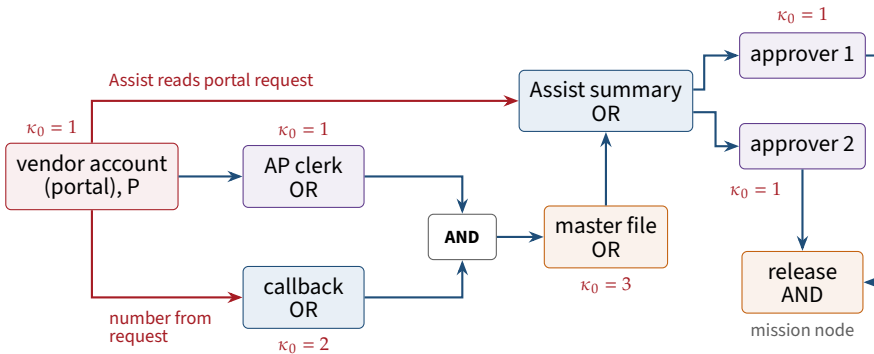


Figure 2.13. Asset-dependency graph of the MERIDIAN finance approval chain in its current design ([Example 2.5](#)). Red numbers are direct compromise costs, and the two red edges from the vendor account are the shared dependencies that let a single account takeover satisfy both AND gates, so the minimum compromise cost of the release is 1 although the recursion of [Theorem 2.2](#) reports 2.

2.7 Dependencies and the Propagation of Impairment

The compromise-cost analysis of [Section 2.6](#) asks what an adversary must impair to reach a mission node. A defender also needs the answer to the complementary question: how far an impairment travels once one asset is impaired, by an adversary or by an ordinary error.

2.7.1 From Individual Error to Societal Harm

Impairment moves along the four dependency surfaces of [Definition 2.8](#): as a corrupted display (technological), a record read as evidence (informational), borrowed credibility (social), or authority that converts one approval into action (organizational).

[Figure 2.14](#) arranges these surfaces into a ladder on which an individual error (L1) becomes a *mission* harm, an *institutional* harm carried by the organization's authority (L4), and a *societal* harm in the beliefs and actions of the public (L5). Each rung passes through a coupling that could have stopped it, such as an interface separating test from live actions, a second person, or a pre-scripted correction. The 2018 Hawaii false missile alert, described in the practice box of this section, climbed every rung.

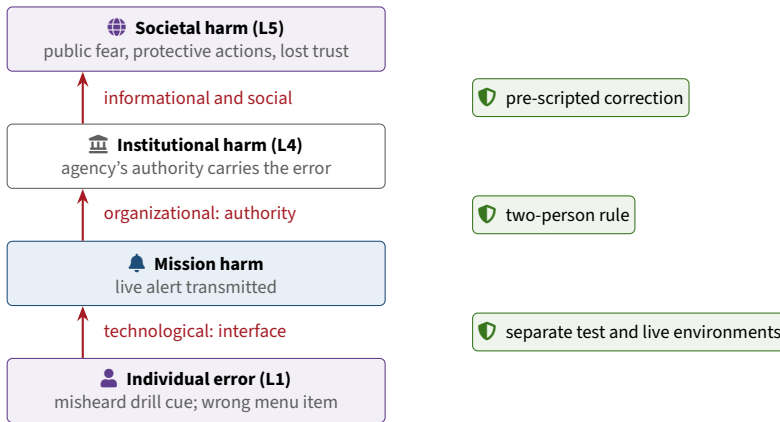


Figure 2.14. The ladder of harm. Impairment climbs from an individual error to mission, institutional, and societal harm through a dependency surface at each rung (red), and each rung has a coupling control that can stop the climb (green). The example text follows the 2018 Hawaii false missile alert.

2.7.2 Impairment as an Independent Cascade

The deterministic gates of [Definition 2.8](#) describe what an adversary must achieve. Ordinary propagation is uncertain: an impaired summary misleads some readers and not others, and an impaired operator's error is caught on some shifts and not on others. We model this uncertainty with the independent cascade model introduced for influence in social networks [65].

Definition 2.9 (Impairment cascade). Let $G = (V, E)$ be a finite directed graph and let each edge $(u, v) \in E$ carry a transmission probability $p_{uv} \in [0, 1]$. An

impairment cascade from a seed set $S_0 \subseteq V$ proceeds in rounds. The nodes of S_0 are impaired at round 0. When a node u first becomes impaired at round t , it makes a single attempt to impair each not-yet-impaired child v , which succeeds with probability p_{uv} independently of all other attempts; a success impairs v at round $t + 1$. The process stops when a round produces no new impairment, and I denotes the final set of impaired nodes.

The model treats each node as an OR gate that is triggered with some probability, which is appropriate for beliefs and actions that combine inputs without independent checks. Controls that require several impaired inputs, such as dual approval, are threshold gates; for those the cascade overstates propagation, and [Theorem 2.2](#) is the better tool. A key fact about the independent cascade is that its randomness can be drawn in advance.

Lemma 2.3 (Live-edge representation). *Declare each edge (u, v) live independently with probability p_{uv} , and let $R(S_0)$ be the set of nodes reachable from S_0 by directed paths of live edges. Then I and $R(S_0)$ have the same distribution.*

Proof. Sample the live edges first, and run the cascade of [Definition 2.9](#) using the sample: the attempt of u on v succeeds if and only if (u, v) is live. A node is impaired at most once and makes its attempts only at the round in which it becomes impaired, so each edge is attempted at most once. The outcomes of the attempts are therefore distinct coordinates of the live-edge sample, which are independent with success probabilities p_{uv} , and the coupled process has the law of [Definition 2.9](#). It suffices to show that $I = R(S_0)$ for every sample.

If $v \in I$, then either $v \in S_0$ or v was impaired by a successful attempt from a node u impaired in the previous round, along a live edge (u, v) . By induction on the round, every impaired node is joined to S_0 by a path of live edges, so $I \subseteq R(S_0)$. Conversely, let $v \in R(S_0)$ and choose a live path $w_0, w_1, \dots, w_k = v$ with $w_0 \in S_0$. We show by induction on i that $w_i \in I$. The case $i = 0$ holds because $w_0 \in S_0$. If $w_i \in I$, then at the round in which w_i became impaired, either w_{i+1} was already impaired, or w_i attempted w_{i+1} along the live edge (w_i, w_{i+1}) and succeeded. In both cases $w_{i+1} \in I$. Hence $R(S_0) \subseteq I$. $\square$

2.7.3 A Propagation Threshold

[Theorem 2.3](#) turns questions about the cascade into questions about random reachability, which yields a bound on every finite graph. For a branching approximation, the same quantity decides whether the expected cascade is finite. Let $\mathbf{P}$ be the $|V| \times |V|$ matrix with entries $P_{uv} = p_{uv}$ for $(u, v) \in E$ and 0 otherwise, and let $\bar{m} = \max_u \sum_v P_{uv}$ be the largest expected number of children that a single impaired node impairs directly.

Proposition 2.4 (Cascade size bounds and threshold). (i) *On a finite graph with seed set S_0 , for every node v ,*

$$\mathbb{P}(v \in I) \leq \min \left\{ 1, \sum_{s \in S_0} \sum_{k \geq 0} (\mathbf{P}^k)_{sv} \right\}, \quad (2.6)$$

and if $\bar{m} < 1$, then $\mathbb{E}|I| \leq |S_0|/(1 - \bar{m})$.

(ii) In the branching approximation, a single seed impairs ξ_0 nodes in the first round, and every newly impaired node independently impairs a further number of new nodes distributed as ξ , where $\xi_0, \xi, \xi', \dots$ are independent, identically distributed, nonnegative integer random variables with mean $m = \mathbb{E}\xi \in (0, \infty)$. Let Z_n be the number of nodes impaired in round n , with $Z_0 = 1$, and let $Y = \sum_{n \geq 0} Z_n$ be the total cascade size. Then $\mathbb{E}Z_n = m^n$, and

$$\mathbb{E}Y = \begin{cases} 1/(1 - m), & m < 1, \\ \infty, & m \geq 1. \end{cases} \quad (2.7)$$

Moreover, if $m \leq 1$ and $\mathbb{P}(\xi = 1) < 1$, the cascade stops in finite time with probability one; if $m > 1$, it continues without end with probability $1 - q > 0$, where q is the smallest root in $[0, 1]$ of $q = f(q)$ and $f(s) = \mathbb{E}s^\xi$.

Proof. (i) By Theorem 2.3, $\mathbb{P}(v \in I) = \mathbb{P}(v \in R(S_0))$. If $v \in R(S_0)$, some simple directed path from some $s \in S_0$ to v has all of its edges live. A simple path has distinct edges, so by independence the probability that all its edges are live is the product of their transmission probabilities. By the union bound over the seeds and the simple paths, $\mathbb{P}(v \in I) \leq \sum_{s \in S_0} \sum_{\text{simple } s \rightarrow v \text{ paths}} \prod_{(a,b) \text{ on path}} p_{ab}$. Each simple path of length k is a walk of length k , and the sum of edge-probability products over all walks of length k from s to v equals $(P^k)_{sv}$, with P^0 the identity. The terms are nonnegative, so (2.6) follows, and the minimum with 1 is trivial. Summing over v gives $\mathbb{E}|I| = \sum_v \mathbb{P}(v \in I) \leq \sum_{s \in S_0} \sum_{k \geq 0} (P^k \mathbf{1})_s$. Since P is nonnegative and $P\mathbf{1} \leq \bar{m}\mathbf{1}$ entrywise, induction gives $P^k \mathbf{1} \leq \bar{m}^k \mathbf{1}$, and therefore $\mathbb{E}|I| \leq |S_0| \sum_{k \geq 0} \bar{m}^k = |S_0|/(1 - \bar{m})$ when $\bar{m} < 1$.

(ii) Conditional on $Z_n = z$, the variable Z_{n+1} is a sum of z independent copies of ξ , so $\mathbb{E}[Z_{n+1} | Z_n] = mZ_n$ and, by the tower property, $\mathbb{E}Z_{n+1} = m\mathbb{E}Z_n$. With $\mathbb{E}Z_0 = 1$ this gives $\mathbb{E}Z_n = m^n$. The partial sums $\sum_{n \leq N} Z_n$ increase to Y , so by monotone convergence $\mathbb{E}Y = \sum_{n \geq 0} m^n$, which equals $1/(1 - m)$ for $m < 1$ and diverges for $m \geq 1$.

For the stopping probability, let $q_n = \mathbb{P}(Z_n = 0)$. Conditioning on the first round, the process stops by round n exactly when each of the ξ_0 subtrees started in round 1 stops within $n - 1$ further rounds, and these subtrees are independent copies of the process, so $q_n = \mathbb{E}[q_{n-1}^{\xi_0}] = f(q_{n-1})$ with $q_0 = 0$. The events $\{Z_n = 0\}$ increase in n , so q_n increases to $q = \mathbb{P}(\text{the cascade stops})$, and continuity of f on $[0, 1]$ gives $q = f(q)$. If $s^* \in [0, 1]$ is a root of $s = f(s)$, then $q_0 = 0 \leq s^*$, and $q_{n-1} \leq s^*$ implies $q_n = f(q_{n-1}) \leq f(s^*) = s^*$ because f is nondecreasing; hence $q \leq s^*$, and q is the smallest root in $[0, 1]$.

Now $f(1) = 1$, f is convex on $[0, 1]$, and its left derivative at 1 is m . Suppose $m \leq 1$ and $\mathbb{P}(\xi = 1) < 1$. If $\mathbb{P}(\xi \geq 2) > 0$, f is strictly convex, so for $s \in [0, 1)$, $f(s) > f(1) + m(s - 1) = 1 - m(1 - s) \geq s$. If $\mathbb{P}(\xi \geq 2) = 0$, then $f(s) = \mathbb{P}(\xi = 0) + \mathbb{P}(\xi = 1)s$ with $\mathbb{P}(\xi = 0) = 1 - \mathbb{P}(\xi = 1) > 0$, and $f(s) - s = \mathbb{P}(\xi = 0)(1 - s) > 0$ for $s < 1$. In both cases $s = 1$ is the only root, so $q = 1$. Suppose instead $m > 1$. Then $(1 - f(s))/(1 - s) \rightarrow m > 1$ as $s \uparrow 1$, so $f(s) < s$ for some $s_1 < 1$, while $f(0) - 0 \geq 0$. By the intermediate value theorem, $f(s) = s$ for some $s \in [0, s_1]$, so $q \leq s_1 < 1$. $\square$

Part (i) holds on every finite graph but can be loose, because it counts walks rather than distinct nodes, and part (ii) is exact for the branching model. Both identify the same controlling quantity, the expected number of assets that one impaired asset directly impairs. A defender who cannot remove every error can still hold this number below one, by lowering transmission probabilities (verification at couplings) or by lowering the number of dependents per asset (compartmentalization).

Example 2.6 (Cascade size on the MERIDIAN outage-information graph). During the storm-outage scenario, 310,000 MERIDIAN customers are without power. For this example we assume that the outage-map feed (D) displays a wrong restoration estimate, and that the error can propagate along the dependency graph of Figure 2.15: to the grid shift lead (O) with probability 0.5 and to MERIDIAN Assist, which drafts customer notices from the feed (A), with probability 0.8; from the shift lead to the call-center lead (CC) with probability 0.5 and to the communications officer (CM) with probability 0.4; from Assist to the communications officer with probability 0.6; and from the communications officer and the call-center lead to MERIDIAN’s public social media post (S), which reaches 240,000 followers, with probabilities 0.7 and 0.3. The problem is to find the probability that the public post carries the error and the expected number of impaired assets, and to compare them with the bound of Theorem 2.4.

By Theorem 2.3, we enumerate the $2^7 = 128$ live-edge configurations. The call-center lead is impaired with probability $0.5 \times 0.5 = 0.25$. The communications officer is impaired unless both of its incoming chains fail, and the two chains use disjoint edges, so the probability is $1 - (1 - 0.5 \times 0.4)(1 - 0.8 \times 0.6) = 0.584$. The post is impaired with probability 0.4477, a value that requires the enumeration because its two parents share the ancestor O. The expected cascade size, including the seed, is $1 + 0.5 + 0.8 + 0.25 + 0.584 + 0.4477 = 3.58$. The largest row sum of $\mathbf{P}$ is $\bar{m} = 1.3$ at the feed, so the geometric bound of part (i) does not apply, but the path sums $(\mathbf{P}^k)$ give $\mathbb{P}(S \in I) \leq 0.551$ and $\mathbb{E}|I| \leq 3.78$. The conclusion is that a single feed error reaches the public post almost half the time, and that verification at the feed, whose outgoing transmission probabilities sum to 1.3, lowers the expected reach the most. Halving the outgoing probabilities of one node at a time lowers the expected cascade size from 3.58 to 2.34 at the feed, 3.26 at Assist, and 3.35 at the shift lead, so the node with the second largest row sum (the shift lead, 0.9) is not the second most valuable place to verify; Assist is, because its single edge feeds the strongest path to the post.

Example 2.7 (Propagation threshold for internal lures from a compromised mailbox). At MERIDIAN the click or credential-submission rate on delivered phishing is 8% at baseline and 4% after annual training with quarterly simulations. For this example we assume that an adversary who controls a mailbox sends a lure to k internal contacts, that each contact is impaired independently with the same probability p as for external phishing, that each impaired mailbox repeats the step with k fresh contacts, and that overlaps between contact lists can be neglected, so that the branching approximation of Theorem 2.4 applies with $\xi \sim \text{Binomial}(k, p)$

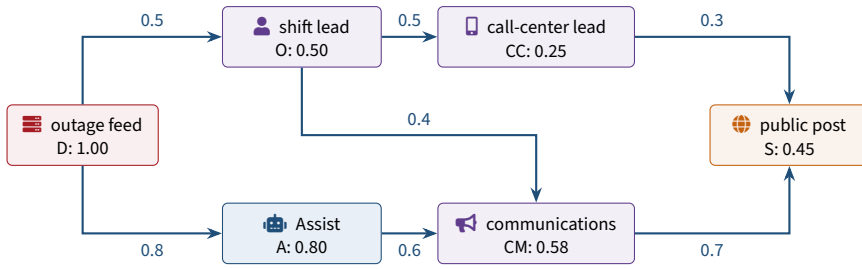


Figure 2.15. Outage-information dependency graph of Example 2.6. Edge labels are transmission probabilities, and each node shows the exact probability that it carries the feed error; two partly independent chains reach the public post.

and $m = kp$. The problem is to find the expected number of compromised mailboxes $\mathbb{E}Y$, including the first, and the threshold number of contacts.

By (2.7), $\mathbb{E}Y = 1/(1 - kp)$ for $kp < 1$. With training ($p = 0.04$), $k = 5$ gives $m = 0.2$ and $\mathbb{E}Y = 1.25$, and $k = 20$ gives $m = 0.8$ and $\mathbb{E}Y = 5$; the threshold is $k = 25$. At the baseline rate ($p = 0.08$), $k = 10$ already gives $\mathbb{E}Y = 5$, the threshold falls to $k = 12.5$, and $k = 20$ gives $m = 1.6$, for which the expected size is unbounded in the approximation. For $k = 20$ and $p = 0.08$, the smallest root of $q = (1 - p + pq)^{20}$ is $q = 0.335$, so the cascade dies out with probability 0.335 and continues without end in the approximation with probability 0.665. Figure 2.16 plots $\mathbb{E}Y$ against k . Halving the click rate doubles the number of contacts that an impaired mailbox can reach before propagation becomes self-sustaining, which is why limits on internal bulk messaging and training act on the same quantity m .

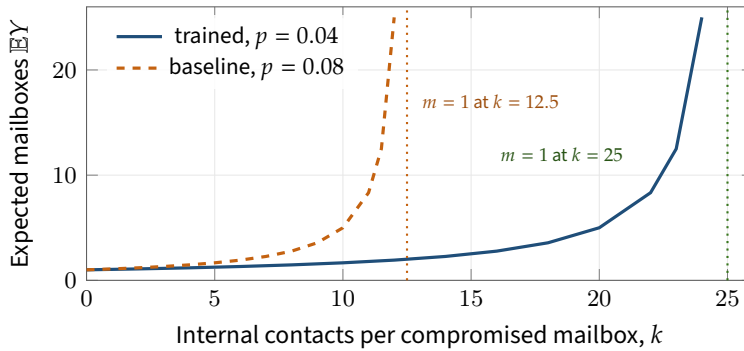


Figure 2.16. Expected number of compromised mailboxes in the branching approximation of Example 2.7. Each curve diverges as $m = kp$ approaches 1 (dotted lines); halving the click rate moves the threshold from 12.5 to 25 contacts.

Cognitive Security in Practice: The 2018 Hawaii False Ballistic Missile Alert

On Saturday, January 13, 2018, at 8:07 a.m. Hawaii Standard Time, the Hawaii Emergency Management Agency (HI-EMA) sent a ballistic missile alert through the Emergency Alert System (EAS) and Wireless Emergency Alerts (WEA). It told the public that a missile threat was inbound, to seek immediate shelter, and that the message was not a drill. No missile had been launched. The account below follows the investigation report of the Federal Communications Commission (FCC) [66].

The alert began as an internal, no-notice drill that the midnight-shift supervisor ran during the 8:00 a.m. shift change. The day-shift supervisor misunderstood the plan and was not in the watch center. The recorded drill message began and ended with “exercise, exercise, exercise” but, in a deviation from the drill script, also contained the phrase “this is not a drill.” The warning officer at the alert terminal reported not hearing the exercise cues, heard the second phrase, and believed that the attack was real. The officer selected the live missile alert from a drop-down menu that listed it on the same screen as the test alert, and confirmed a prompt that read the same for tests and live alerts and did not display the message text. Only one credentialed officer was required to send the alert.

Figure 2.17 gives the timeline. HI-EMA canceled further transmission at 8:12 a.m. without issuing an all-clear and posted on Twitter at 8:20 a.m. that there was no missile threat. Its checklist contained no protocol for correcting a false alert, and the correction was sent through the alert systems at 8:45 a.m., 38 minutes after the false alert. After the event HI-EMA required supervisors to oversee drills, adopted a two-person rule for tests and live alerts, prepared correction templates, and asked its software vendor to separate the test and live environments more clearly [66].

In the terms of this chapter, a Level 1 failure (unperceived drill cues) produced a false Level 2 comprehension, and three missing couplings let it climb the ladder of Figure 2.14: an interface that did not separate test from live actions, an organizational rule that let one person commit the agency’s authority, and the absence of a pre-scripted correction channel at the institutional-to-public rung.

The compromise-cost and cascade analyses locate the same design lever: the couplings between assets, whose transmission probabilities, shared ancestors, and authority can be changed without requiring individuals to be infallible.

2.8 Ethics and Limits

An inventory of cognitive assets includes people, and the tools of this chapter can be turned against the people they describe. The first harm is surveillance: a program that measures situation awareness, trust calibration, or state-dependent exposure

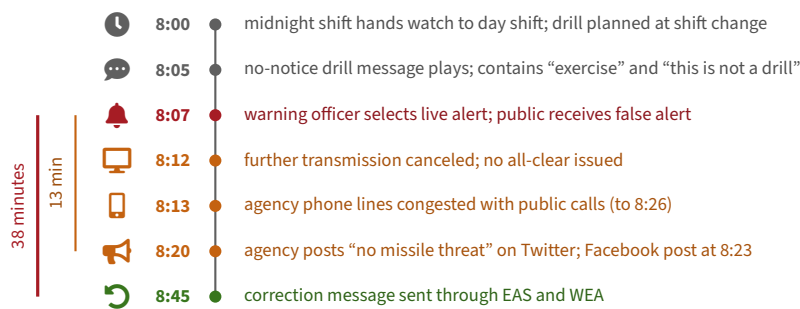


Figure 2.17. Timeline of the January 13, 2018 Hawaii false missile alert, Hawaii Standard Time, from the FCC report [66]. The correction through the alert systems (green) took 38 minutes, against 13 minutes for the first no-threat post on social media.

can drift into continuous monitoring of individual employees, which intrudes on privacy and can be coercive. The second is stigmatization: a dependency graph that marks a person as a low-cost entry point invites the weakest-link reading and can shape assignments or discipline on the basis of a model parameter rather than conduct. The third is misclassification of dissent: treating an analyst’s unconventional assessment, a whistleblower’s report, or a public challenge to an official statement as an *impaired node* violates the separation of authorization from agreement in Definition 2.7 and the pluralism constraint of cognitive defense. The fourth is dual use: a compromise-cost analysis is also a targeting map, so the graph itself needs access control.

Figure 2.18 separates legitimate from harmful uses by whether person-level cognitive data is used to design the system or to evaluate the person. Controls should accordingly attach to couplings, such as what an assistant reads or how a callback number is obtained, rather than to the scrutiny of individual people.

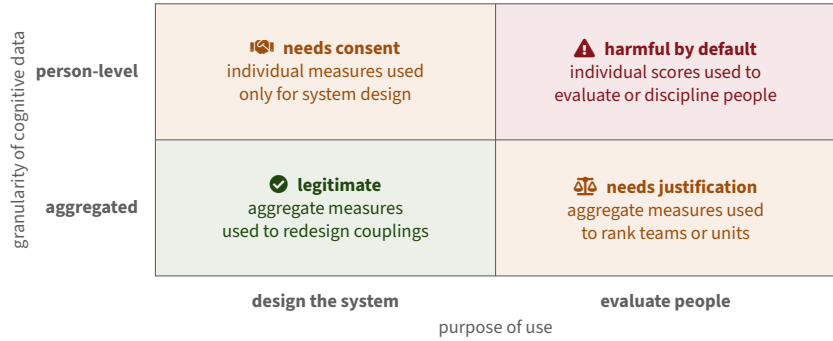


Figure 2.18. Legitimacy of cognitive-asset measurement by the granularity of the data and the purpose of use. Individual scores used to evaluate people are harmful by default unless they rest on consent, necessity, and a route to contest conclusions.

The models carry their own limits. The compromise costs κ_0 of Theorem 2.2 are judgments, not measurements, and a minimum compromise set is only as reliable as the cost estimates and the completeness of the graph. The independent

cascade of [Definition 2.9](#) assumes that transmission attempts are independent, that each node behaves as a probabilistic OR gate, and that probabilities are stationary; correlated beliefs, threshold behavior in groups, and learning after the first error violate these assumptions, and the branching approximation further ignores overlap between contacts. The transfer result of [Theorem 2.1](#) assumes no error correction along a relay path. Numerical inputs marked as assumptions in the worked examples are illustrative, not estimates, because MERIDIAN is notional. Finally, the functional description of artificial agents in [Definition 2.3](#) is a modeling choice. It supports security analysis without implying that an agent understands, intends, or is responsible for what it produces, and responsibility for an agent's actions remains with the people and organizations that deploy it.

2.9 Summary

This chapter asked what cognitive security protects and through which dependencies it can be reached. The individual is a bounded cognitive system whose constructs rest on evidence of unequal strength, and whose exposure depends more on state than on trait, so the book models the conditions under which a cognitive state becomes exploitable rather than sorting people into strong and weak links. Situation awareness refines this account for operators: its levels are cumulative, most documented breakdowns occur at perception, and the order in which information arrives can matter more than expertise.

Organizations perceive, remember, and decide through routines, roles, retention locations, and transactive memory, and their redundancy protects only when redundant judgments rest on independent evidence. Artificial agents are functional cognitive systems, and a person and an agent together form a joint system whose reliability depends on the person's vigilance as much as on the agent's recall. Trust couples these levels; treated as a system property it has a calibration gap, and proximate transfer overstates reliability by an amount that grows with the number of unseen hops.

Cognitive assets, protected properties, and trusted boundaries place security on state transitions rather than on information flow, and separate authorization from agreement with content. The asset-dependency graph shows how one shared dependency can defeat several nominally redundant controls, and the independent cascade model shows that impairment stays bounded when each impaired asset directly impairs fewer than one other on average. The Hawaii false alert illustrated how missing couplings let an individual error climb to societal harm, and the ethics section argued that inventories including people should redesign couplings rather than evaluate individuals.

Exercises

Exercise 2.1 [C] For each of the five components of individual cognition in [Figure 2.2](#), name one manipulation that acts on it and one control that reduces exposure without relying on the individual's vigilance. State the evidence status of each construct on which the answer relies, using [Figure 2.3](#).

Exercise 2.2 [C] Classify each of the following as a Level 1, Level 2, or Level 3 situation awareness failure, and justify the classification: an operator does not see an alarm hidden below the visible part of a list; an analyst reads a correct log entry but attributes it to maintenance; a shift lead correctly identifies a fault but expects load to fall when it will rise.

Exercise 2.3 [A] In [Example 2.1](#), find the largest alarm count N for which $P_1(N) \geq 0.5$ when $c = 12$, $K = 3$, and $s = 2$. Then find the reading capacity c needed to keep $P_1(60) \geq 0.5$. Interpret the two answers as design requirements for alarm management.

Exercise 2.4 [A] Generalize [Example 2.2](#) to n approvers who each detect a fraudulent request with probability d from independent evidence, and who with probability c all rely on one shared artifact. Derive the miss probability $M_n(c)$, show that $\lim_{n \rightarrow \infty} M_n(c) = c(1 - d)$, and explain why adding approvers cannot compensate for common-mode reliance.

Exercise 2.5 [A] In [Example 2.3](#), suppose analyst detection on shown alerts depends on utilization ρ as $d_a(\rho) = 0.98 - 0.15\rho$ and, independently, automation bias subtracts $\beta \geq 0$. For which values of β does the copilot lower the joint miss probability compared with analysts working alone at utilization 0.67 with no auto-closure and no bias? State all assumptions.

Exercise 2.6 [C] Give an example, from a sector other than utilities, of trust transfer in which authentication of a channel is taken as evidence for the content of a message. Identify the relay path, the hop that is checked, and the hop with the lowest reliability.

Exercise 2.7 [A] Prove that when [Assumption 2.1](#) is relaxed so that a later hop can correct an earlier error, the reliability of the received claim can exceed $\prod_k r_k$. Construct a two-hop example with explicit probabilities, and show that the calibration gap of proximate transfer can then be negative.

Exercise 2.8 [A] In [Example 2.4](#), suppose the callback to an independently held number detects a fraudulent change with probability 0.9. Find the fraud base rate ρ at which the monthly cost of callback verification equals the expected loss it prevents, with the other values unchanged. Then repeat the calculation if callback detection falls to 0.6 because callbacks are placed to numbers supplied in the request.

Exercise 2.9 [A] Show by a counterexample that the recursion of [Theorem 2.2](#) can overstate the minimum compromise cost by an arbitrarily large factor. Construct a family of asset-dependency graphs with an AND gate over n parents that share one ancestor of cost 1, and compute $\hat{\kappa}$ and κ^* .

Exercise 2.10 [A] For the outage-information graph of [Example 2.6](#), compute the probability that the public post is impaired if a verification step lowers the transmission probability from the feed to Assist from 0.8 to 0.4. Compare the reduction with that obtained by lowering the probability from the communications officer to the post from 0.7 to 0.35, and explain the difference using the path sums of (2.6).

Exercise 2.11 [A] In the branching approximation of [Example 2.7](#) with $k = 20$ and $p = 0.08$, suppose a rate limit caps internal messages so that a compromised mailbox reaches at most k' contacts. Find the largest k' for which $\mathbb{E}Y \leq 3$, and compute the extinction probability q for $k = 15$.

Exercise 2.12 [C] Using the practice box on the 2018 Hawaii false alert, map each contributing factor reported by the Federal Communications Commission to a dependency surface and to a rung of [Figure 2.14](#). For each rung, name the control that HI-EMA later adopted, and identify one rung for which the report describes no control.

Exercise 2.13 [P] *Lab: MERIDIAN asset-dependency graph and cascade simulation.* Build the asset-dependency graph of the MERIDIAN finance approval chain ([Example 2.5](#)) and the outage-information graph ([Example 2.6](#)) in code; the companion files `companion/ch02/ch02_adg.py` and `ch02_examples.py` provide a starting point. (a) Implement exhaustive search for κ^* and the recursion $\hat{\kappa}$, and reproduce the values for designs D0, D1, and D2. (b) Implement the independent cascade by simulation and by live-edge enumeration, and reproduce $\mathbb{E}|I| = 3.58$. (c) Add selected SOC and customer-communication assets with justified transmission probabilities, and find the single edge whose probability, if halved, most reduces the probability that the public post is impaired. (d) Report the assumptions that most affect the conclusions and describe how they could be estimated from data without scoring individual employees.

Notes and Further Reading

Individual cognition. Baddeley’s episodic buffer paper [67] extends the multi-component model of working memory, and Evans and Stanovich [40] correct common misreadings of dual-process theories. Heuristics and biases as attack surfaces are developed in [Chapter 3](#).

Situation awareness. Attentional denial of service against operators, which targets Level 1 situation awareness directly, is the subject of [Chapter 10](#); our own work on alert overload and human-assistive attention management [68] is one formal treatment.

Distributed, organizational, and joint cognition. Cooke and colleagues [69] locate team cognition in interaction rather than in the sum of members’ knowledge. The human-cyber-physical framing of cognitive security, including the mission stack and the role of situation awareness, problem solving, and collaboration, is developed in the monograph by Huang and Zhu [3]. Insider manipulation of organizational decisions is treated in [Chapter 12](#), and human-AI couplings in [Chapter 19](#).

Trust. Hoff and Bashir [70] separate dispositional, situational, and learned trust in automation, and Mayer, Davis, and Schoorman [71] ground organizational

trust in perceived ability, benevolence, and integrity; Lee and See [26] also define the resolution and specificity of trust.

Dependencies and cascades. Rinaldi, Peerenboom, and Kelly [64] introduced the vocabulary of infrastructure interdependency that our dependency surfaces adapt. Watts [72] analyzes threshold cascades on random networks, which model group-level adoption better than the independent cascade. Athreya and Ney [73] give the general theory of branching processes behind [Theorem 2.4](#). Metrics that turn cascade reach into decision-quality loss are developed in [Chapter 4](#), and cross-level pathways into physical processes in Chapter 20.

Cognitive Vulnerabilities, Threats, and the Cognitive Attack Chain

Learning Objectives

- ▶ Define a cognitive vulnerability as an exploitable regularity and distinguish innate from acquired vulnerabilities, and vulnerability from error, exploit mechanism, and technique.
- ▶ Explain how the levers of authority, familiarity, repetition, urgency, reciprocity, and identity convert latent regularities into decision errors, and how organizations, networks, recommender systems, and interfaces create systemic vulnerabilities.
- ▶ Characterize threat actors by capability, intent, access, and opportunity, and relate these attributes to exposure and susceptibility.
- ▶ Trace a campaign through the seven stages of the cognitive attack chain, including level switching and dwell time.
- ▶ Model the chain as an absorbing Markov chain, derive absorption probabilities and expected times through the fundamental matrix, and prove that attack success decreases in stage-wise detection probabilities.
- ▶ Compute the marginal value of interdiction at each stage and explain why vulnerability analysis must not treat dissent or unconventional belief as compromise.

A security discipline needs a precise account of what can go wrong before it can decide what to defend, and this chapter builds that account for cognition. [Sections 3.1 to 3.4](#) define cognitive vulnerabilities as exploitable regularities, describe the levers that trigger them and the structures that make them systemic, and characterize the actors who exploit them. [Sections 3.5 and 3.6](#) arrange this activity in time as the seven-stage cognitive attack chain and model it as an absorbing Markov chain with complete proofs and a MERIDIAN business email compromise example. [Section 3.7](#) draws the boundary that keeps vulnerability analysis from becoming a tool against dissent and states the harms and limits of the analysis.



Figure 3.1. Level map for Chapter 3. The chapter concentrates on individuals (L1) and organizations (L4) across all five stages of the cognitive loop, with artificial agents (L2) treated as a secondary target. Society (L5) enters through recommender systems and networks that shape what is sensed and believed, and human-AI teams (L3) through delegated decisions.

Figure 3.1 places the chapter on the Cognitive Security Stack, whose five levels run from the individual (L1) to society (L5), and on the cognitive loop of Sense, Model, Decide, Act, and Learn. The attack chain developed here is the reason for the broad shading: a single campaign typically enters at one level and stage and takes effect at another.

MERIDIAN Running Example

MERIDIAN is a notional regional energy and water utility created for teaching; it does not represent a real organization. Its finance and procurement office processes about 900 vendor payments per week, with a median value of \$12,000, and receives about 40 requests per month to change vendor bank details. Policy requires a callback on a number already on file before a bank-detail change is applied and a second approver for payments of \$50,000 or more.

On a Thursday before a quarter close, an accounts payable clerk receives a message that appears to come from a long-standing maintenance contractor. It references a real purchase order and asks that the next invoice be paid to a new account before month end. The clerk forwards it to the shift lead as routine. The lead notices that the reply-to domain differs from the contractor’s usual domain by a single character, places a callback to the contractor’s number of record, and learns that no change was requested. The attempt stops there. The chapter asks what made the message plausible, which earlier stages produced it, and how much each control contributed to stopping it.

Table 3.1. Chapter-specific notation. Symbols common to the book are listed in the front-matter Notation section.

Symbol	Meaning
K	number of transient stages of the attack chain ($K = 7$)
e, ψ, κ	exposure probability, susceptibility, conversion of belief into action
p_k, q_k, w_k	undefended per-step probabilities of advancing, abandoning, and waiting at stage k
δ_k	per-step probability that the defender detects and interdicts at stage k
α_k, d_k	probability of advancing from stage k ; expected steps per visit to stage k
$\mathbf{M}, \mathbf{G}$	transient-to-transient and transient-to-absorbing blocks of $\mathbf{P}$
$\mathbf{N}$	fundamental matrix $(\mathbf{I} - \mathbf{M})^{-1}$
$\mathbf{B}, \mathbf{h}$	absorption probability matrix $\mathbf{N}\mathbf{G}$; success probability vector
$\tau, \mathbf{t}$	time to absorption; vector of expected times to absorption

3.1 Vulnerability as Exploitable Regularity

People attend to what is salient, rely on familiar cues, defer to apparent authority, and repeat what worked before. These regularities make cognition efficient in ordinary environments, and they make it predictable, which is what an adversary needs: a message that reaches an overloaded clerk near a deadline and imitates a familiar vendor is a good investment because the response can be anticipated. This section turns that observation into a definition, classifies the regularities, and separates a standing vulnerability from the exposure that exercises it.

3.1.1 Definition and Anatomy

The term vulnerability is borrowed from computer security, where it names a flaw that an attacker can use to violate a security property. The cognitive analogue differs in one essential respect: the regularity being exploited is usually not a flaw. The availability heuristic, which judges frequency by the ease of recalling examples, performs well when recall tracks experience [27]; simple heuristics can match or outperform elaborate strategies in environments to which they are adapted [74]. The regularity becomes a vulnerability only relative to an environment that an adversary can shape.

Definition 3.1 (Cognitive vulnerability). A *cognitive vulnerability* of a cognitive system (a person, a team, an organization, or an artificial agent) is a regularity in how the system senses, models, decides, acts, or learns that satisfies three conditions: (i) it is predictable at the level of a population, role, or system class; (ii) conditions that an adversary can create or time increase the probability that it produces a decision error; and (iii) the resulting error moves a decision in a direction that serves the adversary.

The definition has three consequences. First, it locates the vulnerability in the regularity rather than in a person: an authority heuristic is shared by most members of a hierarchical organization, so calling one employee “the vulnerability” mistakes the carrier for the property. Second, condition (ii) makes vulnerability

relational. The same regularity is harmless where an adversary cannot influence the triggering conditions and consequential where it can. Third, condition (iii) separates vulnerability from generic fallibility; a random lapse that benefits no one is an error but not an exploited vulnerability.

Three further terms keep the analysis precise. An *error* is the observed failure: the approval, the click, the wrong belief. In Reason's classification of human error, slips and lapses are failures of execution and memory, while mistakes are failures of planning [20]. A vulnerability sits upstream of these outcome categories and explains why a class of error recurs. An *exploit mechanism* is the causal route by which a trigger turns the regularity into the error, for instance impersonation of an authority. A *technique* is the packaged method that delivers the mechanism in the field, for instance a spoofed message timed to a payment run. Authority deference is the vulnerability, impersonation is the mechanism, and the timed spoofed message is the technique. Keeping the three apart matters because they call for different evidence and different controls: the regularity is established by behavioral research, the mechanism by incident analysis, and the technique by telemetry.

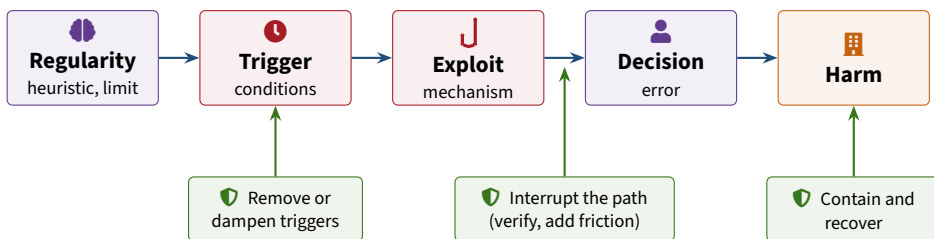


Figure 3.2. Anatomy of a cognitive exploit. A regularity becomes a vulnerability only when trigger conditions that an adversary can influence activate an exploit mechanism; the error is the observable part. Defenses act on the triggers, on the path from mechanism to error, or on the consequences, and none of them requires changing the regularity itself.

Figure 3.2 summarizes the anatomy. A program that sees only the error tends to answer with blame, whereas one that sees the full path can remove triggers, interrupt the path (a callback before a bank-detail change), or contain the consequence (a payment hold), each of which works while the regularity persists.

3.1.2 Innate and Acquired Vulnerabilities

A classification is useful when it tells a defender which class of control can move the quantity at issue. Following Huang and Zhu, we classify vulnerabilities by whether short-term external intervention, such as training, education, or incentive design, can mitigate them [3]. *Innate* vulnerabilities arise from the architecture of cognition: limited attention, reliance on heuristics, the coupling of emotion and judgment, and sensitivity to social information. Training cannot enlarge working memory or remove the pull of social proof, although it can teach cue recognition and routines that reduce exploitability in specific settings. *Acquired* vulnerabilities are learned or institutional: gaps in knowledge, habits formed by repetition in a particular environment, and incentives that reward the insecure action. They can

in principle be removed, and the organization often creates them itself. Figure 3.3 shows the resulting tree, with the control class each branch implies.

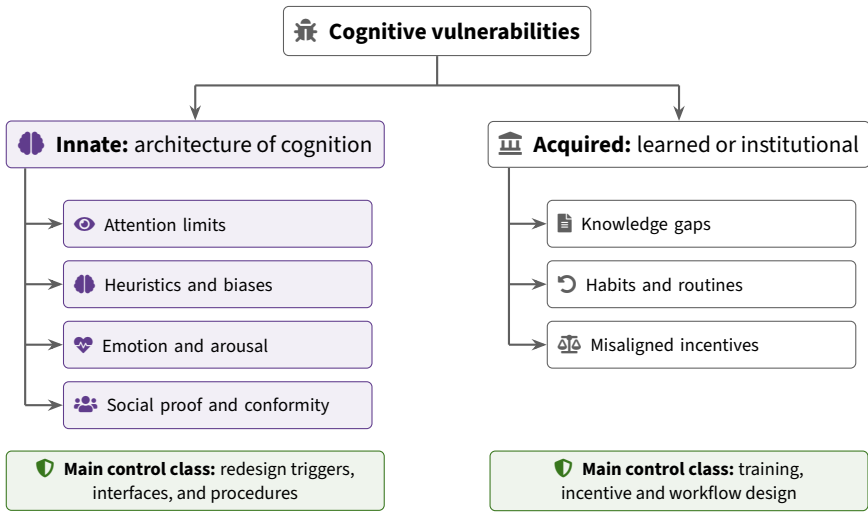


Figure 3.3. Taxonomy of cognitive vulnerabilities. Innate vulnerabilities follow from the architecture of cognition and are mitigated mainly by changing the environment in which decisions are made; acquired vulnerabilities are learned or created by the organization and respond to training and to incentive and workflow design. Real incidents usually engage several branches at once.

Attention limits are the most basic innate vulnerability. Attention is a scarce resource that must be allocated across competing stimuli, and what falls outside the allocated region can go unnoticed even when it is salient. In a well-known demonstration, observers counted basketball passes in a video, and 46% of them, pooled across conditions, failed to notice an unexpected person in a gorilla suit or carrying an umbrella walking through the scene [36]. In security settings the unattended stimulus is a sender domain that differs by one character or an unusual login location, and the competing task is the work the person is paid to do. Attention can also be depleted deliberately: an adversary who floods an analyst with alerts reduces the attention available for the one that matters, a pattern that Huang and Zhu model as an informational denial of service against alert triage [2].

Heuristics and biases are the second family. Tversky and Kahneman showed that judgments of probability rely on representativeness, availability, and anchoring, which produce systematic departures from normative reasoning [27]; prospect theory adds that outcomes are evaluated as gains and losses relative to a reference point, with losses weighted more heavily [75]. Simon’s earlier observation that decision makers satisfice, stopping at the first option that meets an aspiration level, explains why a plausible request is often accepted without search for disconfirming evidence [28]. Base-rate neglect is especially relevant to self-assessment: participants in one study relied less on base rates when predicting their own susceptibility to phishing than when predicting that of others, which

supports a belief that attacks succeed against other people [76].

Emotion and arousal form the third family. Fear of loss, anxiety about a deadline, and the wish to help a colleague narrow deliberation and shift judgment toward cues that can be processed quickly. Dual-process accounts of persuasion describe this shift as movement from central processing of argument quality toward peripheral processing of cues such as source attractiveness or apparent expertise [77]. In phishing studies, attention to urgency cues in the message and habitual patterns of email use were associated with higher susceptibility [78]. *Social proof and conformity*, the fourth family, is the tendency to treat the behavior and judgments of others as evidence. Asch's line-judgment experiments found that a unanimous majority giving a wrong answer drew conforming errors from many participants [79], and a review of compliance research documents how perceived consensus and social norms guide behavior when a situation is ambiguous [80].

The evidence behind these families is uneven, and the analysis should not claim more than the literature supports. Inattentional blindness, anchoring, loss aversion, and the illusory truth effect have been reproduced in many laboratories. Other findings that entered popular accounts of manipulation have fared worse. A well-known claim that exposure to words associated with old age slows walking speed did not replicate under controlled conditions [81], and a preregistered replication across 23 laboratories found an ego-depletion effect close to zero [44]. A large coordinated effort to reproduce 100 published psychology studies obtained statistically significant results in fewer than half of them [82]. For vulnerability analysis the lesson is to prefer regularities with robust support, to treat effect sizes from single studies as provisional, and to measure susceptibility locally rather than import it from the literature.

Acquired vulnerabilities differ in kind. A *knowledge gap* is a missing fact, such as not knowing that a callback number printed in a message is worthless for verification, and training is its first-line control. A *habit* is a context-cued response that runs with little deliberation once a behavior has been repeated in a stable setting [83], such as approving routine requests in a batch; an adversary who imitates the routine setting inherits the automaticity. *Misaligned incentives* make the insecure action locally rational: when verification is slow and throughput is measured, verification loses [55], and each additional security demand competes with productive work within a limited compliance budget [84]. A check skipped because of misaligned incentives looks like an attention lapse; whether skipped checks track workload or instead track deadline and appraisal pressure separates the two.

3.1.3 Susceptibility, Exposure, and Conversion

A vulnerability is a standing property; harm requires that it be exercised. The distinction between susceptibility and exposure makes this precise and prevents a common error: labeling people as high risk on the strength of click history alone. Fix a scenario (an adversary technique over a period) and a target population, and consider three nested events for a member of that population: $\mathcal{E}$, the member encounters the attack; $\mathcal{B}$, the member forms the intended belief (for instance, that a bank-detail change is genuine); and $\mathcal{C}$, the member acts on it. Because

$C \subseteq \mathcal{B} \subseteq \mathcal{E}$, the chain rule gives

$$\mathbb{P}(C) = \underbrace{\mathbb{P}(\mathcal{E})}_e \underbrace{\mathbb{P}(\mathcal{B} \mid \mathcal{E})}_\psi \underbrace{\mathbb{P}(C \mid \mathcal{B})}_\kappa. \quad (3.1)$$

Definition 3.2 (Exposure, susceptibility, and conversion). In Equation (3.1), the *exposure* e is the probability of encountering the attack, the *susceptibility* ψ is the probability of forming the intended belief given exposure, and the *conversion* κ is the probability of acting on that belief given that it has formed.

The three factors respond to different controls, as Figure 3.4 shows. A simulated phishing campaign delivered to every recipient sets $e = 1$ by design and estimates only the product $\psi\kappa$, so a click rate is silent about who is targeted in the field and about how much harm an action would cause. Exposure also varies with role: an accounts payable clerk meets more payment lures than an engineer with identical susceptibility.

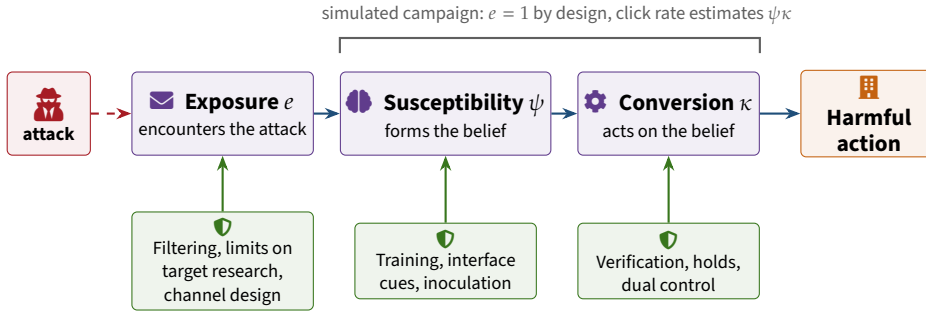


Figure 3.4. Exposure, susceptibility, and conversion as a chain of nested events, from Equation (3.1), with the control family that acts on each factor (green). A simulated campaign fixes exposure and measures only the product of the other two factors.

Example 3.1 (Susceptibility and exposure in MERIDIAN email). MERIDIAN’s gateway passes about 600 phishing messages per month to inboxes. Before training, 8% of delivered phishing messages draw a click or credential submission and 20% are reported; after annual training with quarterly simulations the rates are 4% and 45%. Treating delivery as exposure ($e = 1$ for recipients of delivered messages), the problem is to compare expected clicks and reports per month.

Expected clicks per month are $600 \times 0.08 = 48$ before training and $600 \times 0.04 = 24$ after, and expected reports are $600 \times 0.20 = 120$ and $600 \times 0.45 = 270$. Training halves the clicks, but the larger change is the more than twofold rise in reports, which act as a detection control that lets the security operations center remove a campaign from other inboxes; the race between the first report and the first click is analyzed in Chapter 8.

The factorization in Equation (3.1) will reappear in Section 3.6, where exposure, susceptibility, and conversion become transitions between stages of the attack chain.

3.2 Levers of Influence

A vulnerability is exercised through features of a message or situation that the adversary controls, such as a claim of authority that recruits deference or a deadline that narrows attention. The same features appear throughout legitimate communication; what changes in an attack is that they are attached to a false source, a concealed intent, or a request that bypasses verification.

Definition 3.3 (Lever). A *lever* is a feature of a message, channel, or situation that an actor can set and that increases the probability that a target's cognitive regularity produces a particular belief or action. A lever is *adversarial* when it is used together with deception about source or intent, coercion, or circumvention of a verification step the target would otherwise apply.

Studies of fraud and social engineering converge on a small set of recurring levers. Stajano and Wilson derived seven principles from street and online scams, including social compliance, herd behavior, and time pressure [85], and Ferreira, Coventry, and Lenzini related such principles to the persuasion literature and to phishing [86]. We work with six levers that cover most documented cases and that map onto distinct regularities: authority, familiarity, repetition, urgency, reciprocity, and identity. [Figure 3.5](#) places each lever on the stage of the cognitive loop it chiefly targets and pairs it with the defensive counter that removes its force.

3.2.1 Authority, Familiarity, and Repetition

Authority exploits deference to perceived legitimacy. Milgram's obedience studies, in which many participants continued to follow an experimenter's instructions to administer what they believed were painful shocks, remain the classic demonstration that institutional role can override private judgment [87]. Those studies have been debated on ethical and methodological grounds, but the narrower claim relevant here, that apparent authority raises compliance with requests, is supported by a broad compliance literature [80]. In organizations authority is carried by titles, signatures, reporting lines, and the conventions of internal service desks. Executive impersonation in payment fraud and help-desk impersonation in credential theft both rely on it. The lever acts on the Model stage, where the target infers who is asking, and on the Decide stage, where the inferred authority substitutes for an independent assessment of the request.

Familiarity exploits recognition-based trust. A known brand, a colleague's name, a vendor's letterhead, or the visual layout of a routine message is processed fluently, and fluent processing is read as a sign of safety. Lookalike domains, copied signature blocks, and messages sent from a compromised account of a real counterparty all borrow familiarity. The lever acts early, at the Sense stage, because it determines whether the message is scrutinized at all.

Repetition exploits the illusory truth effect: statements seen before are rated as more likely true than new statements. The effect was first reported by Hasher, Goldstein, and Toppino [88] and has been reproduced many times. Repetition increases perceived truth even for statements that contradict participants' prior

knowledge [89], and processing fluency is the leading explanation for why it works [90]. In an organizational attack, repetition appears as a series of low-stakes contacts that make a later request feel expected; in an influence campaign it appears as the same claim recycled across accounts and paraphrases. Repetition acts on the Model stage and, through memory, on Learn.

3.2.2 Urgency, Reciprocity, and Identity

Urgency compresses the time available for deliberation. Deadlines, threatened account suspensions, and “before the close of business” framings shift processing toward cues that can be checked quickly and away from verification. When the urgency is framed as avoiding a loss, prospect theory predicts that the loss weighs more heavily than an equivalent gain [75]. Urgency is often combined with authority, because a senior requester who is also in a hurry makes a delay feel costly in two ways at once. The lever acts on Decide and Act, and it is the most direct target for procedural friction.

Reciprocity exploits the norm of returning a favor. In an early experiment, participants who had received a small unsolicited favor from a confederate bought more raffle tickets from that confederate afterward, whether or not they liked the person [91]. Pretexting that begins with help, such as a caller who resolves a fabricated technical problem before asking for a code, uses this lever. It acts on Decide, where the felt obligation enters the choice, and on Act.

Identity exploits motivated reasoning: evidence is processed in a way that protects membership in a valued group. Kahan found that people with higher scores on a cognitive reflection test showed more, not less, ideologically motivated evaluation of evidence in his experiment [92]. Appeals to team loyalty (“we need to keep this vendor on side”), professional pride, or political and cultural identity use this lever. It acts on Model and on Learn, because identity-protective updating makes later correction harder. Identity is also the lever where vulnerability analysis most easily overreaches, a point taken up in [Section 3.7](#).

The map in [Figure 3.5](#) makes two patterns visible. Levers that act on Sense and Model, such as familiarity and repetition, decide whether a message is scrutinized and what it is believed to be; their counters concern provenance. Levers that act on Decide and Act, such as urgency and reciprocity, decide what is done with the belief; their counters concern procedure. A well-constructed pretext combines levers from both groups. If lever effects add on the log-odds scale, as in an illustrative logistic choice model, two levers that each raise compliance from 5% to 10% together raise it to about 19%, not 15%. Removing even one lever therefore pays: a standing 24-hour hold on first payments to changed bank details weakens every pretext that relies on urgency, whatever other levers it uses.

Levers also indicate where not to intervene. Authority, familiarity, and reciprocity are the ordinary material of cooperation in an organization. A defense that teaches staff to distrust colleagues or to refuse help imposes costs on legitimate work and tends to be bypassed. The counters in [Figure 3.5](#) avoid this by relocating trust from the cue to a channel: staff may continue to defer to the finance director, provided the instruction arrives through a channel whose authenticity is established independently of the message.

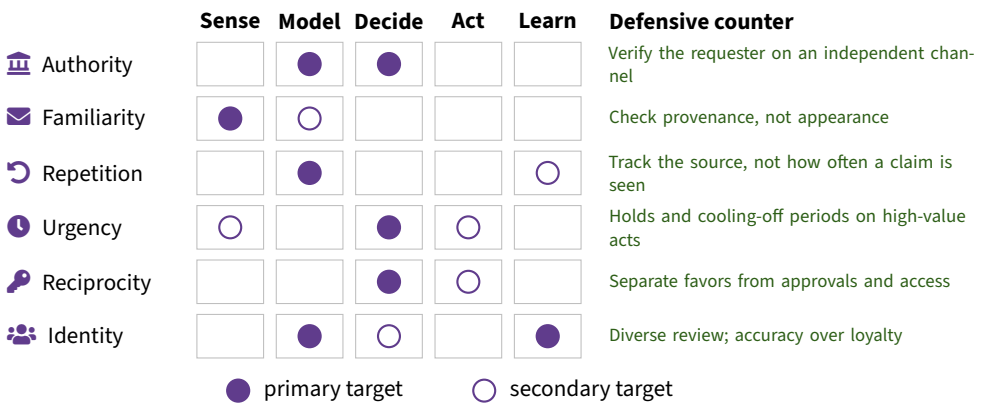


Figure 3.5. Lever map. Each lever is placed on the stage of the cognitive loop it chiefly targets (filled) and the stages it also affects (open), with the defensive counter that removes its force. Counters act on the channel, the procedure, or the source rather than on the person’s regularity.

3.3 Systemic Vulnerabilities

The vulnerabilities of [Section 3.1](#) belong to individual cognitive systems. Many consequential attacks succeed for reasons that no individual analysis would reveal: an approval rule that can be satisfied by splitting a payment, a trusted vendor whose mailbox has been taken over, a ranking algorithm that rewards content engineered for engagement, or an interface that trains users to dismiss warnings. These are properties of the structure that connects people, machines, and procedures. We call them systemic vulnerabilities.

Definition 3.4 (Systemic vulnerability). A *systemic vulnerability* is a property of the structure connecting cognitive systems (roles, procedures, communication networks, algorithms, or interfaces) under which decision errors become more likely, more consequential, or more strongly correlated than the susceptibility of the individual members would imply.

The third clause, correlation, matters because redundancy is the usual answer to individual error: two approvers who each miss with probability m both miss with probability $m^2 + \rho_c m(1 - m)$ when their misses have correlation ρ_c , so reviewers who rely on the same forged document turn redundancy into a single point of failure.

3.3.1 Organizational Structure

Organizations encode cognition in roles and procedures. That encoding creates vulnerabilities of four recurring kinds. *Authority gradients* make it costly for a junior person to challenge a senior request, so an adversary who can impersonate seniority inherits the gradient. *Thresholds* create discontinuities that can be gamed: MERIDIAN requires a second approver for payments of \$50,000 or more, which invites an adversary to request several payments just below the threshold. *Handoffs*

between units split responsibility, so that procurement assumes finance verified a bank change while finance assumes procurement did. *Normalization of deviance* erodes controls over time: in her study of the Challenger launch decision, Vaughan described how repeated acceptance of anomalies made them part of the expected operating envelope [93]. A callback step that is skipped for trusted vendors during every quarter close becomes, after a year, a callback step that exists only on paper.

Reason’s account of organizational accidents offers a compact picture of these conditions. Defenses are layered, each layer has holes created by active failures and latent conditions, and harm occurs when the holes align [20]. A systemic vulnerability is a latent condition that an adversary can align deliberately, and Figure 3.6 marks such conditions in MERIDIAN’s payment workflow.

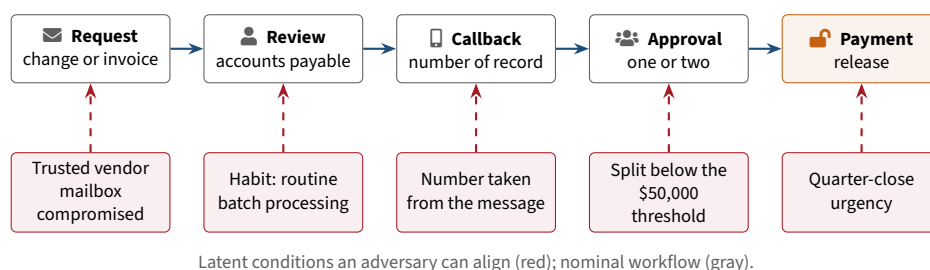


Figure 3.6. Systemic vulnerabilities in MERIDIAN’s vendor payment workflow. Each control in the nominal workflow has a latent condition beneath it that an adversary can exploit; harm requires these conditions to align, which is why an attack chain is organized to create them in sequence.

3.3.2 Networks and Recommender Systems

Communication networks determine who can reach whom and whose word is trusted. They create systemic vulnerability through *trust transfer*: a message from a counterparty inherits the trust the relationship has earned. Compromising one vendor’s mailbox therefore reaches every customer that trusts the vendor, and the recipient’s susceptibility is higher than for a message from a stranger because the familiarity lever comes for free. Networks also shape how beliefs and behaviors spread. In an online experiment, a health behavior spread farther through clustered networks, in which people received reinforcing signals from several contacts, than through random networks with shorter paths [94]. Beliefs that require social reinforcement are therefore sensitive to the local structure of trust, which coordinated inauthentic accounts attempt to simulate. On Twitter, false news spread farther and faster than true news, mainly through human sharing [19].

Recommender systems add a feedback loop. A ranking model selects what each user sees, the user’s attention and engagement become training signals, and the updated model shapes the next round of exposure. Figure 3.7 draws the loop and the points at which an adversary can enter it. The systemic vulnerability is that the algorithm optimizes an observable proxy, engagement, that an adversary can manufacture with coordinated accounts and emotionally charged content.

Evidence on the downstream effect is mixed: a YouTube audit found commenters migrating from milder to more extreme communities [95], while a Facebook field experiment during the 2020 United States election found that cutting exposure to like-minded sources by about one third did not measurably change polarization [96]. The defensible claim is that recommender loops shape exposure e and repetition, which adversaries exploit, while effects on belief depend on the population and period.

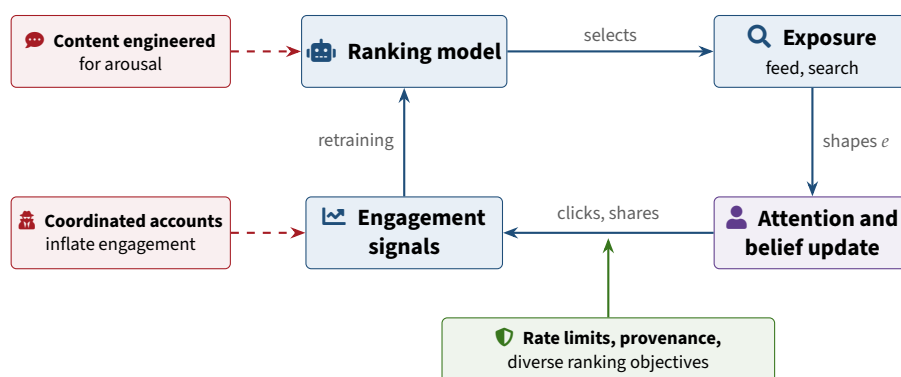


Figure 3.7. The recommender feedback loop as a systemic vulnerability. The loop optimizes an observable proxy, engagement, that adversaries can manufacture from outside; defenses act on the signals entering the loop rather than on the users inside it.

3.3.3 Interfaces and Artificial Agents

Interfaces decide which cues reach attention and how costly a careful action is. They create systemic vulnerabilities in three ways. First, warnings that fire often and are usually false teach users to dismiss them; a large field study of browser security warnings found that users clicked through some warning types far more often than others, and that design choices influenced adherence [97]. Second, *dark patterns*, interface designs that steer users toward choices they would not otherwise make, are common in commercial settings; an automated crawl of about 11,000 shopping websites identified many instances, including false urgency and scarcity messages [98]. An organization that tolerates such patterns in its own customer communications trains its users to accept urgency cues from its brand. Third, interfaces conceal provenance: a display name shown without the underlying address, a shortened link, or a forwarded message that drops its headers removes the cues that verification needs.

Artificial agents are becoming interfaces in their own right. MERIDIAN Assist, the utility’s AI assistant, reads and drafts email, retrieves from a store of 400,000 documents, and reads vendor portals for 1,200 staff. When such an assistant summarizes a message, the summary becomes the cue a person acts on. Instructions embedded in retrieved content can steer the output of language-model applications, an attack class known as indirect prompt injection [9]. An adversary who places text in a vendor document can thereby influence what the assistant tells the clerk, which is a systemic vulnerability at level L2 that produces

its effect at L1 and L4. MERIDIAN's guardrail that actions touching payment records need human confirmation places the decision back with a person, but it does not protect that person from a manipulated summary.

3.4 Threat Actors

Vulnerabilities, levers, and systemic weaknesses describe what can be exploited. Threat actors determine what is exploited, against whom, and when. Threat assessment in security practice characterizes a threat source by its capability, its intent, and its targeting [99]. For cognitive attacks it is useful to separate targeting into two attributes, access and opportunity, because they act on different factors of the exposure decomposition of Equation (3.1).

Definition 3.5 (Threat actor profile). The *profile* of a threat actor is the tuple of four attributes. *Capability* is the set of resources, skills, and tools the actor can bring to bear, including research, content production, and automation. *Intent* is the actor's objective together with its degree of target specificity. *Access* is the actor's position relative to the channels, information, and authority of the target, ranging from an outsider through a partner to an insider. *Opportunity* is the set of times and conditions under which the target's vulnerabilities are exposed, such as deadlines, outages, reorganizations, and changes of procedure.

The attributes connect to measurable quantities. Intent sets which targets are attempted and how often; if attempts against a population arrive as a Poisson process with rate λ per month and each attempt independently results in a harmful action with probability $e\psi\kappa$, then harmful actions form a Poisson process with rate $\lambda e\psi\kappa$, by the thinning property of the Poisson process. Access raises exposure e , because an actor who can send from a real vendor account or who knows the payment calendar reaches the right person at the right time. Capability raises susceptibility ψ , because better research and better content yield more plausible pretexts. Opportunity raises conversion κ by attaching the request to a moment when verification is weakest, and it also raises exposure. Figure 3.8 records this mapping. It explains why a defender who cannot reduce capability or intent can still reduce harm: access and opportunity are shaped by the defender's own architecture, through what is published, who holds authority, and which procedures relax under pressure.

3.4.1 Classes of Actors

Organized criminal groups pursue financial gain and choose targets by expected return. Business email compromise, in which the adversary impersonates an executive, a vendor, or another trusted party to redirect a payment, is the most costly cognitive attack class reported by businesses to United States law enforcement, as the practice box below documents. Criminal groups invest in capability where it pays: reconnaissance on vendor relationships, lookalike domain registration, and access to compromised mailboxes bought from others. Their intent is specific to a transaction rather than to an organization, so they

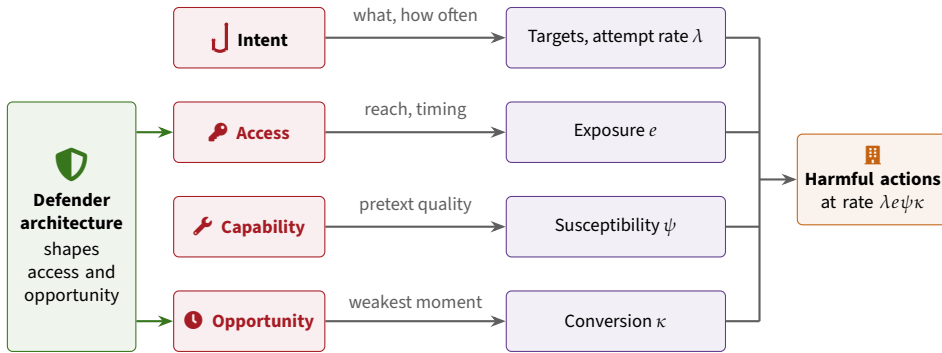


Figure 3.8. How the four attributes of a threat actor act on the factors of harm. Intent and capability belong to the actor; access and opportunity depend strongly on the target’s own architecture, which is why they are the attributes a defender can most directly reduce.

abandon hard targets quickly, which gives early controls that raise the cost of research and pretext development a deterrent value beyond detection.

State and state-affiliated actors pursue intelligence, influence, and disruption. They combine high capability with patience and accept long dwell times, and their cognitive operations range from spear-phishing of officials to influence campaigns aimed at public audiences. Attribution of specific campaigns to states is often contested and should be stated with the evidence and the degree of confidence of the attributing party. For vulnerability analysis, the relevant feature of this class is that intent can be strategic rather than transactional, so the effect sought may be a durable belief or a loss of trust rather than a single action.

Insiders are defined by access. The CERT insider threat program distinguishes malicious insiders who misuse authorized access from those whose actions are unintentional, and it documents cases of theft, sabotage, and fraud in which access rather than technical skill was decisive [100]. A cognitive attack chain can also create an insider without the person’s knowledge: an employee whose credentials are phished, or who is persuaded that a fraudulent request is legitimate, acts with insider access on the adversary’s behalf. The manipulated insider is the most common way outsiders obtain insider access.

Opportunistic individuals and small groups have limited resources but can achieve disproportionate effects when a systemic vulnerability offers leverage. The 2020 compromise of Twitter, analyzed in Section 3.5, was carried out according to the New York regulator by a 17-year-old and accomplices using telephone calls rather than malware [101].

Automated actors extend each of the other classes. Social bots, accounts controlled partly or wholly by software, can simulate consensus and amplify content at a scale no human operator can match [102]. Generative models lower the cost of producing plausible, personalized pretexts, which raises the capability available to low-resource actors. On the target side, a steered assistant gives the adversary a form of insider access through an automated intermediary. We describe such systems functionally; the intent belongs to the actor who deploys or manipulates

them.

Cognitive Security in Practice: Business Email Compromise in FBI IC3 Reporting

The Internet Crime Complaint Center (IC3) of the Federal Bureau of Investigation collects complaints of internet-enabled crime from victims in the United States and abroad. Its 2024 annual report records 859,532 complaints with reported losses of \$16.6 billion. Business email compromise, which IC3 defines as a scam targeting businesses or individuals who regularly perform wire transfers, carried out by compromising email and other communication accounts through social engineering or intrusion, accounted for 21,442 complaints and \$2,770,151,146 in reported losses [103].

The comparison with other categories shows why frequency and consequence must be kept apart (Figure 3.9). Phishing and spoofing produced 193,407 complaints in 2024 but \$70,013,036 in reported losses, while investment fraud produced 47,919 complaints and \$6,570,639,864 in losses [103]. Business email compromise sits between them: comparatively few complaints, each carrying a large average loss of roughly \$129,000. A public service announcement in September 2024 reported a cumulative exposed dollar loss of \$55,499,915,582 across 305,033 domestic and international incidents reported between October 2013 and December 2023 [104].

Reporting also documents a late-stage control. The IC3 Recovery Asset Team initiates a Financial Fraud Kill Chain process with financial institutions to freeze fraudulent transfers, and most incidents it handles are business email compromise. In 2024 it acted on 3,020 complaints involving \$848.4 million in attempted theft, with \$469.1 million frozen domestically and \$92.5 million internationally, and reported a success rate of 66% [103]. These are complaint-based figures: they undercount unreported incidents and do not measure attempts that were stopped earlier in the chain.

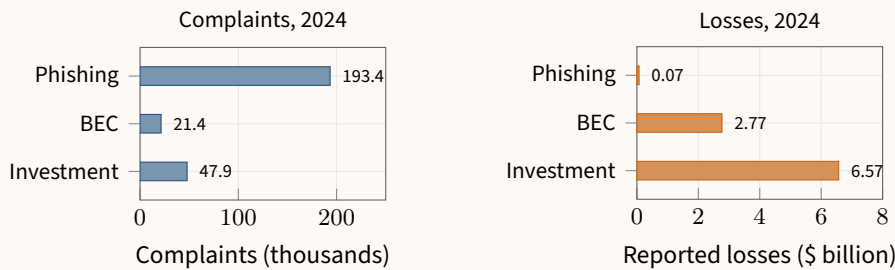


Figure 3.9. Complaints and reported losses in three IC3 categories for 2024 [103]. Phishing is the most frequent category but among the least costly per complaint; business email compromise is infrequent but costly. BEC denotes business email compromise.

3.5 The Cognitive Attack Chain

The preceding sections say what is exploitable and who exploits it, but not in what order. Arranging the activity of a cognitive attack as an ordered sequence yields the cognitive attack chain, following the intrusion kill chain of Hutchins, Cloppert, and Amin, which decomposes a network intrusion into ordered, observable, interruptible phases [31], and the social-engineering kill chain of Montañez Rodriguez and Xu, which places human belief and compliance at the center [105]. Unlike a network intrusion, a cognitive chain can change the level of the Cognitive Security Stack from one stage to the next, and its stages are separated by dwell times during which the adversary waits.

Definition 3.6 (Cognitive attack chain). The *cognitive attack chain* is the ordered sequence of seven stages an adversary passes through to produce and sustain a cognitive effect: (1) reconnaissance and profiling, (2) target and channel selection, (3) pretext and content development, (4) delivery and exposure, (5) cognitive exploitation, (6) action and effect, and (7) reinforcement and persistence. At each stage the diagnostic question is which cognitive conditions the adversary is trying to create, exploit, or preserve.

The seven-stage model is an analytic device to be tested against incidents, not standardized doctrine. Figure 3.10 shows the stages with the level at which each typically operates, the vulnerabilities and levers it engages, and an observable indicator.

3.5.1 The Seven Stages

Reconnaissance and profiling gathers the material of a later pretext: roles, reporting lines, vendor relationships, internal vocabulary, shift patterns, and the payment calendar. The adversary is not yet acting on cognition but is locating where cognition is soft and where trust is placed. The activity is mostly at the organizational and societal levels, and its indicators are external: scraping, unusual profile views, and registration of lookalike domains.

Target and channel selection converts the profile into a choice of whom to approach and through which medium. The lever of familiarity is set here, because the channel determines whether the message will be processed fluently: a request that arrives through the vendor's genuine email thread carries trust that the same request over an unknown number would not. Selection also fixes exposure e by choosing a recipient whose role gives the request a plausible reason to exist.

Pretext and content development builds the message. Here the adversary attaches levers to the chosen vulnerabilities: an authority claim, a familiar signature block, an urgency frame tied to the quarter close. Capability shows itself at this stage, and generative tools reduce its cost. The visible traces are properties of the artifact: a reply-to domain that differs by a character, a signature copied imperfectly, a tone that is close but not exact.

Delivery and exposure presents the content through the chosen channel at a chosen time. This is the first stage at which the target is involved, and it sets exposure in fact rather than in plan. Delivery is timed to the weakest moment,

near a deadline or during an outage, so that attention is narrow and verification feels costly. Indicators cluster here because the artifact meets the target’s systems: spoofed numbers, anomalous send patterns, and reports from recipients who found the message suspicious.

Cognitive exploitation is the decisive stage, where the target forms the intended belief or performs the intended act: the approval, the click, the accepted false claim. It is the point at which susceptibility ψ and conversion κ are realized. The vulnerabilities engaged are those of attention and judgment under load, and the signature of a successful exploitation is often visible after the fact, for instance an approval that follows a run of denials in a prompt-bombing attack.

Action and effect realizes the adversary’s objective once the cognitive state is in place: the funds move, the credential is used, the narrative is amplified. This stage frequently switches level, from an individual’s decision (L1) to an organizational consequence (L4) or a societal one (L5). Its indicators are transactional: a wire to a new account, a login from an unusual location, a surge of coordinated posts.

Reinforcement and persistence works to keep the effect in place: reusing established trust for follow-on requests, suppressing or getting ahead of correction, and moving to channels where scrutiny is lower. In fraud it appears as a second request that leans on the first; in an influence operation it appears as a claim recycled after a public correction. Persistence is what distinguishes a durable effect from a transient one, and it is the stage that determines whether recovery is possible.

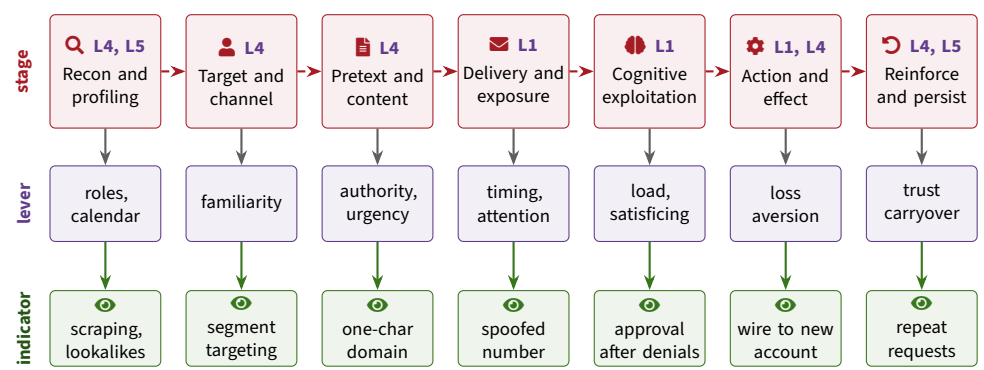


Figure 3.10. The seven-stage cognitive attack chain. Each stage (top) operates at a level of the Cognitive Security Stack, engages a lever (middle), and leaves an observable indicator (bottom). Level switching between delivery and exploitation (to L1) and between exploitation and action (back to L4) is the reason single-level defenses miss such campaigns.

3.5.2 Level Switching and Dwell Time

Two features of the chain matter for defense. The first is level switching: a business email compromise begins at the organizational level, moves to the individual level when a clerk believes a message, and returns to the organizational level when a payment is released, so a defender who watches one level sees a fragment.

The second feature is dwell time. The adversary waits between stages, for operational reasons (research takes days) or tactically (delivery is held until a deadline). Time spent at a stage is time during which an indicator can be noticed and a control can act, and the Markov model of [Section 3.6](#) makes it measurable. Automation that shortens dwell time is therefore a genuine change in the threat even when the stages are unchanged.

Cognitive Security in Practice: The 2020 Twitter Phone Spear-Phishing Compromise

On 14 and 15 July 2020, attackers compromised Twitter's internal systems and took over 130 high-profile accounts, tweeting a cryptocurrency scam from 45 of them. The analysis below follows the investigation report of the New York State Department of Financial Services [101]; the criminal charges are documented separately [106]. The incident is instructive because, in the report's words, it used no malware, exploits, or backdoors: the entry was a telephone call.

Read across the chain, the stages are legible. In *reconnaissance and profiling*, the attackers researched employee roles and functions so they could impersonate Twitter's help desk. In *target and channel selection*, they chose the telephone and staff who were plausibly experiencing the problem they would cite. The *pretext* exploited a real condition: the pandemic shift to remote work had made virtual private network (VPN) problems common, so a call about a VPN issue was expected rather than surprising. In *delivery and exposure*, the callers claimed to be from the IT department and directed employees to a phishing site whose domain resembled the real VPN login. The *cognitive exploitation* used authority (the IT help desk), familiarity (a routine VPN problem), and personal details that made the callers credible; as employees entered credentials into the fake site, the attackers entered them into the real one and captured the multifactor response. The report found no evidence that employees knowingly aided the attackers, and noted that some reported the calls to Twitter's fraud team. In *action and effect*, the attackers used internal tools to seize accounts, and in *reinforcement* they escalated from selling short usernames to hijacking verified accounts whose reach made the scam appear legitimate, stealing about \$118,000 in bitcoin.

The controls that would break the chain are procedural and architectural rather than a matter of spotting the lie: the report stated that phishing-resistant hardware authentication keys would have stopped the attack because they bind the login to the legitimate site. The case shows a low-capability actor achieving a large effect through a systemic vulnerability, authentication that a person could complete on the attacker's behalf.

3.6 The Attack Chain as an Absorbing Markov Chain

The seven-stage chain describes a sequence, and the dwell times and interruption opportunities of Section 3.5 call for a stochastic model. We model the chain as an absorbing Markov chain in discrete time, which lets us compute the probability that an attack succeeds, the expected time to effect, and the value of interdicting each stage, and lets us prove how these quantities respond to a defender's controls. The treatment is self-contained; the standard results on absorbing chains are those of Kemeny and Snell [107].

3.6.1 Model

Time advances in steps of a fixed length; we use one day, matching the dwell times of a business email compromise. Let the seven stages of Definition 3.6 be the transient states $\{1, \dots, K\}$ with $K = 7$. There are three absorbing states: S (the attack succeeds and the effect is achieved), D (the defender detects and interdicts the chain), and A (the adversary abandons the attempt). The process starts in state 1.

At each step, if the chain is at transient stage k , one of four things happens. With probability δ_k the defender detects and interdicts, sending the chain to D . Otherwise, with the complementary probability $1 - \delta_k$, the adversary's nominal dynamics apply: the chain advances to stage $k + 1$ with probability p_k (or, from stage K , to S), abandons to A with probability q_k , or remains at stage k with probability $w_k = 1 - p_k - q_k$. The parameters satisfy $p_k, q_k, w_k \geq 0$, $p_k + q_k \leq 1$, and $\delta_k \in [0, 1)$.

Assumption 3.1 (Regularity of the chain). For each transient stage k , either $\delta_k > 0$ or $p_k + q_k > 0$; that is, at every stage the chain leaves with positive probability at each step (through detection, advance, or abandonment).

Ordering the states as the K transient stages followed by S, D, A , the one-step transition matrix has the canonical block form

$$P = \begin{pmatrix} M & G \\ \mathbf{0} & I_3 \end{pmatrix}, \quad (3.2)$$

where $M \in \mathbb{R}^{K \times K}$ collects the transient-to-transient probabilities and $G \in \mathbb{R}^{K \times 3}$ the transient-to-absorbing probabilities, whose columns we index by S, D, A . Explicitly, for $1 \leq k \leq K$,

$$M_{k,k} = (1 - \delta_k)w_k, \quad M_{k,k+1} = (1 - \delta_k)p_k \ (k < K), \quad G_{k,D} = \delta_k, \quad G_{k,A} = (1 - \delta_k)q_k, \quad (3.3)$$

with $G_{K,S} = (1 - \delta_K)p_K$ and all other entries zero. Each transient row of P sums to one: $(1 - \delta_k)(w_k + p_k + q_k) + \delta_k = 1$.

Figure 3.11 draws the chain.

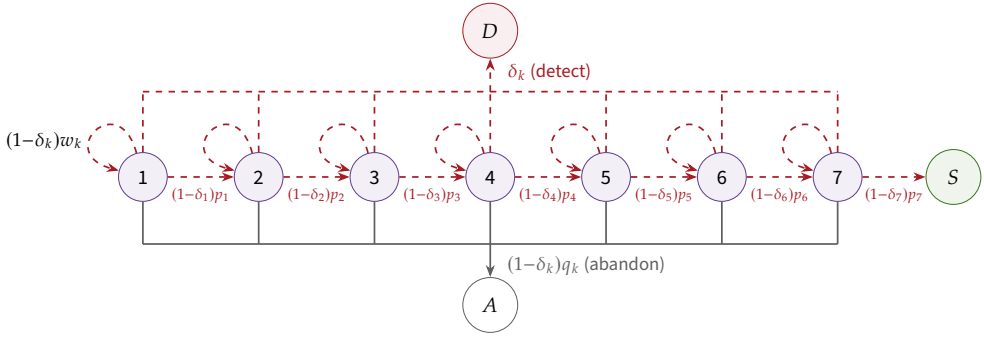


Figure 3.11. The cognitive attack chain as an absorbing Markov chain. The seven transient stages (purple) advance to the right; every stage can be interdicted to D (detection) or lost to A (abandonment), and a self-loop represents waiting. Completing stage 7 reaches S (success). The detection and abandonment transitions of all stages are drawn as shared lines.

3.6.2 Absorption Probabilities and Expected Times

Proposition 3.1 (Fundamental matrix and absorption). *Under Assumption 3.1, the matrix $I_K - M$ is invertible and the fundamental matrix*

$$N = (I_K - M)^{-1} = \sum_{n=0}^{\infty} M^n \quad (3.4)$$

has nonnegative entries, with N_{ij} equal to the expected number of visits to stage j before absorption, starting from stage i . The matrix of absorption probabilities is $B = NG$, where $B_{i,c}$ is the probability of absorption in state $c \in \{S, D, A\}$ starting from stage i ; each row of B sums to one. The vector of expected times to absorption is $\mathbf{t} = N\mathbf{1}$, where $\mathbf{1}$ is the all-ones vector.

Proof. The chain is upper bidiagonal: from Equation (3.3), M has nonzero entries only on its diagonal and first superdiagonal, so M is upper triangular with diagonal entries $M_{k,k} = (1 - \delta_k)w_k$. Under Assumption 3.1, if $\delta_k > 0$ then $M_{k,k} = (1 - \delta_k)w_k \leq 1 - \delta_k < 1$; if $\delta_k = 0$ then $p_k + q_k > 0$, so $w_k = 1 - p_k - q_k < 1$ and $M_{k,k} = w_k < 1$. Hence every diagonal entry satisfies $M_{k,k} < 1$, so every eigenvalue of the triangular matrix M lies strictly inside the unit disk and its spectral radius is below one. Therefore $I_K - M$ is invertible and the Neumann series $\sum_{n=0}^{\infty} M^n$ converges to $(I_K - M)^{-1}$, which establishes Equation (3.4). Each term M^n is entrywise nonnegative because $M \geq 0$, so $N \geq 0$.

The entry $(M^n)_{ij}$ is the probability of being at stage j after n steps having remained transient throughout, starting from i . Writing X_m for the state at step m and τ for the absorption time, the expected number of visits to j is

$$\mathbb{E}_i \left[\sum_{m=0}^{\tau-1} \mathbf{1}\{X_m = j\} \right] = \sum_{n=0}^{\infty} \mathbb{P}_i(X_n = j, n < \tau) = \sum_{n=0}^{\infty} (M^n)_{ij} = N_{ij},$$

which gives the visit interpretation. Summing over j gives $\mathbb{E}_i[\tau] = \sum_j N_{ij} = (N\mathbf{1})_i = t_i$.

For absorption, condition on the first step from a transient state. Let $b_{i,c} = \mathbb{P}_i(\text{absorbed in } c)$. A single step either moves to another transient state j (probability M_{ij}) or is absorbed directly in c (probability $G_{i,c}$), so $b_{i,c} = G_{i,c} + \sum_j M_{ij}b_{j,c}$, that is, $\mathbf{B} = \mathbf{G} + \mathbf{M}\mathbf{B}$ in matrix form. Rearranging, $(\mathbf{I}_K - \mathbf{M})\mathbf{B} = \mathbf{G}$, and since $\mathbf{I}_K - \mathbf{M}$ is invertible, $\mathbf{B} = \mathbf{N}\mathbf{G}$. Finally $\mathbf{B}\mathbf{1} = \mathbf{N}\mathbf{G}\mathbf{1} = \mathbf{N}(\mathbf{I}_K - \mathbf{M})\mathbf{1}$ because each transient row of $(\mathbf{M} \mid \mathbf{G})$ sums to one implies $\mathbf{G}\mathbf{1} = (\mathbf{I}_K - \mathbf{M})\mathbf{1}$; hence $\mathbf{B}\mathbf{1} = \mathbf{1}$ and every starting stage is absorbed with probability one. $\square$

Write $\mathbf{h} = \mathbf{B}_{\cdot,S}$ for the vector of *success probabilities*, so $h_i = \mathbb{P}_i(\text{absorbed in } S)$; the attack's success probability is h_1 . Because $\mathbf{M}$ is upper bidiagonal, the model has closed forms that make the results concrete. Define the per-stage *advance probability* and *conditional dwell*

$$\alpha_k = \frac{(1 - \delta_k)p_k}{1 - (1 - \delta_k)w_k}, \quad d_k = \frac{1}{1 - (1 - \delta_k)w_k}, \quad (3.5)$$

where α_k is the probability that the chain, once at stage k , advances to stage $k + 1$ rather than being absorbed in D or A , and $d_k = N_{kk}$ is the expected number of steps spent at stage k per visit.

Corollary 3.2 (Serial-chain formulas). *For the upper-bidiagonal chain,*

$$h_1 = \prod_{k=1}^K \alpha_k, \quad t_1 = \sum_{j=1}^K \left(\prod_{k=1}^{j-1} \alpha_k \right) d_j, \quad (3.6)$$

and, given that the attack succeeds, the expected time to effect is $\mathbb{E}_1[\tau \mid S] = (\mathbf{N}\mathbf{h})_1/h_1 = \sum_{j=1}^K d_j$.

Proof. Reaching S requires advancing through every stage in turn, and from stage k the chain advances with probability α_k independently of the past by the Markov property (each visit to k ends in advance, abandonment, or detection, and only advance continues the chain). Hence $h_1 = \prod_k \alpha_k$. For the expected time, the reach probability of stage j is $R_j = \prod_{k < j} \alpha_k$, and each visit contributes expected dwell d_j ; because the chain is bidiagonal it visits stages in increasing order, so $t_1 = \sum_j R_j d_j$, which is Equation (3.6). Given success, every stage is reached. During a visit to stage j , each step either waits, with probability $M_{j,j}$, or leaves, and the route of departure is chosen on the leaving step with probabilities proportional to $M_{j,j+1}$ (or $G_{j,S}$, $G_{j,D}$, and $G_{j,A}$ whatever the number of earlier waiting steps; the number of steps in the visit is therefore independent of the route, and its mean given departure by advance is still d_j . Hence the conditional expected time is $\sum_j d_j$. The same value follows from the matrix expression, because $N_{1j} = R_j d_j$ for the bidiagonal chain and $h_j = \prod_{k \geq j} \alpha_k$, so $(\mathbf{N}\mathbf{h})_1 = \sum_j R_j d_j h_j = h_1 \sum_j d_j$. $\square$

3.6.3 Monotonicity and the Value of Interdiction

Theorem 3.3 (Monotonicity and marginal value of interdiction). *Under Assumption 3.1, the success probability h_1 is nonincreasing in each stage-wise detection probability*

$\delta_j \in [0, 1)$, with all other parameters held fixed, and

$$-\frac{\partial h_1}{\partial \delta_j} = \frac{N_{1j} h_j}{1 - \delta_j} \geq 0, \quad (3.7)$$

where N_{1j} is the expected number of visits to stage j and h_j is the success probability from stage j . If, in addition, every advance probability is positive ($p_k > 0$ for $k = 1, \dots, K$), which is equivalent to $h_1 > 0$, then h_1 is strictly decreasing in each δ_j and the inequality in Equation (3.7) is strict; in the serial form, $h_1 = \prod_k \alpha_k$ with each α_k positive and strictly decreasing in δ_k . If some $p_k = 0$, then $h_1 = 0$ for all values of the detection probabilities.

Proof. We first treat the serial form, then prove Equation (3.7). From Equation (3.5),

$$\alpha_k = \frac{(1 - \delta_k)p_k}{1 - (1 - \delta_k)w_k}.$$

The denominator is $1 - M_{k,k}$, which is positive under Assumption 3.1 by the proof of Theorem 3.1. Moreover $\alpha_k \leq 1$, because $(1 - \delta_k)(p_k + w_k) \leq 1$ is equivalent to $(1 - \delta_k)p_k \leq 1 - (1 - \delta_k)w_k$. Since $\delta_k < 1$, $\alpha_k > 0$ if and only if $p_k > 0$, so by Theorem 3.2 $h_1 = \prod_k \alpha_k > 0$ if and only if $p_k > 0$ for every k , and $h_1 = 0$ for all detection probabilities when some $p_k = 0$. This proves the equivalence and the degenerate case in the statement.

Now suppose $p_k > 0$ for every k . Then $w_k \leq 1 - p_k < 1$. Write $x = 1 - \delta_k \in (0, 1]$, so $\alpha_k(x) = xp_k/(1 - xw_k)$ with $1 - xw_k \geq 1 - w_k > 0$ on this interval. Then

$$\frac{d\alpha_k}{dx} = \frac{p_k(1 - xw_k) - xp_k(-w_k)}{(1 - xw_k)^2} = \frac{p_k}{(1 - xw_k)^2} > 0,$$

since the numerator reduces to p_k . Because $x = 1 - \delta_k$ decreases in δ_k , α_k is strictly decreasing in δ_k . Only the factor α_j of $h_1 = \prod_k \alpha_k$ depends on δ_j , and the product of the other factors is positive, so h_1 is strictly decreasing in δ_j . When some $p_k = 0$, h_1 is identically zero and hence nonincreasing, so h_1 is nonincreasing in δ_j in every case covered by Assumption 3.1.

For the marginal value, use the general identity for absorbing chains. Differentiating $\mathbf{B} = \mathbf{G} + \mathbf{M}\mathbf{B}$ (from the proof of Theorem 3.1) with respect to a parameter and solving gives, for the S column,

$$\frac{\partial \mathbf{h}}{\partial \delta_j} = \mathbf{N} \left(\frac{\partial \mathbf{G}_{\cdot, S}}{\partial \delta_j} + \frac{\partial \mathbf{M}}{\partial \delta_j} \mathbf{h} \right).$$

Only row j of $\mathbf{M}$ and $\mathbf{G}$ depends on δ_j . From Equation (3.3), $\partial \mathbf{G}_{j, S} / \partial \delta_j = -p_j \mathbf{1}\{j = K\}$, $\partial \mathbf{M}_{j, j} / \partial \delta_j = -w_j$, and $\partial \mathbf{M}_{j, j+1} / \partial \delta_j = -p_j$ for $j < K$. Hence the bracket is a vector supported on row j with value $-w_j h_j - p_j h_{j+1}$ for $j < K$ (and $-p_K - w_K h_K$ for $j = K$, with $h_{K+1} := 1$ identified with S). Using the one-step relation $h_j = (1 - \delta_j)(w_j h_j + p_j h_{j+1})$, valid for $j < K$, we have $w_j h_j + p_j h_{j+1} = h_j / (1 - \delta_j)$, so the row- j entry equals $-h_j / (1 - \delta_j)$; the same identity with $h_{K+1} = 1$ gives $-h_K / (1 - \delta_K)$ at $j = K$. Multiplying by $\mathbf{N}$ and reading the first component,

$$\frac{\partial h_1}{\partial \delta_j} = N_{1j} \cdot \left(-\frac{h_j}{1 - \delta_j} \right),$$

which is Equation (3.7). Since $N \geq 0$, $h_j \geq 0$, and $1 - \delta_j > 0$, the right side is nonnegative. If $p_k > 0$ for every k , then $h_j = \prod_{k \geq j} \alpha_k > 0$ by the serial argument applied from stage j , and $N_{1j} \geq R_j = \prod_{k < j} \alpha_k > 0$, because the chain reaches stage j with probability R_j and each such path visits j at least once; hence the inequality in Equation (3.7) is strict, consistent with the serial argument. $\square$

Equation (3.7) says that a small increase in detection at stage j is worth the product of how often the chain visits j (N_{1j}) and how much success is still at stake there (h_j), scaled by $1/(1 - \delta_j)$. An early stage has a high visit count and a late stage a high residual success, so which is worth more depends on the parameters rather than on position, as Example 3.4 and Figure 3.12 show.

3.6.4 Worked Examples in MERIDIAN

Table 3.2. Illustrative per-day parameters for a business email compromise chain against the MERIDIAN finance office. These values are assumptions for the example, not entries of the MERIDIAN specification. Detection δ_k is zero at reconnaissance, which is external to the organization, and largest at delivery, exploitation, and action, where indicators and procedures apply.

k	Stage	advance p_k	abandon q_k	detect δ_k
1	Reconnaissance and profiling	0.25	0.02	0.00
2	Target and channel selection	0.40	0.02	0.02
3	Pretext and content development	0.30	0.03	0.01
4	Delivery and exposure	0.60	0.05	0.15
5	Cognitive exploitation	0.30	0.10	0.20
6	Action and effect	0.50	0.05	0.40
7	Reinforcement and persistence	0.35	0.00	0.25

Example 3.2 (Absorption of a business email compromise chain). Using the parameters of Table 3.2, we compute the probability that the chain succeeds and where it is otherwise absorbed. Forming M and G from Equation (3.3), the fundamental matrix $N = (I - M)^{-1}$ gives the absorption probabilities $B = NG$. Starting from reconnaissance, the chain reaches success S with probability 0.052, is detected and interdicted (D) with probability 0.619, and is abandoned (A) with probability 0.328; the three sum to one up to rounding, as Theorem 3.1 requires. The serial form Equation (3.6) gives the same success probability as the product of the per-stage advance probabilities $\alpha = (0.926, 0.908, 0.882, 0.726, 0.462, 0.411, 0.512)$, whose product is 0.052.

Under these controls a campaign succeeds about one time in nineteen, and the smallest advance probabilities, at exploitation (0.46) and action (0.41), locate the callback and dual-approval controls that carry most of the interdiction.

Example 3.3 (Dwell time and level dwell). We now compute how long the campaign takes and where the time is spent. The expected number of days at each stage is the first row of N , namely (3.70, 2.15, 2.50, 1.06, 1.04, 0.34, 0.20), and their sum

is the expected time to absorption $t_1 = \sum_j N_{1j} = 10.98$ days by [Theorem 3.1](#). Conditioning on success, [Theorem 3.2](#) gives the expected time to effect as the sum of the conditional dwells d_j in [Equation \(3.5\)](#), which is 15.7 days; a successful campaign takes longer than average because it must reach the later stages rather than being absorbed early.

[Figure 3.10](#) lists two levels for three stages. For the dwell computation we assign each stage to its primary level in a business email compromise: reconnaissance and reinforcement (labeled L4, L5) target the organization and are assigned to L4, and action and effect (labeled L1, L4) is assigned to L4 because the payment is released through the organization's process, the clerk's decision having been formed at exploitation. With this assignment, stages 1, 2, 3, 6, and 7 sit at the organizational level (L4) and stages 4 and 5 at the individual level (L1). Summing the expected visits by level, the chain spends about 8.9 days at L4 and 2.1 days at L1, so controls at the individual level have a narrow window while the organizational-level activity offers more time to interrupt.

Example 3.4 (Value of early versus late control). Suppose MERIDIAN can raise the per-day detection probability by 0.10 at exactly one stage, and must choose between an early control (domain monitoring at stage 2, target and channel selection) and a late control (a strengthened callback at stage 6, action and effect). We compare their effect on the success probability and on expected loss. Take the diverted payment at \$240,000 (twenty times the median vendor payment, a plausible large invoice) and assume that the payment is released during the action stage, so detections at stages 1 to 6 incur no loss, a detection at the reinforcement stage (stage 7) recovers 60% of the funds through a freeze request and loses 40%, and an undetected success loses the full amount. The expected loss per campaign is then $\$240,000 \times (h_1 + 0.4 N_{1,7} \delta_7)$, which is about \$17,300 at the parameters of [Table 3.2](#).

Raising δ_2 from 0.02 to 0.12 lowers h_1 from 0.052 to 0.041 and expected loss to about \$13,700, a reduction of roughly \$3,600. Raising δ_6 from 0.40 to 0.50 also lowers h_1 to 0.041 and expected loss to about \$13,600, a reduction of roughly \$3,700; part of each saving comes from fewer chains reaching stage 7, where detections still lose 40%. The two controls are close in value, as [Equation \(3.7\)](#) explains: the early stage has a high visit count ($N_{1,2} = 2.15$) but low residual success ($h_2 = 0.057$), the late stage a low visit count ($N_{1,6} = 0.34$) but high residual success ($h_6 = 0.21$), and the products are comparable.

The chapter lab ([Exercise 3.11](#)) reproduces these quantities by simulation and extends the analysis to a joint detection budget across stages.

3.7 Dissent, Ethics, and Limits

The apparatus of this chapter can harm the people it is meant to protect. A framework that classifies regularities of belief as vulnerabilities can be turned against legitimate disagreement, a taxonomy can license blaming individuals, a threat-actor model can license surveillance, and an attack chain can be read as a manual. This section draws the boundary that keeps vulnerability analysis

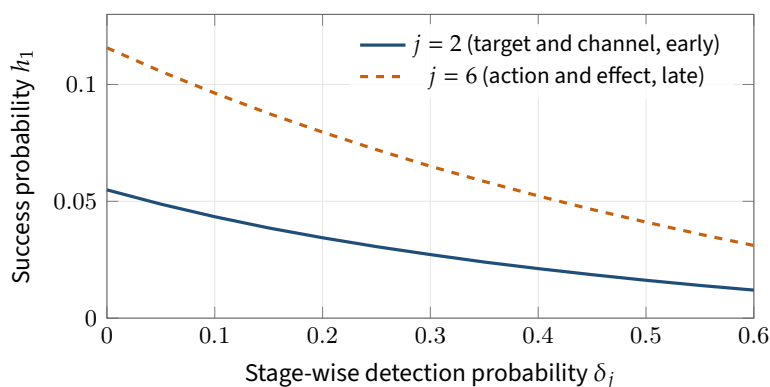


Figure 3.12. Attack success probability h_1 as a function of the detection probability δ_j at one stage, from the model of Table 3.2, illustrating Theorem 3.3. The late-stage curve starts higher because stage 6 carries the larger baseline detection, and near their operating points the two slopes are comparable, matching Example 3.4.

from becoming a tool against dissent, a constraint on every later chapter, and then states the harms and limits of the analysis.

3.7.1 The Pluralism Boundary

The boundary follows from the definitions. Definition 3.1 requires that the regularity produce a *decision error*, a departure from the person's own goals and standards, not a belief that an observer dislikes; a person who holds a view outside the mainstream after weighing evidence has not committed one. Definition 3.3 adds that an influence is adversarial only when it is joined to deception about source or intent, coercion, or circumvention of a check the person would otherwise apply. Open argument that leaves the person free to verify and to decline is influence, however much one disagrees with its conclusion.

Assumption 3.2 (Pluralism constraint). A cognitive-security analysis does not treat a belief, a preference, or a change of belief as a vulnerability or a compromise on the basis of its content. Vulnerability is attributed to a process (a regularity exploited through deception, coercion, or circumvention of verification), not to a conclusion. Dissent, minority belief, and unconventional trust are outside the scope of the threat model.

Three distinctions make the constraint operational. The first is process versus conclusion, drawn in Figure 3.13: two people can reach the same unconventional conclusion, one after open argument and one after a deception, and only the second involved an exploited vulnerability. A program that flags conclusions misclassifies the first and presents the analyst's own view as the standard of correctness.

The second distinction is between autonomy-preserving and autonomy-degrading intervention. A callback procedure, an accuracy prompt, a provenance signal, and a prebunking exercise leave the person free to reach their own

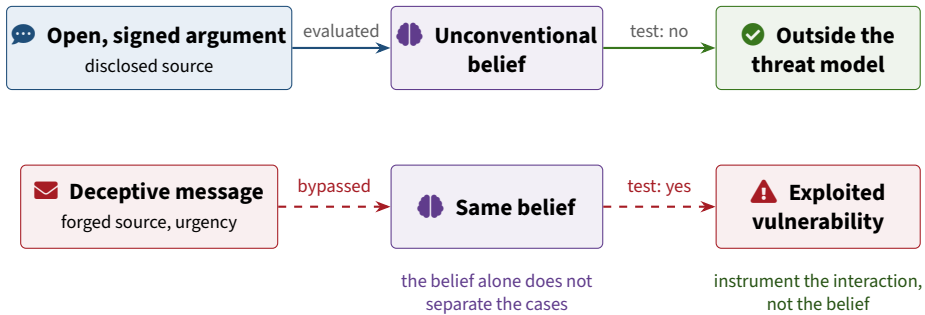


Figure 3.13. Process versus conclusion. Two people reach the same unconventional belief by different processes; only the process test (deceived about source, coerced, or denied a check) separates an exploited vulnerability from dissent.

conclusion, whereas a covert nudge that manipulates the regularity an attacker would use fails the constraint even when its aim is benign.

The third distinction concerns measurement. Repeated anomalous identity claims, escalating urgency across a contact sequence, and a request that bypasses an approval channel are observable without a judgment about what the person believes, and each is actionable through a workflow control; inferring private beliefs or political commitments from behavioral traces is weaker evidence and turns defense into surveillance of belief. Programs should therefore instrument the interaction and the decision pathway before instrumenting the person. An attack is also not defined by a false payload: selectively true claims, flooded attention, or induced distrust can be adversarial, while a true, openly sourced correction that a person is free to reject remains a defense.

3.7.2 Harms and Limits

The first harm is stigmatization. Naming a regularity a vulnerability invites the conclusion that some employees are the weak link, which [Definition 3.1](#) rejects by placing the vulnerability in a shared regularity and a shaped environment; programs should report at the level of process, use the language of susceptibility and exposure, and avoid per-person risk scores built from click history. The second harm is surveillance: the indicators of the attack chain can be implemented as pervasive monitoring, and staff who believe their beliefs are scored report less and challenge less, so monitoring should be proportionate to a named threat, transparent to those subject to it, and bounded by retention limits and oversight.

The third harm is dual use. An attack chain and a lever map describe how manipulation works, so this book keeps to the level of the published literature, describes mechanisms rather than recipes, and pairs each offensive construct with the control that interrupts it, on the judgment that the mechanisms are already known to adversaries. The fourth harm is the cost of false positives: a callback delays a genuine payment, a flagged message consumes an analyst's attention, and controls applied indiscriminately train people to bypass them. The marginal-value analysis of [Section 3.6](#) partly answers this harm by concentrating

controls where they reduce success most, and the costliest controls should be reserved for the highest-consequence actions.

The analysis also has limits. The Markov model is a teaching model whose parameters are illustrative, whose stages idealize a continuous process, and whose stationarity assumption ignores an adversary who adapts to the defense, so its numbers structure reasoning and should be recomputed against local estimates rather than reported as calibrated risk. Chapter 22 develops the governance structures that enforce the conditions of legitimate use stated here.

3.8 Summary

This chapter built the account of what can go wrong in cognition that the rest of the book defends against. A cognitive vulnerability is an exploitable regularity rather than a personal defect: a predictable feature of how a person, team, organization, or artificial agent attends, judges, feels, or learns, which conditions an adversary controls can turn into a decision error that serves the adversary. Separating the regularity from the error, the exploit mechanism, and the technique points each control at the right place. Innate regularities are mitigated mainly by changing the decision environment, acquired ones by training and by workflow and incentive design, and the evidence behind each should be weighed before it is relied on.

Harm requires more than a standing vulnerability. Exposure, susceptibility, and conversion factor the path from an attack to a harmful action and respond to different controls, so a click rate alone is weak evidence of risk. Levers such as authority, urgency, and familiarity trigger the regularities and compound when combined. Organizational thresholds, trust transfer through networks, recommender loops, and interfaces make vulnerability systemic and can turn redundancy into correlated failure, and threat actors differ in capability, intent, access, and opportunity, of which the last two are shaped by the defender's own architecture.

The formal core arranged this activity as the seven-stage cognitive attack chain, which switches levels and dwells between stages, and modeled it as an absorbing Markov chain. The fundamental matrix gives the success probability, the location of absorption, and the expected time to effect, and when every stage can be advanced, success decreases strictly in each stage-wise detection probability with a marginal value equal to visit count times residual success. In the MERIDIAN business email compromise example an early and a late control were close in value, so allocation should follow that computation rather than a rule of position. Finally, the chapter held that dissent, minority belief, and unconventional trust lie outside the threat model, that programs should instrument interactions rather than beliefs, and that the analysis carries harms and modeling limits that legitimate use must respect.

Exercises

Exercise 3.1 [C] Distinguish the four terms of [Section 3.1](#) (regularity, vulnerability, exploit mechanism, and technique) for a help-desk impersonation attack that

ends in a password reset. For each term give the specific content in this case, and state which kind of evidence (behavioral research, incident analysis, or telemetry) would establish it.

Exercise 3.2 [C] Classify each of the following as an innate or an acquired vulnerability, and name the control class [Figure 3.3](#) implies for it: (a) an operator who does not know that a callback number in a message body is worthless; (b) the tendency to treat a familiar sender's layout as a sign of safety; (c) a batch-approval habit formed over a year of routine payments; (d) a bonus scheme that rewards payment throughput. Explain why pooling these into one "human risk" score would misdirect a budget.

Exercise 3.3 [C] Restate the pluralism constraint ([Assumption 3.2](#)) without quoting it. Then decide, for each of the following, whether it involves an exploited cognitive vulnerability, and justify the answer by reference to process rather than conclusion: (a) an employee adopts a minority technical opinion after reading an internal debate; (b) an employee approves a payment after a caller impersonates the finance director; (c) a citizen distrusts an official source after an open, signed critique.

Exercise 3.4 [A] Using the exposure-susceptibility-conversion factorization of [Equation \(3.1\)](#), a role receives phishing at exposure $e = 0.6$ per month, forms the intended belief with probability $\psi = 0.15$, and acts with probability $\kappa = 0.4$. (a) Compute the monthly probability of a harmful action. (b) A training program halves ψ ; a verification step halves κ ; a filter reduces e by one third. Rank the three single interventions by the reduction each produces, and explain why they are not additive. (c) Which two combined give the largest reduction, and what is the residual probability?

Exercise 3.5 [A] Two approvers each miss a fraudulent payment with probability $m = 0.25$. (a) Compute the probability that both miss when the misses are independent, and when they are positively correlated with $\varrho_c = 0.6$, using $m^2 + \varrho_c m(1 - m)$. (b) A design change makes the second approver review the request without seeing the first approver's decision or the same forged document. Explain, in terms of [Definition 3.4](#), why this reduces the correlation, and what it does to the benefit of the second approver.

Exercise 3.6 [A] Consider a three-stage absorbing chain (delivery, exploitation, action) with, per step, advance probabilities $p = (0.6, 0.3, 0.5)$, abandonment $q = (0.05, 0.1, 0.05)$, and detection $\delta = (0.15, 0.2, 0.4)$. (a) Write the per-stage advance probabilities α_k from [Equation \(3.5\)](#) and compute the success probability $h_1 = \prod_k \alpha_k$. (b) Compute the conditional dwell d_k at each stage and the expected time to effect given success. (c) Using [Equation \(3.7\)](#), decide which stage's detection probability to raise by a small amount to reduce h_1 most, and check the answer by recomputing h_1 after adding 0.05 to that δ_k .

Exercise 3.7 [A] Prove that, in the serial chain of [Theorem 3.2](#), the elasticity of the success probability with respect to a stage's detection probability, $\frac{\partial \log h_1}{\partial \delta_j}$, equals $\frac{1}{\alpha_j} \frac{\partial \alpha_j}{\partial \delta_j}$, and show it does not depend on the parameters of the other stages.

Interpret this independence for a defender who can improve detection at only one stage.

Exercise 3.8 [A] The marginal value of interdiction in Equation (3.7) is $N_{1j}h_j/(1 - \delta_j)$. Construct a two-parameter family of seven-stage chains in which the stage of maximum marginal value shifts from an early stage to a late stage as one parameter varies, and explain which feature of the chain (visit count or residual success) drives the shift. This shows that “interrupt early” and “interrupt late” are both special cases.

Exercise 3.9 [A] An adversary launches attempts against a population as a Poisson process at rate $\lambda = 20$ per month, and each attempt independently results in a harmful action with probability $e\psi\kappa = 0.01$. (a) Using the thinning property, give the rate of harmful actions and the expected number per year. (b) A control reduces κ by half. Give the new annual expected number. (c) Explain why a control on κ (conversion) and a control on λ (deterrence that reduces attempts) can yield the same reduction, and what distinguishes them operationally.

Exercise 3.10 [C] Read the 2020 Twitter compromise practice box together with Figure 3.10. Identify, for the reconnaissance, delivery, and action stages, one preventive control and one detective control that would have interrupted the chain, and explain why the report’s recommended hardware authentication key acts at the delivery stage rather than the exploitation stage.

Exercise 3.11 [P] **Chapter lab: attack-chain simulation with stage-wise interdiction.** Implement the seven-stage absorbing Markov chain of Section 3.6 with the parameters of Table 3.2. (a) Build M and G , compute the fundamental matrix $N = (I - M)^{-1}$, and reproduce the absorption probabilities, the expected time to absorption, and the expected time to effect given success from Examples 3.2 and 3.3. (b) Verify the results by Monte Carlo simulation of at least 10^5 sample paths, comparing the simulated success probability and mean time to effect with the analytic values. (c) Compute the marginal value of interdiction $N_{1j}h_j/(1 - \delta_j)$ at each stage and confirm it against a finite-difference estimate. (d) Find the allocation of a total detection increase of 0.20 across stages that minimizes h_1 , compare it with the allocation that minimizes expected loss under the loss model of Example 3.4, and explain the difference. A reference implementation is in `companion/ch03/bec_chain.py`.

Notes and Further Reading

Vulnerability as regularity, and the evidence base. The framing of cognitive vulnerabilities as innate or acquired follows Huang and Zhu [3]. For heuristics and biases see [27, 75, 28], for the ecological reading [74], and on replication [81, 44, 82].

Levers and persuasion. The six levers draw on the compliance literature [80, 79, 87, 91], the illusory truth effect [88, 89, 90], and the elaboration likelihood model [77]; scam and phishing principles are in [85, 86, 78].

Systemic vulnerabilities. Sources for layered defenses and eroding controls are [20, 93]; for diffusion and recommender effects [94, 19, 95, 96]; and for interfaces, incentives, and habits [98, 97, 55, 84, 83].

Threat actors and the attack chain. The four-attribute characterization of threat sources follows the risk-assessment guidance of NIST SP 800-30 [99]. The attack chain adapts the intrusion kill chain of Hutchins, Cloppert, and Amin [31] and the cyber social-engineering kill chain of Montañez Rodriguez and Xu [105]. Insider threat typologies and cases are documented in the CERT guide [100], social bots by Ferrara and colleagues [102], and the 2020 Twitter compromise by the New York regulator [101] and the Department of Justice charges [106]. Business email compromise figures are from the IC3 annual report [103] and public service announcement [104].

The Markov model. The absorbing-chain machinery (the canonical form, the fundamental matrix, absorption probabilities, and expected times to absorption) is standard and follows Kemeny and Snell [107]. Modeling a multistage attack and its interdiction as a stochastic process with a defender who allocates a detection budget across stages connects to the interdiction literature; Morton, Pan, and Saeger [108] treat a related smuggling-interdiction problem, and the budgeted allocation of [Exercise 3.11](#) is a small instance of the interdiction problems taken up in Chapter 7.

Pointers. Objectives and resilience metrics that quantify the consequences of the vulnerabilities catalogued here are developed in [Chapter 4](#); the inference and game-theoretic methods that act on the chain are in Chapters 5 and 6; social engineering and fraud are treated in depth in Chapter 8; and the governance structures that enforce the ethical conditions of [Section 3.7](#) are in Chapter 22.

Cognitive Security Objectives, Risk, and Resilience Metrics

Learning Objectives

- ▶ State six security objectives for cognitive systems (cognitive integrity, autonomy, attentional availability, calibrated trust, accountability, and resilience) as measurable properties, and relate them to confidentiality, integrity, and availability.
- ▶ Model tensions among objectives, such as vigilance against fatigue, as constrained trade-offs, and compute the loss-minimizing operating point.
- ▶ Decompose cognitive risk into attempt rate, exposure, susceptibility, conversion, and consequence, and explain why risk matrices can reverse the ranking of risks.
- ▶ Choose a decision-quality function $Q(t)$ for each level of the Cognitive Security Stack, compute resilience-curve metrics and the resilience functional R , and prove its basic properties.
- ▶ Compute expected loss area and conditional value-at-risk (CVaR) of decision loss for Markov degradation and recovery models, and allocate effort between detection and recovery.
- ▶ Assess a cognitive-security metric for construct, internal, external, and statistical conclusion validity, and recognize proxy failure under optimization pressure.

This chapter answers two questions that later chapters presuppose: what cognitive defenses should achieve, and how achievement is measured. [Sections 4.1 to 4.3](#) define six objectives, model their conflicts, and decompose cognitive risk. [Sections 4.4 to 4.6](#) build decision quality, the resilience functional, and its stochastic and risk-averse forms, and [Sections 4.7 and 4.8](#) ask when such numbers mean what they claim and how measurement can harm the people it protects.

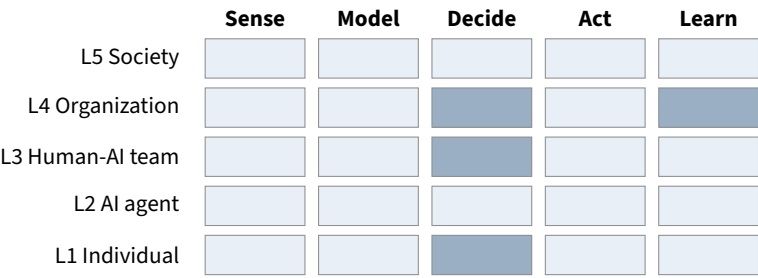


Figure 4.1. Level map for Chapter 4. The chapter supplies measurement for every cell, so all cells are lightly shaded. Dark cells mark where its worked examples concentrate: decisions of individuals, human-AI teams, and the organization, and organizational learning from measured outcomes.

MERIDIAN Running Example

MERIDIAN is a notional regional utility that supplies electricity and water to about 2.0 million residents; it is a teaching construct and is not modeled on a real organization. Its security operations center (SOC) runs five Tier-1 analysts, two Tier-2 analysts, and a shift lead on each shift, supported by an AI triage copilot.

At a quarterly review, the chief information security officer presents three numbers: the phishing click rate fell to 4%, mean time to detect fell by a third, and the risk register shows no red cells. The board asks whether the utility is more secure. The duty analyst’s incident notes suggest a less settled answer. During a phishing wave two weeks earlier, true incidents waited in the queue past their 30-minute deadline for several hours, although the click rate was low and detection was fast once the shift lead looked at the queue. The review has measured activity well and decision quality poorly. This chapter builds the measures that the board’s question requires.

4.1 Security Objectives for Cognitive Systems

A security program without stated objectives cannot tell success from activity. The classical tests of confidentiality, integrity, and availability remain necessary for cognitive assets, but they pass in many incidents that concern this book: an adversary can leave every record bit-identical and still control which records an analyst sees, in what order, and under what urgency. This section states objectives for the protected decision process itself and gives each a measurable form, following a system-scientific view in which human cognition is a component whose vulnerabilities propagate into cyber and physical consequences [3].

4.1.1 The Protected Decision Process

We first fix the object to which the objectives apply. We use the *cognitive loop* of Sense, Model, Decide, Act, and Learn, and the *Cognitive Security Stack* of five

levels, from the individual (L1) through the AI agent (L2), the human-AI team (L3), and the organization (L4) to society (L5). At each level, a decision-making system observes evidence, forms a belief about a hidden state, chooses an action, and learns from outcomes.

Definition 4.1 (Protected decision process). A *protected decision process* at level ℓ consists of a hidden state $h_t \in \mathcal{H}$, an evidence stream x_t received through authorized channels, a belief $\mathbf{b}_t \in \Delta(\mathcal{H})$ over the hidden state, an action $a_t \in \mathcal{A}_{\text{act}}$ chosen by a decision rule from the belief, and a set of *high-impact actions* $\mathcal{A}_{\text{hi}} \subseteq \mathcal{A}_{\text{act}}$ whose consequences are costly to reverse. A manipulation w from a manipulation set $\mathcal{W}$ may alter the evidence, inject inputs u_t through undisclosed channels, or consume the resources the process needs. The *reference process* is the same process run on the authentic evidence with no undisclosed input; its belief and action are written $\mathbf{b}_t^{\text{ref}}$ and a_t^{ref} , and manipulated quantities carry a tilde, $\tilde{\mathbf{b}}_t$ and $\tilde{a}_t$.

The reference process is a counterfactual, not a standard of truth. It holds the system's own inference fixed, including its honest errors, and asks what the manipulation changed. This choice keeps the objectives from licensing a defender to decide which beliefs are correct, a point to which [Section 4.8](#) returns.

4.1.2 Six Objectives

[Figure 4.2](#) relates the classical triad to six cognitive objectives. Confidentiality carries over with a wider scope, covering inferred preferences, internal prompts, and organizational decision context as well as stored records. Integrity and availability acquire cognitive readings. Autonomy, calibrated trust, and accountability have no classical predecessor, and resilience spans the others in time.

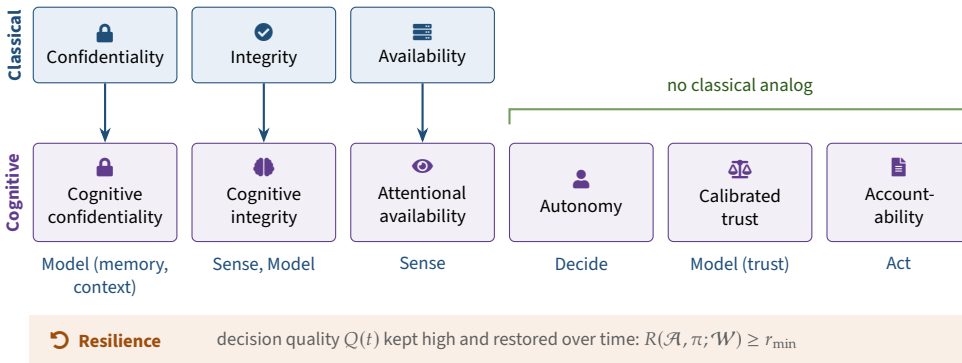


Figure 4.2. Security objectives for cognitive systems. Blue arrows show how confidentiality, integrity, and availability extend to cognitive assets; autonomy, calibrated trust, and accountability have no classical analog. Blue labels give the loop stage each objective mainly protects, and the resilience band spans all objectives in time.

Cognitive integrity concerns whether the belief the process forms is the one its authentic evidence supports. Distortion of a belief can occur without alteration of a byte, through selective disclosure, manufactured corroboration, or context poisoning of an AI agent's retrieved documents.

Definition 4.2 (Cognitive integrity). The *integrity loss* of a protected decision process under manipulation w at time t is $I_t(w) = \mathbb{E}[d_{\text{TV}}(\tilde{\mathbf{b}}_t, \mathbf{b}_t^{\text{ref}})]$, where $d_{\text{TV}}(\mathbf{b}, \mathbf{b}') = \frac{1}{2} \sum_{h \in \mathcal{H}} |b(h) - b'(h)|$ is the total variation distance. The process has *cognitive integrity at tolerance* $\varepsilon_I \in [0, 1]$ over $\mathcal{W}$ if $\sup_{w \in \mathcal{W}} \sup_{t \in [0, T]} I_t(w) \leq \varepsilon_I$.

The total variation distance has a decision-relevant meaning: it is the largest difference, over all events, in the probability the two beliefs assign to that event, so a bound on it bounds how much the manipulation can shift the probability of each hypothesis the decision depends on.

Autonomy concerns whether a consequential decision remains attributable to the authorized decision maker rather than to covert steering. It is violated even when the steered action happens to be correct, which distinguishes it from integrity. Philosophical accounts of manipulation locate the wrong in influence that works by hidden means on a person's decision-making [13]; the definition below uses the counterfactual structure of Definition 4.1 to make the hidden means observable in principle.

Definition 4.3 (Autonomy). Let $\tilde{a}_t$ be the action taken with the undisclosed input u_t of manipulation w and a_t^{ref} the action taken on the same authorized evidence without it. The *autonomy violation* is $V_t(w) = \mathbb{P}(\tilde{a}_t \neq a_t^{\text{ref}})$. The process preserves *autonomy at tolerance* ε_A if $\sup_{w \in \mathcal{W}} \sup_t V_t(w) \leq \varepsilon_A$. Disclosed influence, such as a labeled recommendation or an argument whose source is known, enters through the evidence x_t and does not count as a violation.

Attentional availability concerns whether the processing capacity of the decision maker reaches the items that matter in time. An attentional denial of service (ADoS), in which an adversary exhausts or misallocates attention, violates it without falsifying a single message.

Definition 4.4 (Attentional availability). For a class of protected items and a deadline $\tau > 0$, the *attentional availability at time t* is

$$\text{Av}_\tau(t) = \mathbb{P}(\text{an item arriving at } t \text{ receives processing within } \tau).$$

The objective is $\text{Av}_\tau(t) \geq 1 - \varepsilon_V$ for all t and all $w \in \mathcal{W}$.

Calibrated trust concerns whether reliance on a source, a colleague, or an automated aid tracks that source's reliability in the context of use, so that neither over-trust (misuse) nor under-trust (disuse) occurs [22, 26].

Definition 4.5 (Calibrated trust). Let $s \in \mathcal{S}$ index contexts of use with distribution ν , let $p(s)$ be the probability that a source's output is correct in context s , and let $\hat{p}(s) \in [0, 1]$ be the decision maker's trust, measured as the subjective probability that the output is correct. The *calibration gap* is $\Gamma = \mathbb{E}_{s \sim \nu} |\hat{p}(s) - p(s)|$, decomposed into *over-trust* $\Gamma^+ = \mathbb{E}_{s \sim \nu} (\hat{p}(s) - p(s))^+$ and *under-trust* $\Gamma^- = \mathbb{E}_{s \sim \nu} (p(s) - \hat{p}(s))^+$, so that $\Gamma = \Gamma^+ + \Gamma^-$. Trust is *calibrated at tolerance* ε_T if $\Gamma \leq \varepsilon_T$ under every $w \in \mathcal{W}$.

The decomposition matters for defense because the two failures call for opposite remedies: teaching blanket suspicion reduces Γ^+ by raising Γ^- . An adversary

who cannot corrupt a reliable aid can still attack its value by inducing under-trust, for example with a burst of conspicuous false alarms.

Accountability concerns whether each consequential action can be attributed to an authorized principal and reconstructed from the evidence and authority on which it rested. It is what makes a decision contestable and reversible after manipulation is discovered, and it is also the objective on which recovery depends: an organization that cannot tell which approvals rested on a forged message cannot decide which to revisit.

Definition 4.6 (Accountability). For a high-impact action $a \in \mathcal{A}_{hi}$, an *attribution record* lists the principal who authorized it, the authority under which it was taken, and the evidence items on which it relied, each with verifiable provenance. The *accountability level* is $Ac = \mathbb{P}(\text{a complete and verifiable attribution record exists} \mid a \in \mathcal{A}_{hi})$, and the objective is $Ac \geq 1 - \varepsilon_C$.

The five objectives so far are properties at an instant or averaged over instants; the sixth concerns their trajectory. *Resilience* is the capacity of the protected process to keep decision quality high under manipulation and to restore it afterward, following the goals of cyber resiliency engineering to anticipate, withstand, recover from, and adapt to adversity [30]. The *resilience objective* requires $R(\mathcal{A}, \pi; \mathcal{W}) \geq r_{\min}$ for a level $r_{\min} \in (0, 1]$, where R is the worst-case time average of normalized decision quality defined in Section 4.5.

The six objectives are not independent: integrity and availability are inputs to decision quality, accountability is a precondition for recovery, and autonomy constrains which defenses may pursue the others. A defense that covertly steers staff or the public toward a preferred belief violates Definition 4.3 by construction and so cannot be counted as a gain in security under this chapter's definitions.

4.2 Tensions Among Objectives

Cognitive-security objectives cannot be raised independently as items on a checklist, because the controls that advance one consume the resources or relationships on which another depends. This section names three recurring tensions and models one formally to show that the loss-minimizing design sits strictly inside the range of available effort.

4.2.1 Three Recurring Tensions

The first tension is *vigilance against fatigue*. Scrutiny of messages, alerts, and requests raises the chance of catching a manipulation, and it also consumes the attention it relies on. Sustained monitoring is effortful and stressful, and performance in vigilance tasks declines with time on task [109, 110]. A program that asks every employee to inspect every message with maximal care is therefore not maximally secure; beyond some point, additional demanded vigilance lowers the sensitivity of the scrutiny it buys and spends attentional availability that other tasks need. Alert-management strategies that deliberately defer or leave some alerts uninspected, chosen to keep operator attention within capacity, formalize the same trade-off for informational denial-of-service attacks [2].

The second tension is *skepticism against trust*. Skepticism toward unverified sources protects cognitive integrity, but indiscriminate skepticism is under-trust in the sense of [Definition 4.5](#). An organization whose staff distrust all automated recommendations has lost the benefit of reliable aids, and one whose public distrusts all official messages cannot deliver a genuine boil-water advisory. Blanket distrust is thus a possible outcome of an attack on trust calibration rather than a defense against it.

The third tension is *monitoring against privacy and autonomy*. Detecting manipulation, and reconstructing decisions afterward, requires observation of communication, delegation, and decision behavior, which advances accountability. Observation of people, as distinct from observation of workflows, erodes privacy, can chill legitimate dissent, and creates a new store of sensitive data that is itself an attack target.

[Figure 4.3](#) places the three tensions on one picture, with a policy as a point whose coordinates give its share of design emphasis on each vertex.

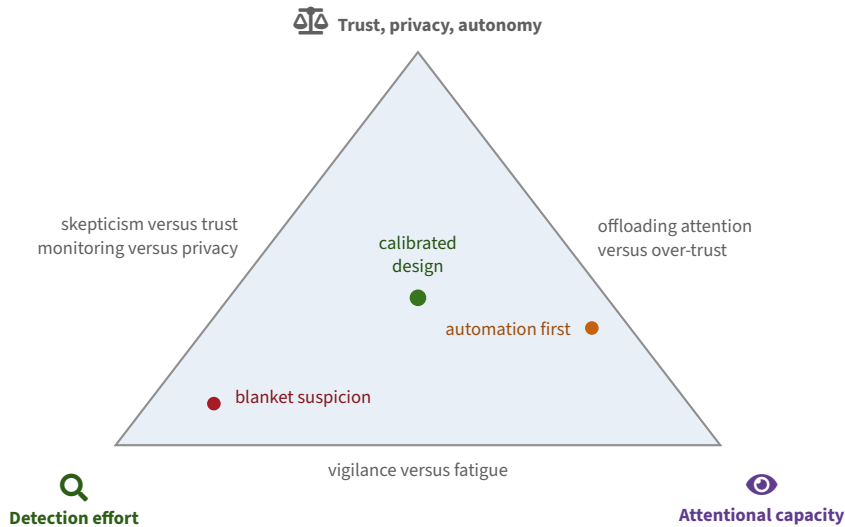


Figure 4.3. The objective tension simplex. A design distributes emphasis among detection effort, attentional capacity, and trust with privacy and autonomy; the edges carry the three recurring tensions. Designs near an edge sacrifice the opposite vertex, as blanket suspicion does, while the interior point spends each resource where it earns its keep.

A common design response runs through all three tensions: *selective application*. Friction is concentrated at irreversible or unusual transitions rather than applied to every action; telemetry records the structure of events, such as bypassed approvals and channel changes, rather than inferred mental states; delegation to automation is bounded rather than withheld. The formal model below shows why the interior is optimal in the first tension, and the same logic of diminishing and then negative returns recurs in the other two.

4.2.2 A Vigilance-Fatigue Trade-Off Model

Consider an analyst or a team handling a stream of items, of which a fraction $\rho \in (0, 1)$ are adversarial (the base rate). Let $v \in [0, 1]$ be the *vigilance level*, the fraction of items that receive deep investigation. We assume the adversarial items of interest are subtle enough to be found only by deep investigation, and that the sensitivity of deep investigation falls as more of the shift is spent on it.

Assumption 4.1 (Linear fatigue). Deep investigation detects an adversarial item with probability $s(v) = s_0(1 - \phi v)$, where $s_0 \in (0, 1]$ is rested sensitivity and $\phi \in (0, 1)$ is a fatigue coefficient. The detection probability for adversarial items is $P_D(v) = v s(v)$. Each missed adversarial item costs $C_M > 0$, and deep investigation costs $c > 0$ per item.

The expected loss per item is

$$J(v) = \rho C_M(1 - s_0 v(1 - \phi v)) + c v. \quad (4.1)$$

Proposition 4.1 (Interior optimal vigilance). Under Assumption 4.1, J is strictly convex on $[0, 1]$ and has the unique minimizer

$$v^* = \min \left\{ 1, \max \left\{ 0, \frac{1}{2\phi} \left(1 - \frac{c}{\rho C_M s_0} \right) \right\} \right\}. \quad (4.2)$$

In particular, if $c < \rho C_M s_0$ and $\phi > \frac{1}{2}(1 - c/(\rho C_M s_0))$, then $0 < v^* < 1$ and $J(v^*) < J(1)$: demanding full vigilance is strictly worse than the interior level. Moreover v^* is nonincreasing in ϕ and in c and nondecreasing in ρ , in C_M , and in s_0 .

Proof. Expanding (4.1) gives $J(v) = \rho C_M - (\rho C_M s_0 - c)v + \rho C_M s_0 \phi v^2$, a quadratic with leading coefficient $\rho C_M s_0 \phi > 0$, so J is strictly convex on $\mathbb{R}$ and hence on $[0, 1]$. Its unconstrained stationary point solves $J'(v) = -(\rho C_M s_0 - c) + 2\rho C_M s_0 \phi v = 0$, that is, $\bar{v} = (1 - c/(\rho C_M s_0))/(2\phi)$. A strictly convex function on an interval attains its unique minimum at the projection of its unconstrained minimizer onto the interval, because J is decreasing to the left of $\bar{v}$ and increasing to the right of it; this gives (4.2). Under the two stated conditions, $0 < \bar{v} < 1$, so $v^* = \bar{v}$ is interior, and strict convexity with $v^* \neq 1$ gives $J(v^*) < J(1)$. Finally, $\bar{v}$ is decreasing in c and increasing in ρ , C_M , and s_0 for every ϕ . If $c < \rho C_M s_0$, then $\bar{v} > 0$ and $\partial \bar{v} / \partial \phi = -\bar{v} / \phi < 0$; otherwise $\bar{v} \leq 0$ and $v^* = 0$ for every ϕ . The projection $\min\{1, \max\{0, \cdot\}\}$ is nondecreasing, so it preserves these monotonicity properties in the weak sense stated. $\square$

The proposition turns an intuition into a design rule: the right level of demanded vigilance falls as fatigue effects grow and rises with the base rate and the cost of a miss. It also shows why the prevalence effect, in which rare targets are missed more often [7], interacts with filtering: an upstream filter that lowers ρ in the stream lowers v^* , so the residual adversarial items receive less scrutiny exactly when each one is harder to find.

Example 4.1 (Deep-investigation policy in the MERIDIAN SOC). The problem is to choose the fraction of Tier-1 alerts that receive deep investigation. From the

MERIDIAN specification, 2% of alerts are true incidents ($\rho = 0.02$) and staff time costs \$60 per hour. For this example we assume that deep investigation takes 10 additional minutes ($c = \$10$ per alert), that a missed subtle incident costs $C_M = \$20,000$ in expected response and damage, that rested sensitivity is $s_0 = 0.95$, and that the fatigue coefficient is $\phi = 0.6$ on a normal shift and $\phi = 0.8$ during a sustained surge.

For the solution, $\rho C_M s_0 = 380$ and $c/(\rho C_M s_0) = 0.026$. With $\phi = 0.6$, (4.2) gives $v^* = 0.974/1.2 = 0.811$ and expected loss $J(v^*) = \$249.9$ per alert, against $J(1) = \$258.0$ for full deep investigation and $J(0) = \$400$ for none. With $\phi = 0.8$, $v^* = 0.609$, $J(v^*) = \$287.4$, and $J(1) = \$334.0$. Figure 4.4 plots both curves. The conclusion is that under surge fatigue the SOC should deliberately deep-investigate about three alerts in five rather than all of them, and that the loss penalty of demanding full vigilance grows from 3% to 16% as fatigue increases.

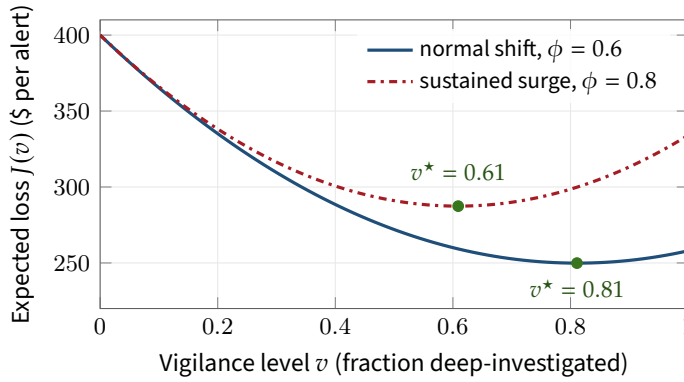


Figure 4.4. Expected loss per alert in Example 4.1 as a function of the vigilance level. Green dots mark the optimal levels from Theorem 4.1. Beyond the optimum, fatigue lowers the sensitivity of scrutiny faster than added scrutiny catches incidents, and the penalty is larger under surge conditions.

4.3 Cognitive Risk

Objectives say what to protect; risk says where protection is most needed [99]. For cognitive attacks the central difficulty is that *susceptibility*, a property of a person, team, or agent, is often reported as if it were *risk*, a property of a scenario: a highly susceptible analyst who receives no tailored lure contributes little risk, while a moderately susceptible approver with payment authority, heavily targeted and weakly verified, contributes a great deal. This section separates the factors, derives the loss distribution they imply, and examines the risk matrix.

4.3.1 A Factorization of Cognitive Risk

Fix a scenario, such as credential phishing against MERIDIAN staff, and a period of length T . The path from attempt to harm passes through four events, and Figure 4.5 draws them with the control family that acts on each.

Definition 4.7 (Cognitive risk factors). Attempts arrive as a Poisson process with rate λ per unit time. For a given attempt, the *exposure* $e = \mathbb{P}(E)$ is the probability that the target encounters the attempt (event E); the *susceptibility* $\psi = \mathbb{P}(B | E)$ is the probability that the target forms the intended belief or misplaced trust (event B) given exposure; the *conversion* $\kappa = \mathbb{P}(A | B)$ is the probability that the belief is converted into an action with authority, such as a credential submission or a payment approval (event A); and the *consequence* $C \geq 0$ is the loss caused by the action, a random variable with finite second moment, independent across attempts and of the events E, B, A . The *harmful-action rate* is $\lambda e \psi \kappa$, and the *cognitive risk* over $[0, T]$ is the expected loss $\mathbb{E}[S_T]$, where S_T is the total consequence of harmful actions in $[0, T]$.

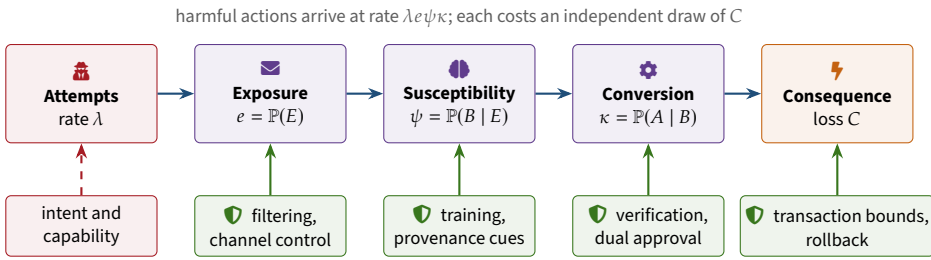


Figure 4.5. The factorization of cognitive risk. An attempt becomes a loss only if it is encountered, believed, and converted into an action with authority; green boxes show the control family that reduces each factor.

The factors answer distinct questions (who meets the attack, who is persuaded, whether persuasion reaches an action with authority, and what that action costs), and a click rate measured on delivered simulations estimates only the product $\psi \kappa$ and does not describe e or the distribution of C .

Proposition 4.2 (Distribution of cognitive loss). *Under Definition 4.7, and assuming that the events E, B, A for different attempts are independent, the number N_T of harmful actions in $[0, T]$ is Poisson with mean $\bar{N}_T = \lambda e \psi \kappa T$, and the total loss $S_T = \sum_{k=1}^{N_T} C_k$ satisfies*

$$\mathbb{E}[S_T] = \lambda e \psi \kappa T \mathbb{E}[C], \quad \text{Var}(S_T) = \lambda e \psi \kappa T \mathbb{E}[C^2]. \quad (4.3)$$

Proof. Let M_T be the number of attempts in $[0, T]$, Poisson with mean λT . Each attempt independently becomes a harmful action with probability $q = \mathbb{P}(E \cap B \cap A) = \mathbb{P}(E)\mathbb{P}(B | E)\mathbb{P}(A | B) = e \psi \kappa$ by the chain rule, where $\mathbb{P}(A | B) = \mathbb{P}(A | B \cap E)$ because action presupposes belief and belief presupposes exposure. Conditional on $M_T = m$, N_T is binomial with parameters m and q , so for $n \geq 0$,

$$\begin{aligned} \mathbb{P}(N_T = n) &= \sum_{m \geq n} e^{-\lambda T} \frac{(\lambda T)^m}{m!} \binom{m}{n} q^n (1-q)^{m-n} \\ &= e^{-\lambda T} \frac{(\lambda T q)^n}{n!} \sum_{j \geq 0} \frac{(\lambda T (1-q))^j}{j!} = e^{-\lambda T q} \frac{(\lambda T q)^n}{n!}, \end{aligned}$$

which is the Poisson distribution with mean $\tilde{N}_T = \lambda Tq$. For the loss, condition on N_T : because the C_k are independent and identically distributed and independent of N_T , $\mathbb{E}[S_T | N_T] = N_T \mathbb{E}[C]$ and $\text{Var}(S_T | N_T) = N_T \text{Var}(C)$. The law of total expectation gives $\mathbb{E}[S_T] = \tilde{N}_T \mathbb{E}[C]$, and the law of total variance gives $\text{Var}(S_T) = \mathbb{E}[N_T] \text{Var}(C) + \text{Var}(N_T) (\mathbb{E}[C])^2 = \tilde{N}_T (\text{Var}(C) + (\mathbb{E}[C])^2) = \tilde{N}_T \mathbb{E}[C^2]$, using $\text{Var}(N_T) = \mathbb{E}[N_T] = \tilde{N}_T$. $\square$

Two implications follow. The expected loss is multiplicative in the four factors, so a proportional reduction in a single factor reduces expected loss by the same proportion; the choice among controls then turns on cost and on robustness to adversary adaptation, not on position in the chain. The variance, however, depends on $\mathbb{E}[C^2]$, so two scenarios with equal expected loss can differ greatly in their tails when one has rare large consequences, which is the typical shape of payment fraud. Expected loss is therefore an incomplete ranking criterion, a point that [Section 4.6](#) develops with conditional value-at-risk.

4.3.2 Risk Matrices and Their Limits

Few organizations estimate the factors of [Definition 4.7](#) numerically. The prevalent instrument is the *risk matrix*, which assigns each risk an ordinal likelihood category and an ordinal consequence category and ranks risks by a color or a score read from the resulting cell. It is quick and requires no probability estimates, but Cox's analysis identified four limitations [[111](#)]: poor resolution, since risks with very different values share a cell; errors, since quantitatively smaller risks can receive higher ratings; misdirected resources; and ambiguous categories such as "likely". The analysis also showed that for risks whose frequency and severity are negatively correlated, matrices can perform worse than a random ranking. Cognitive risks commonly have that shape: high-volume, low-consequence credential phishing sits beside rare, high-consequence executive impersonation.

The error of ranking reversal is easy to state precisely.

Definition 4.8 (Product-score risk matrix). Let $0 = \bar{p}_0 < \bar{p}_1 < \dots < \bar{p}_m = 1$ partition annual probability into likelihood bins $[\bar{p}_{i-1}, \bar{p}_i)$, with the last bin closed, and let $0 = \bar{c}_0 < \bar{c}_1 < \dots < \bar{c}_n$ partition consequence into bins $[\bar{c}_{j-1}, \bar{c}_j)$. A risk with annual probability p and consequence c lies in the cell (i, j) containing (p, c) and receives the *score* ij . Its expected annual loss is pc .

Proposition 4.3 (Ranking reversal). Let (i, j) and (i', j') be cells with $ij > i'j'$. If $\bar{p}_{i-1}\bar{c}_{j-1} < \bar{p}_{i'}\bar{c}_{j'}$, then there exist a risk in cell (i, j) and a risk in cell (i', j') such that the matrix ranks the first strictly higher while its expected loss is strictly lower.

Proof. The lower corner $(p, c) = (\bar{p}_{i-1}, \bar{c}_{j-1})$ lies in cell (i, j) because bins are closed on the left, and a risk placed there has expected loss $\bar{p}_{i-1}\bar{c}_{j-1}$. The expected loss of a risk in cell (i', j') can be made arbitrarily close to the upper corner value $\bar{p}_{i'}\bar{c}_{j'}$ from below, because the function $(p, c) \mapsto pc$ is continuous and the points $(\bar{p}_{i'} - \eta, \bar{c}_{j'} - \eta)$ lie in the cell for small $\eta > 0$. Let $g = \bar{p}_{i'}\bar{c}_{j'} - \bar{p}_{i-1}\bar{c}_{j-1} > 0$. Choose the first risk at the lower corner of (i, j) and choose $\eta > 0$ small enough that

$(\bar{p}_{i'} - \eta)(\bar{c}_{j'} - \eta) > \bar{p}_{i-1}\bar{c}_{j-1} + g/2$. The first risk then has score $ij > i'j'$ and expected loss $\bar{p}_{i-1}\bar{c}_{j-1}$, while the second has expected loss greater than $\bar{p}_{i-1}\bar{c}_{j-1} + g/2$. $\square$

The condition of the proposition holds for many pairs of adjacent cells in the usual three-by-three and five-by-five designs, because the range of expected loss within a single cell spans a factor of $\bar{p}_i\bar{c}_j/(\bar{p}_{i-1}\bar{c}_{j-1})$, which is unbounded in the bottom row and column and equals four in the middle cell of a three-by-three matrix with equal bins.

Example 4.2 (A ranking reversal in the MERIDIAN risk register). The problem is to rank two cognitive risks with MERIDIAN's three-by-three register and to compare the ranking with expected loss. The register uses likelihood bins of annual probability $[0, \frac{1}{3})$, $[\frac{1}{3}, \frac{2}{3})$, $[\frac{2}{3}, 1]$ and consequence bins of \$0 to \$3 million, \$3 to \$6 million, and \$6 to \$9 million, scored by the product of bin indices. For this example we assume the following estimates. Risk A is a material incident from credential phishing, with annual probability 0.70 and consequence \$3.2 million in response, recovery, and service disruption. Risk B is a deepfake-supported payment fraud that exploits the chief financial officer's single-wire authority of up to \$5 million, with annual probability 0.64 and consequence \$4.8 million.

For the solution, risk A falls in cell (High, Medium) with score $3 \times 2 = 6$ and risk B in cell (Medium, Medium) with score $2 \times 2 = 4$, so the register ranks A above B and colors A red. The expected annual losses are $0.70 \times 3.2 = \$2.24$ million for A and $0.64 \times 4.8 = \$3.07$ million for B, so B carries 37% more expected loss. [Theorem 4.3](#) applies because the lower corner of cell (High, Medium) has expected loss $\frac{2}{3} \times 3 = \$2$ million, below the upper corner of cell (Medium, Medium) at $\frac{2}{3} \times 6 = \$4$ million. [Figure 4.6](#) shows both risks against curves of constant expected loss. The conclusion is that a register ranking would direct the next control budget toward phishing, while an expected-loss ranking directs it toward payment verification; the reversal arises because A sits just above two bin boundaries and B just below one.

A matrix can be kept as a communication device while its failure modes are managed: record the numeric estimates behind each placement, report expected loss alongside the cell, and treat pairs of risks near bin boundaries as unranked. None of these remedies addresses the deeper limitation that a two-dimensional summary omits the tail of the consequence distribution, which [Theorem 4.2](#) showed to be a separate quantity.

4.4 Decision Quality as a Performance Function

Risk describes expected harm before an incident; decision quality describes how well the protected process performs as an incident unfolds, which is what the board in the opening vignette asked about. This section defines what counts as a decision-quality function and gives one at each level of the Stack.

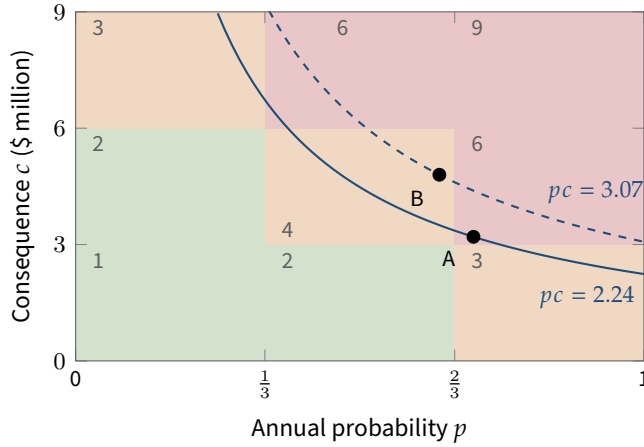


Figure 4.6. The risk matrix of Example 4.2. Cell shading and the gray scores follow the product rule, which rates risk A (score 6) above risk B (score 4). The blue curves of constant expected loss show that B lies on a higher curve than A, a ranking reversal.

4.4.1 Admissible Decision-Quality Functions

Definition 4.9 (Admissible decision-quality function). A *decision-quality function* for a protected decision process is a map $t \mapsto Q(t; \mathcal{A}, \pi, w)$ from $[0, T]$ to $[0, Q_{\max}]$ that is Lebesgue measurable in t for each architecture $\mathcal{A}$, policy π , and manipulation w , and whose larger values mean better decisions. It is *admissible* if, in addition, (i) its nominal value $Q_0 \in (0, Q_{\max}]$ is its value under the reference process of Definition 4.1 with no manipulation; (ii) it is defined on outcomes of the protected decision, scored against a stated ground truth, rather than on activity counts; and (iii) it does not reward agreement with a particular opinion on questions where disagreement is legitimate.

Condition (ii) excludes quantities such as the number of training modules completed or the number of alerts closed, which can rise while decisions worsen. Condition (iii) is the measurement form of the pluralism constraint that accompanies the resilience functional throughout the book: at the societal level, a decision-quality function may score whether residents know that a boil-water advisory is in force, which has a ground truth, but not whether they hold a favored view about the utility's pricing policy, which does not. Figure 4.7 gives an admissible function at each level of the Stack together with its MERIDIAN instance.

4.4.2 Operationalizations by Level

At level L1, an individual classifies items, such as requests to change a vendor's bank details, as legitimate or malicious. Let ρ be the base rate of malicious items, $P_D(t)$ and $P_{FA}(t)$ the detection and false-alarm probabilities, and C_M and C_F the

Level	Decision quality $Q_i(t)$	MERIDIAN instance
 L5 Society	fraction of the affected population that holds the accurate safety-relevant belief	residents of a 90,000-person district aware of a boil-water advisory
 L4 Organization	fraction of true incidents correctly triaged within the deadline	SOC true incidents handled within 30 minutes
 L3 Human-AI team	appropriate reliance: accept correct and override incorrect recommendations	analyst decisions on AI copilot auto-close suggestions
 L2 AI agent	fraction of tasks completed correctly with no unauthorized tool action	MERIDIAN Assist tasks under injected document content
 L1 Individual	cost-weighted correct classification of legitimate and malicious requests	finance staff decisions on bank-detail change requests

Figure 4.7. Admissible decision-quality functions at the five levels of the Cognitive Security Stack. Each is scored on outcomes of the protected decision against a stated ground truth, and the societal function scores a factual, safety-relevant belief rather than agreement with an opinion.

costs of a miss and a false alarm. We use the *cost-weighted accuracy*

$$Q_1(t) = 1 - \frac{\rho C_M(1 - P_D(t)) + (1 - \rho)C_F P_{FA}(t)}{\rho C_M + (1 - \rho)C_F}, \quad (4.4)$$

which equals 1 for a perfect classifier, equals 0 when every item is misclassified, and weights errors by their consequences. Because an intervention can raise P_D by shifting the decision criterion alone, raising P_{FA} with it [112], (4.4) registers a trade that a detection rate reported alone does not.

At level L2, an AI agent completes tasks with tools. Its decision quality is the fraction of tasks, in a stated window, that are completed correctly and involve no tool action outside the authority delegated for the task. The conjunction matters, because an agent steered by injected content can complete the visible task and also perform an unauthorized action, and a task-success rate alone would not register the second.

At level L3, a human-AI team decides whether to accept a recommendation. If the recommendation is correct with probability p , and the operator accepts correct recommendations with probability r_c and overrides incorrect ones with probability o_i , the *appropriate-reliance rate* is $Q_3 = p r_c + (1 - p) o_i$. It falls under over-trust, through low o_i , and under under-trust, through low r_c , so it is the decision-quality counterpart of the calibration gap in Definition 4.5.

At level L4, an organization carries out a workflow with a deadline. For the MERIDIAN SOC, decision quality is the fraction of true incidents that are correctly identified and triaged within 30 minutes of arrival. It combines the recall of the AI copilot, which auto-closes 3% of true incidents in error, the accuracy of the analyst on the incidents that reach the queue, and the probability that triage finishes in time, and it therefore couples cognitive integrity with attentional availability.

At level L5, the decision maker is a population. During a boil-water advisory, decision quality is the fraction of residents in the affected district who hold the

accurate belief that the advisory applies to them, estimated from a probability sample; a companion function scores the fraction who take the protective action. Both have a ground truth set by the advisory itself.

These functions are chosen per scenario, and the resilience functional of the next section is computed from one function at a time. When several levels matter, as in a cross-level incident, the analysis tracks each level's function and states which one sets the worst case rather than averaging functions with different meanings.

4.4.3 Decision Quality in a Phishing Wave

Example 4.3 (SOC decision quality under a phishing wave). The problem is to compute MERIDIAN SOC decision quality $Q_4(t)$ over a 12-hour shift during a phishing wave, and to compare three responses. From the specification, five Tier-1 analysts each clear 15 alerts per hour (capacity 75 per hour) with exponential service of mean 4 minutes, alerts arrive at 50 per hour (utilization $\rho = 0.67$), the triage deadline is 30 minutes, and the copilot's recall on true incidents is 0.97. For this example we assume an analyst accuracy of 0.98 on true incidents in nominal conditions, a wave that raises arrivals to 90 per hour from hour 1 to hour 4 as reports and gateway detections of the phishing messages reach the queue, and an analyst accuracy of 0.90 while the queue is saturated. The responses are no surge, a surge that moves the two Tier-2 analysts to Tier-1 triage (capacity 105 per hour) at hour 3, and the same surge at hour 2.

For the solution, we use a fluid approximation of the queue: the backlog $B(t)$ grows at the arrival rate minus capacity when positive, a true incident arriving at t waits $W(t) = B(t)/\text{capacity}$, and it is triaged in time with probability $1 - e^{-15(0.5-W(t))}$ for $W(t) < 0.5$ hours and 0 otherwise. Then $Q_4(t) = 0.97 \times a(t) \times (1 - e^{-15(0.5-W(t))})$, where $a(t)$ is the analyst accuracy. Under nominal load, an exact multi-server queue calculation gives a probability of 0.9992 that triage completes within 30 minutes, so $Q_0 = 0.97 \times 0.98 \times 0.9992 = 0.950$. Without surge, the backlog reaches 45 alerts at hour 4, waits exceed 30 minutes from hour 3.5 to hour 4.3, where $Q_4 = 0$, and quality returns within 1% of nominal only at hour 5.8. With surge at hour 3, the backlog peaks at 30 alerts, the lowest quality is $0.714 Q_0$, and quality is restored by hour 4.3. With surge at hour 2, the lowest quality is $0.909 Q_0$ and quality is restored at hour 3.0. The time-averaged ratios $\frac{1}{12} \int_0^{12} Q_4/Q_0 dt$ are 0.866, 0.971, and 0.986. [Figure 4.8](#) plots the three curves.

The conclusion is that the click rate, identical in the three cases, does not distinguish them, and that the timing of the surge decision, a detection-and-response quantity, determines whether true incidents are triaged at all during the peak.

Queueing models of attention, including exact treatment of multi-server queues under attentional denial of service, are developed in Chapter 10.

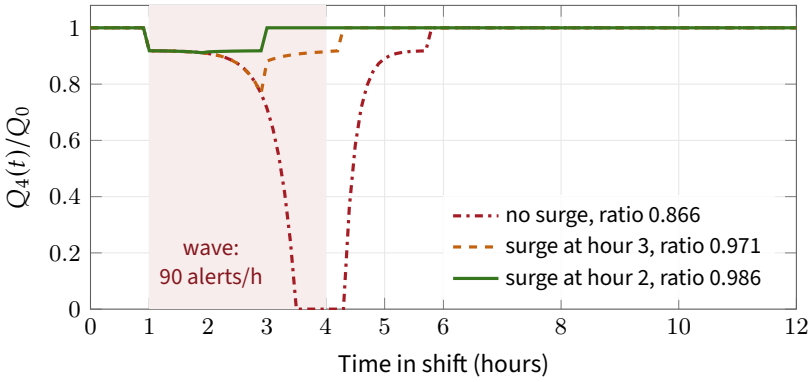


Figure 4.8. Normalized SOC decision quality in Example 4.3. The shaded band is the phishing wave. Without surge, true incidents cannot be triaged within the deadline between hours 3.5 and 4.3; an earlier surge decision makes the dip shallower and shorter.

4.5 The Resilience Curve and the Resilience Functional

A single value of decision quality describes a moment; security decisions concern trajectories. The *resilience curve* plots $Q(t)$ through an incident, and resilience engineering summarizes such curves by the depth of the drop, the time to restoration, and the area between the nominal level and the curve [32]. This section adapts that tradition to decision quality, adds the adversary through a worst case over manipulations, and proves the properties that make the resulting functional a usable design criterion.

4.5.1 Metrics of the Resilience Curve

The four resilience phases of the Cognitive Security Cube, Anticipate, Withstand, Recover, and Adapt, correspond to segments of the curve: anticipation sets conditions before onset, the process withstands the manipulation until it is detected, it recovers until quality is restored, and it may adapt so that quality settles at a new level.

Definition 4.10 (Resilience-curve metrics). Fix $\mathcal{A}$, π , a manipulation w , and a horizon T , and write $q(t) = Q(t; \mathcal{A}, \pi, w)/Q_0$ for normalized decision quality. Let t_a be the *onset* time of the manipulation, $t_{al} \geq t_a$ the time at which the first alert or indicator is raised, $t_d \geq t_{al}$ the *detection* time at which the defender acts on the manipulation, and $t_r \geq t_d$ the *restoration* time after which $q(t) \geq 1 - \epsilon_r$ for a stated tolerance ϵ_r . The *quality deficit* at time t is $1 - q(t)$, and the *depth* is its largest value, $\delta_{\max} = 1 - \inf_{t \in [t_a, t_r]} q(t)$; the *time to alert* is $t_{al} - t_a$, the *time to act* is $t_d - t_{al}$, and the *time to detect* is their sum, $\text{TTD} = t_d - t_a$; the *time to recover* is $\text{TTR} = t_r - t_d$. The *loss area* and the *gross loss area* are

$$\Lambda_w = \int_0^T (1 - q(t)) dt, \quad \Lambda_w^+ = \int_0^T (1 - q(t))^+ dt, \quad (4.5)$$

both measured in time units of nominal quality.

Figure 4.9 annotates the metrics on a curve. Unlike the classical triangle, it splits time to detect into time to alert, which measures the Sense stage of the defender's own loop, and time to act, which measures the Decide stage, so that an alert raised quickly and acted on slowly shows as a detection problem of a cognitive kind.

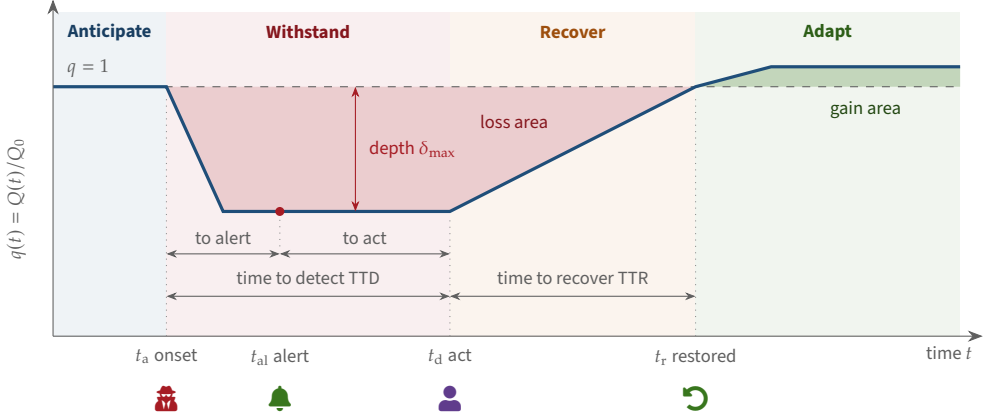


Figure 4.9. The resilience curve with its metrics. Time to detect splits into time to alert (the defender senses) and time to act (the defender decides), and the loss area (red) is offset by the gain area (green) when the process adapts above nominal. The gross loss area Λ_w^+ counts the red region only.

For a manipulation w , the time average of normalized quality is $\bar{q}_w = \frac{1}{T} \int_0^T q(t) dt = 1 - \Lambda_w/T$. The *resilience functional* is its worst case over the manipulation set,

$$R(\mathcal{A}, \pi; \mathcal{W}) = \inf_{w \in \mathcal{W}} \frac{1}{T} \int_0^T \frac{Q(t; \mathcal{A}, \pi, w)}{Q_0} dt = 1 - \sup_{w \in \mathcal{W}} \frac{\Lambda_w}{T}, \quad (4.6)$$

and the resilience objective of Section 4.1 is $R \geq r_{\min}$. Writing Π_{AP} for the policies that satisfy the *autonomy constraint*, under which defenses do not covertly manipulate or coerce the protected population, and the *pluralism constraint*, under which dissent and unconventional belief are not treated as compromise, the design problem is

$$\max_{\pi \in \Pi_{AP}} R(\mathcal{A}, \pi; \mathcal{W}). \quad (4.7)$$

4.5.2 Properties of the Resilience Functional

The next result collects the properties that justify using R to compare designs. Throughout, $\mathcal{W}$ is nonempty and each $q_w(t) = Q(t; \mathcal{A}, \pi, w)/Q_0$ is measurable with values in $[0, Q_{\max}/Q_0]$.

Proposition 4.4 (Properties of the resilience functional). *The resilience functional satisfies the following.*

- (i) Bounds: $0 \leq R(\mathcal{A}, \pi; \mathcal{W}) \leq Q_{\max}/Q_0$, and if $Q \leq Q_0$ for all t and w , then $R \leq 1$ with equality if and only if $\sup_{w \in \mathcal{W}} \Lambda_w = 0$.

- (ii) Monotonicity in the manipulation set: if $\mathcal{W} \subseteq \mathcal{W}'$, then $R(\mathcal{A}, \pi; \mathcal{W}') \leq R(\mathcal{A}, \pi; \mathcal{W})$.
- (iii) Monotonicity in quality: if $Q(t; \mathcal{A}, \pi', w) \geq Q(t; \mathcal{A}, \pi, w)$ for all t and $w \in \mathcal{W}$, then $R(\mathcal{A}, \pi'; \mathcal{W}) \geq R(\mathcal{A}, \pi; \mathcal{W})$.
- (iv) Scale invariance: replacing Q by cQ and Q_0 by cQ_0 for a constant $c > 0$ leaves R unchanged.
- (v) Stability under measurement error: if $\hat{Q}$ satisfies $|\hat{Q}(t; w) - Q(t; w)| \leq \varepsilon$ for all t and w , then the functional $\hat{R}$ computed from $\hat{Q}$ with the same Q_0 satisfies $|\hat{R} - R| \leq \varepsilon/Q_0$.
- (vi) Randomized manipulations: if $\mathcal{W}$ is finite and the adversary may choose a probability distribution σ on $\mathcal{W}$, then $\inf_{\sigma} \sum_w \sigma(w) \bar{q}_w = R(\mathcal{A}, \pi; \mathcal{W})$.

Proof. For (i), $0 \leq q_w(t) \leq Q_{\max}/Q_0$ for all t , so integration over $[0, T]$ and division by T give $0 \leq \bar{q}_w \leq Q_{\max}/Q_0$ for each w , and the infimum of a nonempty set of numbers in an interval lies in that interval. If $Q \leq Q_0$, then $1 - q_w \geq 0$, so $\Lambda_w \geq 0$ and $\bar{q}_w = 1 - \Lambda_w/T \leq 1$; hence $R = 1 - \sup_w \Lambda_w/T \leq 1$, with equality exactly when $\sup_w \Lambda_w = 0$.

For (ii), each $\bar{q}_w$ with $w \in \mathcal{W}$ also belongs to $\{\bar{q}_w : w \in \mathcal{W}'\}$, and the infimum over a larger set is no larger.

For (iii), the hypothesis gives $q_w^{\pi'}(t) \geq q_w^{\pi}(t)$ for all t and w , so $\bar{q}_w^{\pi'} \geq \bar{q}_w^{\pi} \geq R(\mathcal{A}, \pi; \mathcal{W})$ for every w ; taking the infimum over w on the left gives the claim.

For (iv), $cQ(t; w)/(cQ_0) = Q(t; w)/Q_0$ for every t and w , so each $\bar{q}_w$, and hence the infimum, is unchanged.

For (v), for each w , $|\hat{q}_w - \bar{q}_w| \leq \frac{1}{T} \int_0^T |\hat{Q} - Q|/Q_0 dt \leq \varepsilon/Q_0$. Hence $\hat{q}_w \geq \bar{q}_w - \varepsilon/Q_0 \geq R - \varepsilon/Q_0$ for every w , so $\hat{R} \geq R - \varepsilon/Q_0$; exchanging the roles of Q and $\hat{Q}$ gives $R \geq \hat{R} - \varepsilon/Q_0$.

For (vi), for each distribution σ , $\sum_w \sigma(w) \bar{q}_w \geq \sum_w \sigma(w) R = R$, because each $\bar{q}_w \geq R$ and the weights sum to one; so the infimum over σ is at least R . The point mass at a minimizer w^* of $\bar{q}_w$, which exists because $\mathcal{W}$ is finite, attains $\bar{q}_{w^*} = R$, so the infimum equals R . $\square$

Part (ii) says that adding a scenario to a red-team plan can lower measured resilience but not raise it, so reported values are comparable only for the same manipulation set. Part (iv) lets decision quality be reported as a probability, a percentage, or a count per shift; the invariance does not extend to shifts $Q + b$, which move $\bar{q}_w$ toward 1 as b grows; for this reason an admissible function must have a meaningful zero. Part (v) bounds how far measurement error can distort R , and part (vi) says that randomizing over a finite manipulation set does not help an adversary lower time-averaged quality, although it matters for the tail measures of Section 4.6.

4.5.3 Where Loss Area Comes From

The metrics of Definition 4.10 are not independent levers. For the common trapezoidal shape, in which quality declines to a plateau, stays there until the

defender acts, and is restored linearly, the loss area is an explicit function of the other metrics.

Proposition 4.5 (Loss area of a trapezoidal curve). Suppose $q(t) = 1$ for $t \leq t_a$, q decreases linearly from 1 to $1 - \delta_{\max}$ on $[t_a, t_a + \tau_f]$ with $0 \leq \tau_f \leq \text{TTD}$, $q = 1 - \delta_{\max}$ on $[t_a + \tau_f, t_d]$, q increases linearly to 1 on $[t_d, t_r]$, and $q = 1$ on $[t_r, T]$. Then

$$\Lambda_w = \delta_{\max} \left(\text{TTD} - \frac{\tau_f}{2} + \frac{\text{TTR}}{2} \right), \quad \frac{\partial \Lambda_w}{\partial \text{TTD}} = \delta_{\max}, \quad \frac{\partial \Lambda_w}{\partial \text{TTR}} = \frac{\delta_{\max}}{2}. \quad (4.8)$$

Proof. The integrand $1 - q$ vanishes outside $[t_a, t_r]$. On the decline it rises linearly from 0 to $\delta_{\max}$ over τ_f , contributing the triangle area $\delta_{\max} \tau_f / 2$. On the plateau it equals $\delta_{\max}$ over $t_d - t_a - \tau_f = \text{TTD} - \tau_f$, contributing $\delta_{\max} (\text{TTD} - \tau_f)$. On the recovery it falls linearly from $\delta_{\max}$ to 0 over TTR, contributing $\delta_{\max} \text{TTR} / 2$. The sum is $\delta_{\max} (\text{TTD} - \tau_f / 2 + \text{TTR} / 2)$, and the derivatives follow because the expression is affine in TTD and TTR with $\delta_{\max}$ and τ_f held fixed. $\square$

Under linear restoration, an hour removed from time to detect is therefore worth two hours removed from time to recover, and an hour of time to act is worth as much as an hour of time to alert, although detection engineering typically reports only how quickly an alert is raised. The comparison is a statement about the trapezoid; the stochastic model of the next section treats it without assuming a shape.

Example 4.4 (Resilience metrics for the phishing-wave responses). We summarize the three responses of Example 4.3 over the 12-hour shift, with onset at hour 1, detection at the surge decision, and restoration tolerance $\epsilon_r = 0.01$. Integrating the curves of Figure 4.8 numerically gives Table 4.1; with the wave as the only manipulation, R equals the listed ratio. Acting at hour 3 rather than not at all reduces the loss area by 1.27 hours of nominal quality, and acting one hour earlier still raises R by a further 0.015, so the largest gain comes from acting at all before the wave subsides.

Table 4.1. Resilience metrics for the phishing-wave responses of Examples 4.3 and 4.4. Loss area is in hours of nominal decision quality over a 12-hour shift.

Response	Depth $\delta_{\max}$	TTD (h)	Restored at (h)	Loss area Λ_w (h)	$\bar{q}_w$
No surge	1.000	none	5.8	1.611	0.866
Surge at hour 3	0.286	2.0	4.3	0.346	0.971
Surge at hour 2	0.091	1.0	3.0	0.164	0.986

Cognitive Security in Practice: Alerts Raised but Not Acted On (Target, 2013)

In late 2013, attackers entered the network of the United States retailer Target, reportedly with credentials stolen from a heating, ventilation, and air-conditioning (HVAC) contractor, installed malware on point-of-sale

terminals, and removed payment card data and customer records. The Senate Commerce Committee majority staff report, which relied on media and expert analyses because the forensic examination was not complete, states, citing Bloomberg Businessweek, that the malware detection system raised alerts from November 30 and that the security team neither responded nor allowed automatic deletion [113, 114]. The report notes that the alert carried a generic label and could have been read as a false positive. Target learned of the breach from the Department of Justice on December 12 and announced on December 19 that about 40 million card accounts were affected (Figure 4.10). In the terms of this section, time to alert was short and the loss accumulated in time to act, about 12 days, so the case concerns attentional availability and calibrated trust in an alerting system at least as much as detection technology.

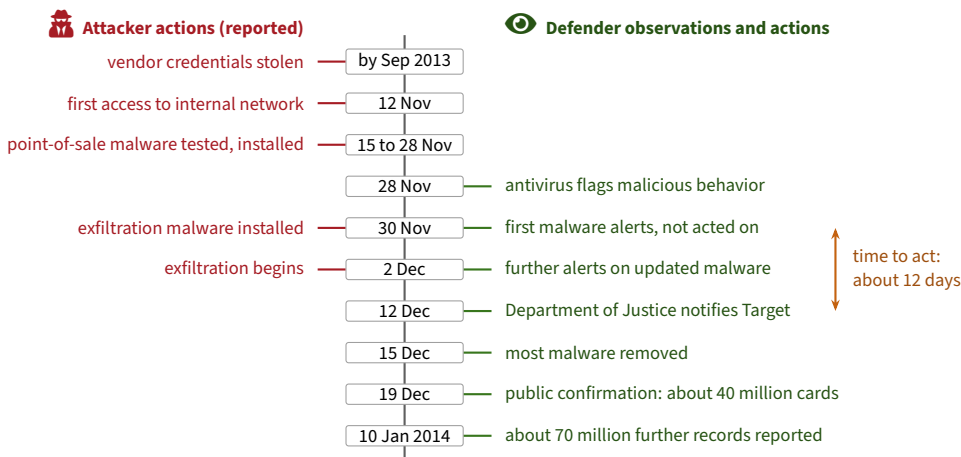


Figure 4.10. Timeline of the 2013 Target breach as summarized by the Senate Commerce Committee staff report: alerts were raised during the attack, but action followed external notification about 12 days later.

4.6 Stochastic and Risk-Averse Resilience

In operations, the onset, detection, and recovery times of a manipulation are random, so a defender must answer questions about averages, about the tail, and about adversaries who randomize over manipulations. This section models degradation and recovery as a continuous-time Markov chain, derives the expected loss area in closed form, measures the tail with conditional value-at-risk, and allocates effort between detection and recovery.

4.6.1 Markov Degradation and Recovery

We model the protected process after the onset of a manipulation as moving through a finite set of degraded states until it returns to nominal operation. The

absorbing-chain view of an attack in progress, before the harmful action occurs, is developed in [Chapter 3](#); here the chain describes the defender's side after the manipulation has begun to degrade decisions.

Definition 4.11 (Degradation-recovery chain). A *degradation-recovery chain* is a continuous-time Markov chain $(X_t)_{t \geq 0}$ on transient states $\{1, \dots, K\}$ and an absorbing state 0 (nominal operation). Its generator restricted to the transient states is the $K \times K$ sub-generator S , with nonnegative off-diagonal entries and row sums at most zero, and the chain starts from the row vector ξ of initial probabilities on the transient states. Each transient state k carries a *quality deficit* $\delta_k \in [0, 1]$, so that normalized decision quality is $q(t) = 1 - \delta_{X_t}$ with $\delta_0 = 0$. The *loss area* over $[0, T]$ is $\Lambda_T = \int_0^T \delta_{X_t} dt$, and $\Lambda_\infty = \int_0^\infty \delta_{X_t} dt$.

[Figure 4.11](#) draws the chain used in the examples. The process enters the *degraded* state D at onset, with deficit δ_D , while the manipulation is undetected. An alert that is acted on moves it at rate h_D to the *detected* state M, in which the response is being mobilized and quality has not yet improved. Mobilization moves it at rate h_M to the *recovering* state V, whose smaller deficit δ_V represents partially restored quality, and restoration returns it at rate h_V to the nominal state N. A later manipulation restarts the cycle.

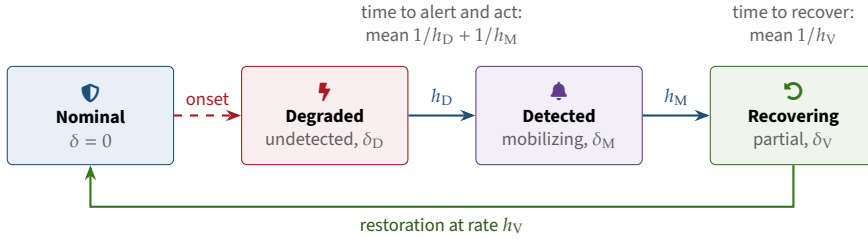


Figure 4.11. A degradation-recovery chain. Each transient state carries a quality deficit, and exponential holding times make the loss area a random variable whose mean and tail can be computed exactly.

Theorem 4.6 (Expected loss area of a degradation-recovery chain). Let $\delta = (\delta_1, \dots, \delta_K)^\top$. For every $T \geq 0$,

$$\mathbb{E}[\Lambda_T] = \xi \left(\int_0^T e^{St} dt \right) \delta. \quad (4.9)$$

If, in addition, from every transient state the chain is absorbed in state 0 with probability one and with finite expected absorption time, then S is invertible, $(-S)^{-1}$ has nonnegative entries,

$$\mathbb{E}[\Lambda_\infty] = \xi(-S)^{-1}\delta, \quad \mathbb{E}[\Lambda_T] = \xi(-S)^{-1}(I - e^{ST})\delta, \quad (4.10)$$

and the expected time-averaged quality over $[0, T]$ satisfies $\mathbb{E}[\bar{q}] = 1 - \mathbb{E}[\Lambda_T]/T \geq 1 - \mathbb{E}[\Lambda_\infty]/T$.

Proof. For a transient state k , the probability $\mathbb{P}(X_t = k)$ is the k th entry of ξe^{St} . This follows from the Kolmogorov forward equation restricted to transient states: the

row vector $\mathbf{p}(t) = (\mathbb{P}(X_t = 1), \dots, \mathbb{P}(X_t = K))$ satisfies $\mathbf{p}'(t) = \mathbf{p}(t)\mathbf{S}$ with $\mathbf{p}(0) = \boldsymbol{\xi}$, because the absorbing state has no transitions back into the transient states, and the unique solution is $\mathbf{p}(t) = \boldsymbol{\xi}e^{St}$. Since $\delta_{X_t} \geq 0$ and the map $(t, \omega) \mapsto \delta_{X_t(\omega)}$ is jointly measurable for a chain with right-continuous paths, Tonelli's theorem permits exchanging expectation and integral: $\mathbb{E}[\Lambda_T] = \int_0^T \mathbb{E}[\delta_{X_t}] dt = \int_0^T \mathbf{p}(t)\boldsymbol{\delta} dt = \boldsymbol{\xi}(\int_0^T e^{St} dt)\boldsymbol{\delta}$, which is (4.9).

For the second part, the (j, k) entry of $N_T = \int_0^T e^{St} dt$ is the expected time spent in transient state k during $[0, T]$ from j , which is nonnegative, nondecreasing in T , and at most the finite expected absorption time from j ; hence $N_\infty = \lim_{T \rightarrow \infty} N_T$ exists with finite nonnegative entries. Absorption with probability one gives $e^{ST} \rightarrow \mathbf{0}$, since each row sum of e^{ST} is the probability of not yet being absorbed, and integrating $\frac{d}{dt}e^{St} = \mathbf{S}e^{St}$ gives $\mathbf{S}N_T = e^{ST} - \mathbf{I}$. Letting $T \rightarrow \infty$ yields $\mathbf{S}N_\infty = -\mathbf{I}$, so $(-\mathbf{S})^{-1} = N_\infty \geq \mathbf{0}$. Then $\mathbb{E}[\Lambda_\infty] = \boldsymbol{\xi}N_\infty\boldsymbol{\delta}$ by monotone convergence, and multiplying $\mathbf{S}N_T = e^{ST} - \mathbf{I}$ on the left by $\mathbf{S}^{-1}$ gives $N_T = (-\mathbf{S})^{-1}(\mathbf{I} - e^{ST})$. The final inequality holds because $\Lambda_T \leq \Lambda_\infty$ pathwise. $\square$

For the chain of Figure 4.11, the theorem reduces to a formula that ties the loss area to the metrics of the resilience curve.

Corollary 4.7 (Time to detect and expected loss area). *For the series chain D, M, V with rates $h_D, h_M, h_V > 0$ started in D ,*

$$\mathbb{E}[\Lambda_\infty] = \frac{\delta_D}{h_D} + \frac{\delta_M}{h_M} + \frac{\delta_V}{h_V} = \delta_D \mathbb{E}[\text{time to alert and act}] + (\delta_M - \delta_D)\frac{1}{h_M} + \delta_V \mathbb{E}[\text{TTR}], \quad (4.11)$$

where $\mathbb{E}[\text{time to alert and act}] = \mathbb{E}[\text{TTD}] = 1/h_D + 1/h_M$.

Proof. The chain leaves each state once, so its holding times in D, M , and V are independent exponential random variables with means $1/h_D, 1/h_M, 1/h_V$, and Λ_∞ is the deficit-weighted sum of the holding times; linearity of expectation gives the first expression, which agrees with (4.10) because $(-\mathbf{S})^{-1}$ for the bidiagonal sub-generator has first row $(1/h_D, 1/h_M, 1/h_V)$. The second expression rearranges the first using $\mathbb{E}[\text{TTD}] = 1/h_D + 1/h_M$ and $\mathbb{E}[\text{TTR}] = 1/h_V$. $\square$

When the deficit does not change at the moment of detection, $\delta_M = \delta_D$ and (4.11) reads $\mathbb{E}[\Lambda_\infty] = \delta_D \mathbb{E}[\text{TTD}] + \delta_V \mathbb{E}[\text{TTR}]$: each expected hour of time to detect costs the full deficit, and each expected hour of time to recover costs only the residual deficit. This is the stochastic counterpart of Theorem 4.5, obtained without assuming a curve shape.

Example 4.5 (Markov recovery from a copilot manipulation). The problem is to compute the expected loss area, the expected time-averaged decision quality over a 24-hour horizon, and the tail of the loss area for a manipulation of the MERIDIAN SOC's AI triage copilot, and to compare two improvements. In this scenario an instruction hidden in a retrieved threat-intelligence document biases the copilot's auto-close suggestions, and analysts accept them. For this example we assume that SOC decision quality falls by 30% while the manipulation is undetected ($\delta_D = 0.30$), that the mean time until an analyst notices and escalates

is 6 hours ($h_D = 1/6$ per hour), that mobilizing the response takes a mean of 1 hour with unchanged deficit ($\delta_M = 0.30$, $h_M = 1$), and that restoring the copilot configuration and re-reviewing closed alerts takes a mean of 3 hours at half the deficit ($\delta_V = 0.15$, $h_V = 1/3$).

For the solution, [Theorem 4.7](#) gives $\mathbb{E}[\Lambda_\infty] = 0.30 \times 6 + 0.30 \times 1 + 0.15 \times 3 = 2.55$ hours of nominal quality. Over $T = 24$ hours, the expected occupation times from (4.10) are 5.89 hours in D, 0.98 hours in M, and 2.87 hours in V, so $\mathbb{E}[\Lambda_{24}] = 2.49$ and $\mathbb{E}[\bar{q}] = 1 - 2.49/24 = 0.896$, just above the bound $1 - 2.55/24 = 0.894$. The loss area Λ_∞ is a sum of independent exponential variables with means 1.8, 0.3, and 0.45 hours; its 95% quantile is 6.24 hours, and the mean loss area in the worst 5% of incidents is 8.04 hours. Halving the mean undetected time $1/h_D$, from 6 to 3 hours, lowers the expected loss area to 1.65 hours and the worst-5% mean to 4.58 hours. Halving the mean time to recover, from 3 to 1.5 hours, lowers them to 2.33 and 7.76 hours.

The conclusion is that the detection improvement is worth more in expectation, as [Theorem 4.7](#) predicts, and far more in the tail, because the long undetected sojourn dominates the variability of the loss.

4.6.2 Conditional Value-at-Risk of Decision Loss

The last example measured the tail by the mean of the worst 5% of outcomes. That quantity is the conditional value-at-risk, which has become a standard tail measure because it satisfies the axioms of coherent risk measures [115, 116] and because it admits a representation as a convex minimization [117, 118].

Definition 4.12 (Value-at-risk and conditional value-at-risk). Let L be a loss with $\mathbb{E}[L] < \infty$ and let $\alpha \in (0, 1)$. The *value-at-risk* at level α is the lower α -quantile $\text{VaR}_\alpha(L) = \min\{\zeta \in \mathbb{R} : \mathbb{P}(L \leq \zeta) \geq \alpha\}$. The *conditional value-at-risk* is

$$\text{CVaR}_\alpha(L) = \min_{\zeta \in \mathbb{R}} F_\alpha(\zeta), \quad F_\alpha(\zeta) = \zeta + \frac{1}{1-\alpha} \mathbb{E}[(L - \zeta)^+]. \quad (4.12)$$

The minimum in (4.12) is attained, and the next theorem identifies both the minimizer and the minimum value.

Theorem 4.8 (Rockafellar-Uryasev representation). Let L be integrable and $\alpha \in (0, 1)$, and write $v = \text{VaR}_\alpha(L)$. Then F_α is convex and finite on $\mathbb{R}$, v minimizes F_α , and

$$\text{CVaR}_\alpha(L) = \frac{1}{1-\alpha} \left(\mathbb{E}[L \mathbb{1}\{L > v\}] + v(\mathbb{P}(L \leq v) - \alpha) \right). \quad (4.13)$$

If $\mathbb{P}(L = v) = 0$, this equals $\mathbb{E}[L \mid L \geq v]$. Moreover $\text{CVaR}_\alpha(L) \geq \max\{\text{VaR}_\alpha(L), \mathbb{E}[L]\}$, and $\text{CVaR}_\alpha(L)$ is nondecreasing in α .

Proof. Let $g(\zeta) = \mathbb{E}[(L - \zeta)^+]$. Since $0 \leq (L - \zeta)^+ \leq |L| + |\zeta|$, g is finite, and it is convex because $\zeta \mapsto (L - \zeta)^+$ is convex for each outcome and expectation preserves convexity; hence F_α is finite and convex.

We compute one-sided derivatives of g . For $\eta > 0$, the difference quotient $((L - \zeta - \eta)^+ - (L - \zeta)^+)/\eta$ lies in $[-1, 0]$ and converges, as $\eta \downarrow 0$, to -1 on $\{L > \zeta\}$ and to 0 on $\{L \leq \zeta\}$. By dominated convergence, the right derivative is

$g'_+(\zeta) = -\mathbb{P}(L > \zeta)$. Similarly, $((L - \zeta + \eta)^+ - (L - \zeta)^+)/\eta$ lies in $[0, 1]$ and converges to 1 on $\{L \geq \zeta\}$ and to 0 on $\{L < \zeta\}$, so the left derivative is $g'_-(\zeta) = -\mathbb{P}(L \geq \zeta)$. Therefore

$$F'_{\alpha,+}(\zeta) = 1 - \frac{\mathbb{P}(L > \zeta)}{1 - \alpha}, \quad F'_{\alpha,-}(\zeta) = 1 - \frac{\mathbb{P}(L \geq \zeta)}{1 - \alpha}.$$

A finite convex function on $\mathbb{R}$ attains its minimum at ζ if and only if $F'_{\alpha,-}(\zeta) \leq 0 \leq F'_{\alpha,+}(\zeta)$, that is, if and only if $\mathbb{P}(L > \zeta) \leq 1 - \alpha \leq \mathbb{P}(L \geq \zeta)$, equivalently $\mathbb{P}(L \leq \zeta) \geq \alpha$ and $\mathbb{P}(L < \zeta) \leq \alpha$. The quantile v satisfies the first condition by definition; the minimum in the definition of v exists because the distribution function is right-continuous and tends to 0 at $-\infty$ and to 1 at $+\infty$. For the second, $\mathbb{P}(L < v) = \lim_{\eta \downarrow 0} \mathbb{P}(L \leq v - \eta) \leq \alpha$, because each $\mathbb{P}(L \leq v - \eta) < \alpha$ by minimality of v . Hence v minimizes F_α .

Evaluating at v , $\mathbb{E}[(L - v)^+] = \mathbb{E}[L \mathbb{1}\{L > v\}] - v\mathbb{P}(L > v)$, so

$$F_\alpha(v) = \frac{1}{1 - \alpha} \left((1 - \alpha)v + \mathbb{E}[L \mathbb{1}\{L > v\}] - v(1 - \mathbb{P}(L \leq v)) \right),$$

which simplifies to (4.13). If $\mathbb{P}(L = v) = 0$, then right-continuity and the second optimality condition give $\mathbb{P}(L \leq v) = \mathbb{P}(L < v) = \alpha$, so $\mathbb{P}(L \geq v) = 1 - \alpha$ and (4.13) becomes $\mathbb{E}[L \mathbb{1}\{L \geq v\}]/\mathbb{P}(L \geq v) = \mathbb{E}[L | L \geq v]$.

For the bounds, $F_\alpha(\zeta) \geq \zeta$ for every ζ , and $F_\alpha(v) \geq v$ gives $\text{CVaR}_\alpha \geq \text{VaR}_\alpha$. By Jensen's inequality, $g(\zeta) \geq (\mathbb{E}[L] - \zeta)^+$, so for $\zeta \geq \mathbb{E}[L]$, $F_\alpha(\zeta) \geq \zeta \geq \mathbb{E}[L]$, and for $\zeta < \mathbb{E}[L]$, $F_\alpha(\zeta) \geq \zeta + (\mathbb{E}[L] - \zeta)/(1 - \alpha) \geq \zeta + (\mathbb{E}[L] - \zeta) = \mathbb{E}[L]$; hence the minimum is at least $\mathbb{E}[L]$. Finally, for each ζ , $F_\alpha(\zeta)$ is nondecreasing in α because $g(\zeta) \geq 0$, and a pointwise nondecreasing family has nondecreasing minima. $\square$

For a discrete loss, (4.13) counts the mass above the quantile in full and the atom at the quantile only as needed to fill the tail mass $1 - \alpha$. The representation (4.12) makes CVaR usable in design, since minimizing it over a policy becomes a joint minimization over the policy and ζ that is convex whenever the loss is convex in the policy.

Example 4.6 (Comparing two training programs by CVaR of decision loss). The problem is to compare two security-awareness programs by the monthly number of credential submissions, a decision loss at level L1. From the MERIDIAN specification, 600 phishing messages reach inboxes each month and the click rate after annual training with quarterly simulations is 4%. For this example we assume that in 10% of months a targeted campaign adds 150 well-crafted messages; that program A, the simulation-centered program of the specification, yields click rates of 4% on ordinary and 30% on targeted messages; and that program B, which emphasizes verification procedures and reporting of unusual requests, yields 5% on ordinary and 12% on targeted messages. Clicks are independent given the month type, so the monthly loss is a mixture of binomial counts.

For the solution, the expected monthly losses are $600 \times 0.04 + 0.1 \times 150 \times 0.30 = 28.5$ for A and $600 \times 0.05 + 0.1 \times 150 \times 0.12 = 31.8$ for B, so A is better on average. Computing the exact distributions, $\text{VaR}_{0.95}$ is 69 for A and 48 for B, and (4.13) gives $\text{CVaR}_{0.95} = 74.9$ for A and 53.3 for B. Direct minimization of $F_{0.95}$ over integer ζ returns the same values, attained at $\zeta = 69$ and $\zeta = 48$, as Theorem 4.8 requires.

At $\alpha = 0.80$ the values are 50.7 and 43.8. Figure 4.12 shows the two distributions with their tail measures.

The conclusion is that program A minimizes expected loss while program B reduces the mean of the worst 5% of months by 29%; an organization whose losses are driven by targeted campaigns, as payment fraud losses often are, should prefer B, and the choice between them is a statement of risk attitude that the expected click rate cannot express.

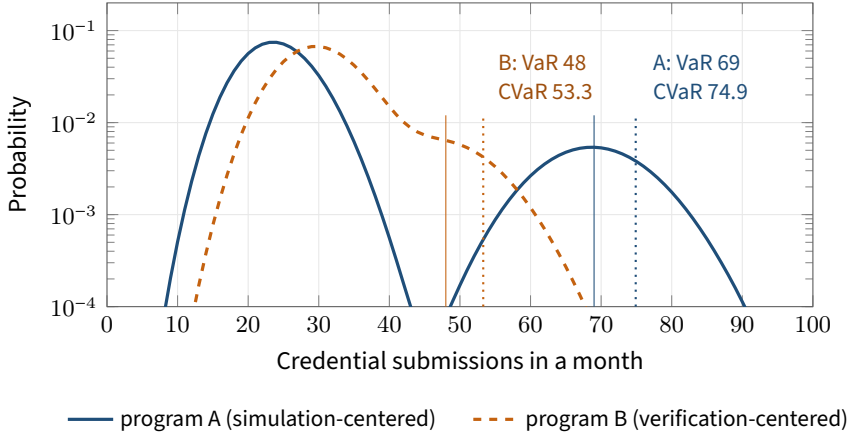


Figure 4.12. Monthly distributions of credential submissions in Example 4.6, on a logarithmic scale. The second hump of each distribution corresponds to the targeted months. Program A has the lower mean but the heavier tail; thin lines mark $\text{VaR}_{0.95}$ and dotted lines $\text{CVaR}_{0.95}$.

4.6.3 Worst Case Over a Manipulation Set

The resilience functional of (4.6) takes a worst case over manipulations of a time average. With random loss areas, the defender can choose between a worst case of expected loss and a worst case of tail loss, and the adversary can randomize over manipulations. Let $\mathcal{W}$ be finite, let Λ_w denote the random loss area over $[0, T]$ under manipulation w , and for a distribution σ on $\mathcal{W}$ let Λ_σ be the loss area when w is first drawn from σ .

Definition 4.13 (Expected and risk-averse resilience). The *expected resilience* and the *risk-averse resilience* at level $\alpha \in (0, 1)$ are

$$R^{\mathbb{E}}(\mathcal{A}, \pi; \mathcal{W}) = 1 - \sup_{w \in \mathcal{W}} \mathbb{E}[\Lambda_w]/T, \quad R^\alpha(\mathcal{A}, \pi; \mathcal{W}) = 1 - \sup_{\sigma \in \Delta(\mathcal{W})} \text{CVaR}_\alpha(\Lambda_\sigma)/T,$$

where $\Delta(\mathcal{W})$ is the set of probability distributions on $\mathcal{W}$.

Proposition 4.9 (Risk-averse resilience). For finite $\mathcal{W}$ and integrable loss areas: (i) $R^\alpha \leq R^{\mathbb{E}}$; (ii) R^α is nonincreasing in α ; (iii) if $\mathcal{W} \subseteq \mathcal{W}'$, then $R^\alpha(\mathcal{A}, \pi; \mathcal{W}') \leq R^\alpha(\mathcal{A}, \pi; \mathcal{W})$; and (iv) $R^\alpha \leq 1 - \max_{w \in \mathcal{W}} \text{CVaR}_\alpha(\Lambda_w)/T$, where the inequality can be strict, so that randomization over manipulations can lower risk-averse resilience below its value against every single manipulation.

Proof. For (i), [Theorem 4.8](#) gives $\text{CVaR}_\alpha(\Lambda_\sigma) \geq \mathbb{E}[\Lambda_\sigma]$ for each σ , and taking σ to be the point mass at a maximizer of $\mathbb{E}[\Lambda_w]$ shows $\sup_\sigma \text{CVaR}_\alpha(\Lambda_\sigma) \geq \max_w \mathbb{E}[\Lambda_w]$. For (ii), $\text{CVaR}_\alpha(\Lambda_\sigma)$ is nondecreasing in α for each σ by [Theorem 4.8](#), so its supremum is too. For (iii), $\Delta(\mathcal{W})$ embeds in $\Delta(\mathcal{W}')$ by assigning zero mass to $\mathcal{W}' \setminus \mathcal{W}$, and the supremum over a larger set is no smaller. For (iv), point masses belong to $\Delta(\mathcal{W})$, which gives the inequality. For strictness, let $T = 24$ hours and $\alpha = 0.9$, let w_1 produce a loss area of 10 hours with probability 0.06 and none otherwise, and let w_2 produce 5.5 hours surely. By (4.13), $\text{CVaR}_{0.9}(\Lambda_{w_1}) = (0.6 + 0 \times (0.94 - 0.9))/0.1 = 6$ and $\text{CVaR}_{0.9}(\Lambda_{w_2}) = 5.5$. Under the even mixture, Λ_σ equals 10 with probability 0.03, 5.5 with probability 0.5, and 0 with probability 0.47, so $\text{VaR}_{0.9} = 5.5$ and $\text{CVaR}_{0.9}(\Lambda_\sigma) = (0.3 + 5.5 \times (0.97 - 0.9))/0.1 = 6.85 > 6$. Hence $R^{0.9} \leq 1 - 6.85/24 = 0.715 < 0.75 = 1 - 6/24$. $\square$

Unlike part (vi) of [Theorem 4.4](#) for time averages, part (iv) says that a red-team plan evaluating manipulations one at a time can overstate risk-averse resilience, because a mixture of a rare severe manipulation and a certain moderate one has a heavier tail than either.

4.6.4 Allocating Effort Between Detection and Recovery

[Theorem 4.7](#) makes the expected loss area a sum of deficit-weighted mean durations, which turns the allocation of a response budget into an explicit optimization. Consider a two-phase version with deficit δ_D until detection at rate h_D and deficit δ_V during recovery at rate h_V , and suppose that raising a rate costs a constant amount per unit, c_D and c_V , within a budget B .

Proposition 4.10 (Square-root allocation). *Let $\delta_D, \delta_V, c_D, c_V, B > 0$. The problem of minimizing $\mathbb{E}[\Lambda_\infty] = \delta_D/h_D + \delta_V/h_V$ over $h_D, h_V > 0$ subject to $c_D h_D + c_V h_V = B$ has the unique solution*

$$h_k^* = \frac{B}{\sqrt{\delta_D c_D} + \sqrt{\delta_V c_V}} \sqrt{\frac{\delta_k}{c_k}}, \quad k \in \{D, V\}, \quad \min \mathbb{E}[\Lambda_\infty] = \frac{(\sqrt{\delta_D c_D} + \sqrt{\delta_V c_V})^2}{B}. \quad (4.14)$$

The optimal share of the budget spent on detection is $s^* = \sqrt{\delta_D c_D} / (\sqrt{\delta_D c_D} + \sqrt{\delta_V c_V})$, and the expected loss area is strictly convex in the detection share.

Proof. For feasible h_D, h_V , the Cauchy-Schwarz inequality applied to the vectors $(\sqrt{\delta_D/h_D}, \sqrt{\delta_V/h_V})$ and $(\sqrt{c_D h_D}, \sqrt{c_V h_V})$ gives

$$\left(\frac{\delta_D}{h_D} + \frac{\delta_V}{h_V} \right) (c_D h_D + c_V h_V) \geq (\sqrt{\delta_D c_D} + \sqrt{\delta_V c_V})^2,$$

with equality if and only if the vectors are proportional, that is, $\sqrt{\delta_k/h_k} = \theta \sqrt{c_k h_k}$ for a common $\theta > 0$, or $h_k = \theta^{-1} \sqrt{\delta_k/c_k}$. Since the second factor equals B , the objective is at least $(\sqrt{\delta_D c_D} + \sqrt{\delta_V c_V})^2/B$, and the budget constraint determines $\theta^{-1} = B/(\sqrt{\delta_D c_D} + \sqrt{\delta_V c_V})$, which gives (4.14) and uniqueness. With detection share $s \in (0, 1)$, $h_D = sB/c_D$ and $h_V = (1-s)B/c_V$, so the objective is $\delta_D c_D/(sB) + \delta_V c_V/((1-s)B)$, whose second derivative $2\delta_D c_D/(s^3 B) + 2\delta_V c_V/((1-s)^3 B)$ is positive; the share $s^* = c_D h_D^*/B$ follows from (4.14). $\square$

The allocation weights each phase by the square root of its deficit times its unit cost, so a phase that is expensive to accelerate also receives more budget. For the copilot scenario of [Example 4.5](#), with $\delta_D = 0.30$, $\delta_V = 0.15$, and baseline rates $h_D = 1/6$ and $h_V = 1/3$ per hour, assume unit costs $c_D = 6$ and $c_V = 2$ in a common budget unit, so that the baseline spends $B = 5/3$ with a detection share of 0.60 and an expected two-phase loss area of 2.25 hours. [Theorem 4.10](#) gives $s^* = 0.71$, mean times of 5.07 hours to detect and 4.14 hours to recover, and a loss area of 2.14 hours. [Figure 4.13](#) shows the convex trade-off and the steep penalty of neglecting either phase.

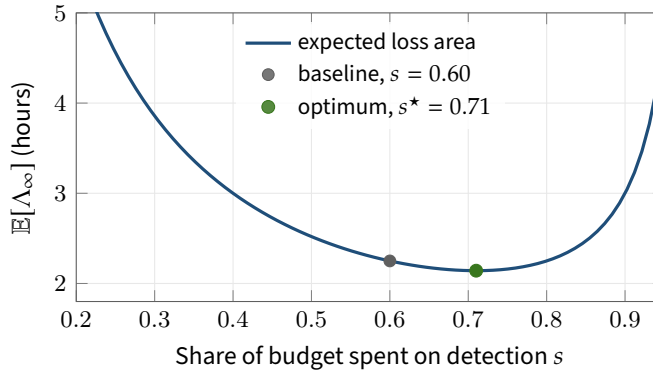


Figure 4.13. Expected loss area against the detection share of a fixed response budget for the copilot scenario. The curve is convex with its minimum at the square-root allocation of [Theorem 4.10](#); loss rises steeply when either detection or recovery is starved.

Resilience measured this way also closes the loop to the Adapt phase: each incident yields estimates of δ_k and h_k , and re-solving (4.14) with updated estimates is a quantitative form of learning from incidents.

4.7 Measurement Validity

The properties proved so far hold for the quantities as defined; whether a number reported by a security program is such a quantity is the question of validity. A click rate may be reliable and still fail to measure susceptibility, and a drop in time to detect after a new tool may be real and still not have been caused by the tool; this section organizes such failures and then examines what happens when a proxy becomes a target.

4.7.1 Four Kinds of Validity

Shadish, Cook, and Campbell distinguish four kinds of validity for causal inferences drawn from data [119]. *Statistical conclusion validity* concerns whether the data support the inference that two variables covary, and how strongly; its threats include low statistical power, violated test assumptions, and unreliable measures. *Internal validity* concerns whether an observed covariation reflects a causal relation from treatment to outcome, as opposed to selection, history, maturation, or regression toward the mean. *Construct validity* concerns whether

the operations used in a study represent the constructs they are named for; the classical formulation treats a construct as defined by its place in a network of lawful relations with other constructs and observables [120], and a later unified view extends validity to the consequences of score interpretation and use [121]. *External validity* concerns whether a causal relation holds across variations in persons, settings, treatments, and outcomes.

For cognitive security, two further properties belong on the same list because the measured environment contains an adversary and the measured subjects are people. *Adversarial robustness* asks whether a measured effect persists when the attacker adapts to the defense. *Measurement invariance* asks whether a score means the same thing across roles, languages, and cultures; a phishing-recognition score can reflect local email conventions rather than a general capacity. Figure 4.14 arranges the properties as a ladder, each rung presupposing those below it, with a characteristic threat in cognitive security at each rung.

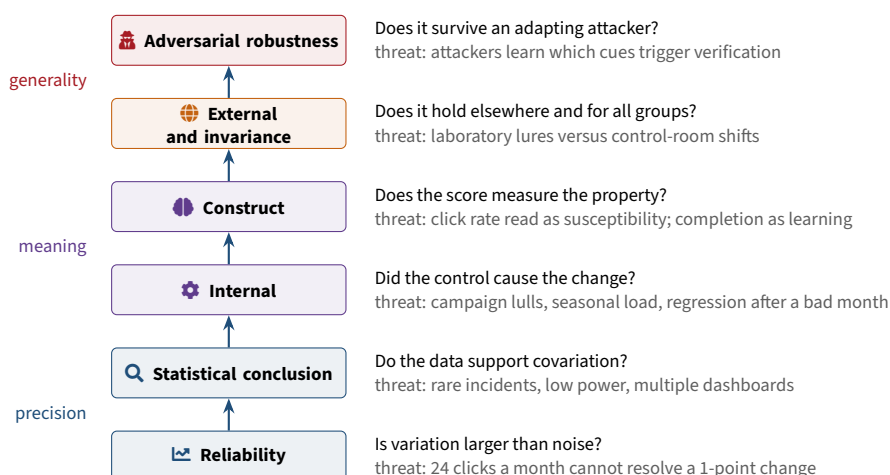


Figure 4.14. The validity ladder for cognitive-security metrics. Each rung presupposes the rungs below it: a metric that is not reliable cannot support a causal claim, and a causal claim about the wrong construct cannot generalize. Gray text gives a characteristic threat at each rung.

The bottom rungs are often the binding ones in practice because cognitive-security outcomes are rare. At MERIDIAN, 600 phishing messages reach inboxes each month. A two-sided test at the 5% level with 80% power needs about 5,300 messages in each arm to distinguish a click rate of 4% from one of 3%, which is roughly nine months of MERIDIAN's delivered phishing per arm; a quarterly dashboard showing a one-point improvement cannot, by itself, support the claim that the program worked. The same arithmetic applies more strongly to true security incidents, which are rarer still, and it is one reason why decision-quality functions defined on frequent decisions, such as triage within deadline, are easier to validate than functions defined on rare losses.

Internal validity is threatened by the structure of adversarial environments. Attack volume varies with campaigns that the defender does not control, so a

before-and-after comparison around a new control confounds the control with the campaign calendar. Regression toward the mean is a specific hazard: programs are often introduced after an unusually bad month, and the following month tends to look better whatever was done. Randomized rollout across teams, interrupted time series with comparison groups, and stepped-wedge designs address these threats where randomization of whole units is feasible.

4.7.2 Proxies and Their Failure Under Pressure

Most operational metrics are proxies: the click rate stands in for susceptibility, report counts for vigilance, and mean time to detect for detection capability. A proxy is useful under the conditions in which its correlation with the property was observed, and using it to manage behavior changes those conditions, the observation associated with Goodhart, Strathern, and Campbell [122, 123, 124]. Manheim and Garrabrant separate four mechanisms: regressional, in which selecting on a noisy proxy overstates the true value; extremal, in which the relation between proxy and target changes in regions far from where it was observed; causal, in which intervening on the proxy does not move the target; and adversarial, in which agents exploit the proxy [125]. The first admits an exact statement.

Proposition 4.11 (Regressional proxy failure). *Let the true decision quality of a unit be $Q \sim \mathcal{N}(m, \sigma_Q^2)$ and its proxy score be $Y = Q + \varepsilon$ with $\varepsilon \sim \mathcal{N}(0, \sigma_\varepsilon^2)$ independent of Q , where $\sigma_Q^2 > 0$. Then*

$$\mathbb{E}[Q | Y = y] = m + \beta(y - m), \quad \beta = \frac{\sigma_Q^2}{\sigma_Q^2 + \sigma_\varepsilon^2} \in (0, 1], \quad (4.15)$$

so a unit selected for its proxy score $y > m$ has expected true quality below its score by $(1 - \beta)(y - m)$, a gap that grows linearly with the score and with the noise share $1 - \beta$.

Proof. The pair (Q, Y) is jointly Gaussian because it is a linear image of the independent Gaussian pair (Q, ε) . Let $Z = Q - \beta Y$. Then $\text{Cov}(Z, Y) = \text{Cov}(Q, Q + \varepsilon) - \beta \text{Var}(Y) = \sigma_Q^2 - \beta(\sigma_Q^2 + \sigma_\varepsilon^2) = 0$. The pair (Z, Y) is jointly Gaussian, being a linear image of (Q, ε) , and uncorrelated jointly Gaussian variables are independent, so $\mathbb{E}[Z | Y] = \mathbb{E}[Z] = m - \beta m$. Hence $\mathbb{E}[Q | Y] = \mathbb{E}[Z + \beta Y | Y] = (1 - \beta)m + \beta Y$, which is (4.15). The gap $y - \mathbb{E}[Q | Y = y] = (1 - \beta)(y - m)$ follows by subtraction, and $\beta \leq 1$ because $\sigma_\varepsilon^2 \geq 0$. $\square$

The proposition explains a familiar disappointment: the team with the best phishing-simulation score in one quarter tends to look ordinary in the next, and awarding it the lightest training load on the strength of one score allocates effort by noise. The other three mechanisms have no equally compact statement, but the adversarial one is the most important in security, because the population being measured includes both staff who respond to incentives and attackers who respond to defenses.

Example 4.7 (A report-rate target at MERIDIAN). The problem is to evaluate a proposal to reward departments for raising the rate at which staff report suspicious email. From the MERIDIAN specification, 600 phishing messages reach inboxes each month, 45% of them are reported after training, and 2.5 million messages arrive each month in total. For this example we assume that before the incentive one benign message in 10,000 is reported, that the incentive raises the phishing report rate to 50% and the benign report probability to 6 in 10,000, and that each report takes a Tier-1 analyst 4 minutes to close.

For the solution, before the incentive staff report $0.45 \times 600 = 270$ phishing and $2.5 \times 10^6 \times 10^{-4} = 250$ benign messages a month, a precision of $270/520 = 0.52$ and about 35 analyst-hours of triage. After it they report 300 phishing and 1,500 benign messages, a precision of $300/1,800 = 0.17$ and 120 analyst-hours. The proxy rose by 11%; the fraction of reports that point to a real threat fell by two-thirds, and the added 85 analyst-hours a month come from the same Tier-1 capacity that [Example 4.3](#) showed to be the constraint during a phishing wave. [Figure 4.15](#) traces the two quantities as the incentive strengthens.

The conclusion is that the report rate is a valid proxy for vigilance only while it is not a target; a decision-quality function that scores reports by what they reveal, such as the number of true phishing reports received within an hour of delivery, resists this failure better.

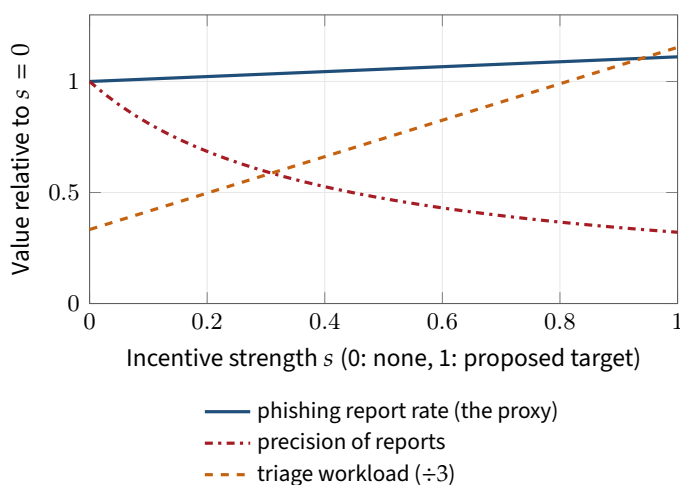


Figure 4.15. Proxy divergence in [Example 4.7](#), with the report rate and the benign report probability rising linearly in the incentive strength. The proxy improves by 11% while the precision of reports falls to about a third of its initial value and the triage workload, plotted at one third of scale, grows by a factor of 3.5.

A program should also say which kind of evidence, from replicated experiments to practitioner frameworks and scenarios, supports each claim about a measure. Evaluation methods that produce the stronger kinds of evidence, including red teaming and cognitive digital twins, are the subject of Chapter 21.

4.8 Ethics and Limits

Measurement is itself an intervention, and the metrics of this chapter can cause harm through misuse against the people measured, through surveillance, and through the choice of what counts as good decision quality.

4.8.1 Metric Misuse

The first harm is the use of aggregate security metrics as judgments of individuals. Click rates in simulated phishing, report counts, and triage speeds are designed to evaluate programs and architectures, and the validity analysis of [Section 4.7](#) shows that they are weak instruments for individuals: counts are small, lures differ in difficulty, and scores regress toward the mean. The base rate compounds the problem. If 1% of staff in a period are acting under manipulation, and an indicator flags such staff with probability 0.90 while flagging others with probability 0.05, then by Bayes' rule only $0.90 \times 0.01 / (0.90 \times 0.01 + 0.05 \times 0.99) = 15\%$ of flagged staff are in fact manipulated. A program that feeds such flags into performance reviews punishes mostly ordinary variation, teaches staff to avoid reporting their own mistakes, and so degrades the accountability and calibrated trust it was meant to protect. The simulated phishing on which many of these metrics rest also deceives employees by design, and ethical analyses of such studies ask for proportionate deception, debriefing, and protections for participants [126, 127].

4.8.2 Surveillance Through Measurement

The second harm is surveillance. [Figure 4.16](#) orders the data from which decision quality can be computed by intrusiveness; moving right buys finer signals at the price of privacy, chilling effects on legitimate dissent, and a data store valuable to an adversary. Workflow events such as provenance breaks, bypassed approvals, and decision latency can be observed without a claim about what someone believes, and they are auditable and contestable in ways that inferred mental states are not.

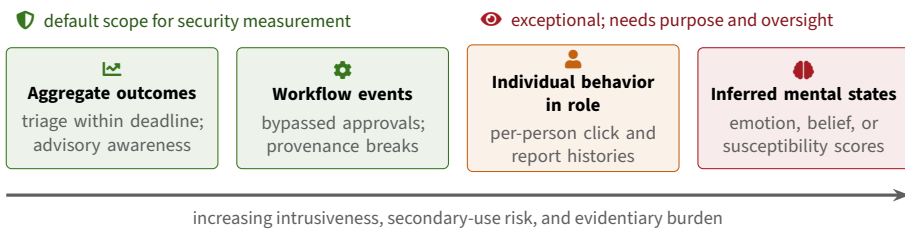


Figure 4.16. The scope of cognitive-security measurement. Sources to the left support most of the objectives of this chapter with little intrusion; sources to the right add privacy harm, chilling effects, and misuse risk, and require a stated protective purpose, minimization, and independent oversight.

Legitimate measurement requires a stated protective purpose, minimal collection and retention, aggregate reporting where the decision concerns an architecture, transparency and a right to contest classifications, and separation from

employment decisions; staff who trust the purpose also report more honestly, which improves the data.

4.8.3 Pluralism and the Choice of Decision Quality

The third harm is subtler. The resilience functional rewards whatever the decision-quality function scores, and at the societal level it is tempting to score agreement with an official position. Condition (iii) of [Definition 4.9](#) rules this out by restricting decision quality to beliefs and actions with a ground truth relevant to safety, such as whether a boil-water advisory applies, and the pluralism constraint in (4.7) forbids policies that treat dissent or unconventional belief as compromise. The restrictions leave judgment about what counts as settled fact with people who can be wrong, but they make that judgment explicit, reviewable, and narrow. Likewise, the formulation can state but not enforce the exclusion of covert nudging, so the feasible set Π_{AP} has to be defined by governance processes outside the mathematics.

4.8.4 Limits of the Formal Measures

Several limits follow from the models themselves. The resilience functional averages over time and so treats a short deep failure and a long shallow one as equal when their areas match, although an irreversible harm during the deep failure may matter far more; the tail measures of [Section 4.6](#) and explicit constraints on depth address this only in part. The Markov model assumes exponential holding times and a fixed state structure, whereas adversaries adapt their timing to the defender. Worst cases are taken over a manipulation set that analysts choose, and an unanticipated manipulation lies outside every guarantee proved here. Finally, the objectives are stated for a single protected decision process, while real incidents cross levels, and aggregating decision quality across levels requires value judgments that this chapter has deliberately not made.

4.9 Summary

This chapter stated what cognitive defenses should achieve and how achievement can be measured. Because classical security properties can hold while a decision is subverted, we defined six objectives for a protected decision process (cognitive integrity, autonomy, attentional availability, calibrated trust, accountability, and resilience), each with a measurable form. The objectives conflict, and the vigilance-fatigue model showed that the loss-minimizing level of scrutiny lies strictly inside the feasible range.

Cognitive risk factors into attempt rate, exposure, susceptibility, conversion, and consequence, so expected loss is multiplicative in the factors while its variance depends on the second moment of consequence. A click rate measures only part of this chain, and risk matrices compress it further and can reverse rankings.

Decision quality $Q(t)$ was operationalized at each level of the Cognitive Security Stack. Its trajectory through an incident defines depth, time to alert, time to act, time to recover, and loss area, and the resilience functional R , the worst case of time-averaged quality over a manipulation set, was shown to be bounded,

monotone, scale invariant, stable under measurement error, and unaffected by randomized manipulations. The Target breach illustrated why time to detect should be reported in its two parts.

With random durations, the expected loss area of a degradation-recovery chain has a closed form, conditional value-at-risk measures its tail, randomization over manipulations can make that tail heavier, and a square-root rule allocates a budget between detection and recovery. These numbers are meaningful only when they are valid; proxies fail under optimization pressure, and measurement carries risks of misuse and surveillance that bound its legitimate use.

Exercises

Exercise 4.1 [C] Describe a MERIDIAN scenario in which a manipulation leaves the integrity loss of [Definition 4.2](#) equal to zero but violates autonomy ([Definition 4.3](#)), and a second scenario in which the reverse holds. For beliefs $b^{\text{ref}} = (0.7, 0.2, 0.1)$ and $\tilde{b} = (0.4, 0.5, 0.1)$ over three hypotheses, compute the total variation distance and name the event whose probability changes most.

Exercise 4.2 [C] An analyst uses an AI copilot in three contexts with frequencies 0.5, 0.3, and 0.2. The copilot is correct with probabilities 0.95, 0.70, and 0.40, and the analyst's trust is 0.90, 0.90, and 0.80. Compute Γ , Γ^+ , and Γ^- of [Definition 4.5](#). Which intervention, and in which context, would reduce the gap most, and why would a generic warning to "trust the copilot less" be a poor choice?

Exercise 4.3 [A] Replace [Assumption 4.1](#) by $s(v) = s_0(1 - \phi v^2)$ with $\phi \in (0, 1)$. Show that $J(v) = \rho C_M(1 - s_0 v + s_0 \phi v^3) + cv$ is convex on $[0, 1]$, derive the minimizer, and evaluate it for the values of [Example 4.1](#) with $\phi = 0.8$. Compare with the linear-fatigue result.

Exercise 4.4 [A] For deepfake-supported payment fraud at MERIDIAN, suppose attempts arrive at 20 per year and $e\psi\kappa = 0.03$, and that the consequence is \$400,000 with probability 0.9 and \$4.8 million with probability 0.1. Use [Theorem 4.2](#) to compute the mean and standard deviation of annual loss, and the probability of at least one harmful action in a year. Explain why a risk register that records only the mean consequence misstates this risk.

Exercise 4.5 [C] For a five-by-five matrix with equal likelihood and consequence bins and product scoring, list all pairs of cells with different scores for which [Theorem 4.3](#) guarantees a ranking reversal, and all pairs for which no reversal is possible. What fraction of pairs admits a reversal?

Exercise 4.6 [A] Finance staff classify bank-detail change requests with base rate $\rho = 0.02$, miss cost $C_M = \$300,000$, and false-alarm cost $C_F = \$6$ (a callback). Training moves (P_D, P_{FA}) from $(0.80, 0.05)$ to $(0.90, 0.30)$. Compute Q_1 from [\(4.4\)](#) before and after. Repeat with $C_F = \$600$, and explain what the comparison says about reporting the detection rate alone.

Exercise 4.7 [A] Show by example that replacing Q by $Q + b$ and Q_0 by $Q_0 + b$ for $b > 0$ can change the ranking of two policies by R . Then show that the bound in part (v) of [Theorem 4.4](#) is attained for a suitable $\hat{Q}$.

Exercise 4.8 [A] Model the Target timeline of Figure 4.10 as a trapezoid with a decline of 2 days, time to alert of 0.5 days, time to act of 12 days, time to recover of 3 days, and depth 0.8 in a suitable decision-quality function. Compute the loss area with Theorem 4.5, and compare the reductions from halving time to alert, halving time to act, and halving time to recover. State which assumptions of the proposition are least plausible for this case.

Exercise 4.9 [A] Extend the chain of Example 4.5 so that the recovering state V is left at total rate $1/3$ per hour, returning to nominal with probability 0.8 and to the degraded state D with probability 0.2 (an incomplete clean-up). Write the sub-generator, compute $\mathbb{E}[\Lambda_\infty]$ with Theorem 4.6, and interpret the increase relative to 2.55 hours. For the original chain, solve the forward equation $p'_M = h_D p_D - h_M p_M$ to show that the expected time spent in M during $[0, T]$ is $\frac{h_D}{h_M - h_D} \left(\frac{1 - e^{-h_D T}}{h_D} - \frac{1 - e^{-h_M T}}{h_M} \right)$ for $h_D \neq h_M$, and check the value 0.98 hours at $T = 24$.

Exercise 4.10 [A] Show that $\sigma \mapsto \text{CVaR}_\alpha(\Lambda_\sigma)$ is concave on $\Delta(\mathcal{W})$ by using the representation (4.12). Deduce that $\text{CVaR}_\alpha(\Lambda_\sigma) \geq \sum_w \sigma(w) \text{CVaR}_\alpha(\Lambda_w)$, and find the distribution σ that maximizes $\text{CVaR}_{0.9}$ for the two manipulations in the proof of Theorem 4.9.

Exercise 4.11 [A] Generalize Theorem 4.10 to K phases with deficits δ_k , unit costs c_k , and budget B , and prove the result. Apply it to the three-state chain of Example 4.5 with unit costs $(6, 4, 2)$ and a budget equal to the cost of the baseline rates.

Exercise 4.12 [A] Twenty SOC teams are scored on a quarterly exercise with $\sigma_Q^2 = \sigma_\varepsilon^2$. Using Theorem 4.11, compute the expected true quality of a team whose score is two standard deviations of Y above the mean, in units of σ_Q . How should a program that rewards the top-scoring team adjust its decision?

Exercise 4.13 [C] Design an evaluation of the two training programs of Example 4.6 at MERIDIAN. Address statistical conclusion validity (use the power calculation of Section 4.7), internal validity (campaign calendars and regression toward the mean), construct validity (what the click count does and does not measure), and the privacy conditions of Section 4.8.

Exercise 4.14 [P] *Lab: resilience metrics from simulated decision traces.* The companion script `companion/ch04/lab_resilience_traces.py` simulates episodes of the degradation-recovery chain of Example 4.5 and, within each episode, the individual triage decisions of the SOC, each correct with probability $Q_0(1 - \delta_{X_i})$. (a) Estimate $Q(t)$ from the decision trace with a sliding window, and estimate depth, time to detect, time to recover, and loss area for each episode. (b) Compare the mean and $\text{CVaR}_{0.95}$ of the estimated loss area with the exact values of Example 4.5, and explain the bias introduced by the window length, relating it to part (v) of Theorem 4.4. (c) Add a second manipulation with a short deep dip and estimate $R^\mathbb{E}$ and $R^{0.95}$ over the set of both, including the even mixture. (d) State which of the estimates should be presented to the board of the chapter's opening vignette, and which should not.

Notes and Further Reading

Objectives and risk. The six objectives extend the security properties discussed in the system-scientific treatment of cognitive security by Huang and Zhu [3]. Cox's analysis of risk matrices [111] repays reading in full, including its constructive suggestions for designing matrices that satisfy weak consistency.

Resilience metrics. Henry and Ramirez-Marquez [128] and Ayyub [129] develop time-dependent and valuation-based metrics that extend the resilience triangle, and Hosseini, Barker, and Ramirez-Marquez [130] survey the field. Game-theoretic formulations of resilience across layers are developed by Zhu and Başar [10], and attention management against informational denial of service by Huang and Zhu [2]; both are natural settings in which to compute R as an equilibrium value.

Risk measures. Acerbi and Tasche established the coherence of expected shortfall with the atom correction used in (4.13) [116]. The phase-type view of absorption times in continuous-time Markov chains underlies [Theorem 4.6](#).

Validity and proxies. Messick's unified view of validity [121] adds the consequences of score use, which connects validity to the ethical concerns of [Section 4.8](#).

Bibliography

- [1] Linan Huang et al. “ADVERT: An Adaptive and Data-Driven Attention Enhancement Mechanism for Phishing Prevention”. In: *IEEE Transactions on Information Forensics and Security* 17 (2022), pp. 2585–2597. doi: [10.1109/TIFS.2022.3189530](https://doi.org/10.1109/TIFS.2022.3189530).
- [2] Linan Huang and Quanyan Zhu. “RADAMS: Resilient and Adaptive Alert and Attention Management Strategy against Informational Denial-of-Service (IDoS) Attacks”. In: *Computers & Security* 121 (2022), p. 102844. doi: [10.1016/j.cose.2022.102844](https://doi.org/10.1016/j.cose.2022.102844).
- [3] Linan Huang and Quanyan Zhu. *Cognitive Security: A System-Scientific Approach*. SpringerBriefs in Computer Science. Cham: Springer, 2023. doi: [10.1007/978-3-031-30709-6](https://doi.org/10.1007/978-3-031-30709-6).
- [4] Intelligence Advanced Research Projects Activity. *ReSCIND: Reimagining Security with Cyberpsychology-Informed Network Defenses*. Program web page. Accessed September 2026. 2024. URL: <https://www.iarpa.gov/research-programs/rescind>.
- [5] Heather Chen and Kathleen Magramo. *Finance Worker Pays Out \$25 Million after Video Call with Deepfake ‘Chief Financial Officer’*. CNN. Feb. 4, 2024. URL: <https://www.cnn.com/2024/02/04/asia/deepfake-cfo-scam-hong-kong-intl-hnk> (visited on 09/13/2026).
- [6] CNN. *Arup Revealed as Victim of \$25 Million Deepfake Scam Involving Hong Kong Employee*. May 16, 2024. URL: <https://www.cnn.com/2024/05/16/tech/arup-deepfake-scam-loss-hong-kong-intl-hnk> (visited on 09/13/2026).
- [7] Jeremy M. Wolfe, Todd S. Horowitz, and Naomi M. Kenner. “Rare Items Often Missed in Visual Searches”. In: *Nature* 435.7041 (2005), pp. 439–440. doi: [10.1038/435439a](https://doi.org/10.1038/435439a).
- [8] Ben D. Sawyer and Peter A. Hancock. “Hacking the Human: The Prevalence Paradox in Cybersecurity”. In: *Human Factors* 60.5 (2018), pp. 597–609. doi: [10.1177/0018720818780472](https://doi.org/10.1177/0018720818780472).
- [9] Kai Greshake et al. “Not What You’ve Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection”. In: *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (AISec)*. 2023, pp. 79–90. doi: [10.1145/3605764.3623985](https://doi.org/10.1145/3605764.3623985).
- [10] Quanyan Zhu and Tamer Başar. “Game-Theoretic Methods for Robustness, Security, and Resilience of Cyberphysical Control Systems: Games-in-Games Principle for Optimal Cross-Layer Resilient Control Systems”. In: *IEEE Control Systems Magazine* 35.1 (2015), pp. 46–65. doi: [10.1109/MCS.2014.2364710](https://doi.org/10.1109/MCS.2014.2364710).
- [11] Ralph Langner. *To Kill a Centrifuge: A Technical Analysis of What Stuxnet’s Creators Tried to Achieve*. The Langner Group, 2013.
- [12] Electricity Information Sharing and Analysis Center and SANS Industrial Control Systems. *Analysis of the Cyber Attack on the Ukrainian Power Grid*. Defense Use Case. Washington, DC: E-ISAC, Mar. 18, 2016.

- [13] Daniel Susser, Beate Roessler, and Helen Nissenbaum. "Technology, Autonomy, and Manipulation". In: *Internet Policy Review* 8.2 (2019). doi: [10.14763/2019.2.1410](#).
- [14] NPR. *AP Twitter Account Hacked, Tweet about Obama Shakes Market*. Apr. 23, 2013. URL: <https://www.npr.org/sections/thetwo-way/2013/04/23/178620410/ap-twitter-account-hacked-tweet-about-obama-shakes-market> (visited on 09/13/2026).
- [15] Bloomberg News. *Fake Post Erasing \$136 Billion Shows Markets Need Humans*. Apr. 23, 2013. URL: <https://www.bloomberg.com/news/articles/2013-04-23/fake-report-erasing-136-billion-shows-market-s-fragility> (visited on 09/13/2026).
- [16] MITRE Corporation. *MITRE ATT&CK: Adversarial Tactics, Techniques, and Common Knowledge*. Knowledge base. URL: <https://attack.mitre.org/> (visited on 09/13/2026).
- [17] MITRE Corporation. *MITRE ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems*. Knowledge base. URL: <https://atlas.mitre.org/> (visited on 09/13/2026).
- [18] Claire Wardle and Hossein Derakhshan. *Information Disorder: Toward an Interdisciplinary Framework for Research and Policy Making*. Council of Europe report DGI(2017)09. Strasbourg: Council of Europe, 2017.
- [19] Soroush Vosoughi, Deb Roy, and Sinan Aral. "The Spread of True and False News Online". In: *Science* 359.6380 (2018), pp. 1146–1151. doi: [10.1126/science.aap9559](#).
- [20] James Reason. "Human Error: Models and Management". In: *BMJ* 320.7237 (2000), pp. 768–770. doi: [10.1136/bmj.320.7237.768](#).
- [21] Mica R. Endsley. "Toward a Theory of Situation Awareness in Dynamic Systems". In: *Human Factors* 37.1 (1995), pp. 32–64. doi: [10.1518/001872095779049543](#).
- [22] Raja Parasuraman and Victor Riley. "Humans and Automation: Use, Misuse, Disuse, Abuse". In: *Human Factors* 39.2 (1997), pp. 230–253. doi: [10.1518/001872097778543886](#).
- [23] Dario Amodei et al. *Concrete Problems in AI Safety*. 2016. arXiv: [1606.06565](#).
- [24] Rand Waltzman. *The Weaponization of Information: The Need for Cognitive Security*. Testimony presented before the Senate Armed Services Committee, Subcommittee on Cybersecurity, 27 April 2017 CT-473. Santa Monica, CA: RAND Corporation, 2017. URL: <https://www.rand.org/pubs/testimonies/CT473.html>.
- [25] Tamara Denning, Yoky Matsuoka, and Tadayoshi Kohno. "Neurosecurity: Security and Privacy for Neural Devices". In: *Neurosurgical Focus* 27.1 (2009), E7. doi: [10.3171/2009.4.FOCUS0985](#).
- [26] John D. Lee and Katrina A. See. "Trust in Automation: Designing for Appropriate Reliance". In: *Human Factors* 46.1 (2004), pp. 50–80. doi: [10.1518/hfes.46.1.50.30392](#).
- [27] Amos Tversky and Daniel Kahneman. "Judgment under Uncertainty: Heuristics and Biases". In: *Science* 185.4157 (1974), pp. 1124–1131. doi: [10.1126/science.185.4157.1124](#).
- [28] Herbert A. Simon. "A Behavioral Model of Rational Choice". In: *The Quarterly Journal of Economics* 69.1 (1955), pp. 99–118. doi: [10.2307/1884852](#).

- [29] Ralph Langner. "Stuxnet: Dissecting a Cyberwarfare Weapon". In: *IEEE Security & Privacy* 9.3 (2011), pp. 49–51. doi: [10.1109/MSP.2011.67](#).
- [30] Ron Ross et al. *Developing Cyber-Resilient Systems: A Systems Security Engineering Approach*. NIST Special Publication 800-160 Vol. 2 Rev. 1. Gaithersburg, MD: National Institute of Standards and Technology, 2021. doi: [10.6028/NIST.SP.800-160v2r1](#).
- [31] Eric M. Hutchins, Michael J. Cloppert, and Rohan M. Amin. "Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains". In: *Leading Issues in Information Warfare & Security Research* 1.1 (2011), pp. 1–14.
- [32] Michel Bruneau et al. "A Framework to Quantitatively Assess and Enhance the Seismic Resilience of Communities". In: *Earthquake Spectra* 19.4 (2003), pp. 733–752. doi: [10.1193/1.1623497](#).
- [33] Roberto O. Andrade and Sang Guun Yoo. "Cognitive Security: A Comprehensive Study of Cognitive Science in Cybersecurity". In: *Journal of Information Security and Applications* 48 (2019), p. 102352. doi: [10.1016/j.jisa.2019.06.008](#).
- [34] Edwin Hutchins. "How a Cockpit Remembers Its Speeds". In: *Cognitive Science* 19.3 (1995), pp. 265–288. doi: [10.1207/s15516709cog1903_1](#).
- [35] Daniel Kahneman. *Attention and Effort*. Englewood Cliffs, NJ: Prentice-Hall, 1973.
- [36] Daniel J. Simons and Christopher F. Chabris. "Gorillas in Our Midst: Sustained Inattentional Blindness for Dynamic Events". In: *Perception* 28.9 (1999), pp. 1059–1074. doi: [10.1068/p281059](#).
- [37] George A. Miller. "The Magical Number Seven, Plus or Minus Two: Some Limits on Our Capacity for Processing Information". In: *Psychological Review* 63.2 (1956), pp. 81–97. doi: [10.1037/h0043158](#).
- [38] Nelson Cowan. "The Magical Number 4 in Short-Term Memory: A Reconsideration of Mental Storage Capacity". In: *Behavioral and Brain Sciences* 24.1 (2001), pp. 87–114. doi: [10.1017/S0140525X01003922](#).
- [39] Daniel Kahneman and Gary Klein. "Conditions for Intuitive Expertise: A Failure to Disagree". In: *American Psychologist* 64.6 (2009), pp. 515–526. doi: [10.1037/a0016755](#).
- [40] Jonathan St. B. T. Evans and Keith E. Stanovich. "Dual-Process Theories of Higher Cognition: Advancing the Debate". In: *Perspectives on Psychological Science* 8.3 (2013), pp. 223–241. doi: [10.1177/1745691612460685](#).
- [41] Daniel Kahneman. *Thinking, Fast and Slow*. New York: Farrar, Straus and Giroux, 2011.
- [42] Elizabeth A. Phelps. "Emotion and Cognition: Insights from Studies of the Human Amygdala". In: *Annual Review of Psychology* 57 (2006), pp. 27–53. doi: [10.1146/annurev.psych.56.091103.070234](#).
- [43] Jennifer S. Lerner et al. "Emotion and Decision Making". In: *Annual Review of Psychology* 66 (2015), pp. 799–823. doi: [10.1146/annurev-psych-010213-115043](#).
- [44] Martin S. Hagger, Nikos L. D. Chatzisarantis, Hugo Alberts, et al. "A Multilab Pre-registered Replication of the Ego-Depletion Effect". In: *Perspectives on Psychological Science* 11.4 (2016), pp. 546–573. doi: [10.1177/1745691616652873](#).

- [45] Mica R. Endsley. "Measurement of Situation Awareness in Dynamic Systems". In: *Human Factors* 37.1 (1995), pp. 65–84. doi: [10.1518/001872095779049499](#).
- [46] Debra G. Jones and Mica R. Endsley. "Sources of Situation Awareness Errors in Aviation". In: *Aviation, Space, and Environmental Medicine* 67.6 (1996), pp. 507–512.
- [47] International Society of Automation. *ANSI/ISA-18.2-2016: Management of Alarm Systems for the Process Industries*. Research Triangle Park, NC: International Society of Automation, 2016.
- [48] Paul M. Salmon et al. "What Really Is Going On? Review of Situation Awareness Models for Individuals and Teams". In: *Theoretical Issues in Ergonomics Science* 9.4 (2008), pp. 297–323. doi: [10.1080/14639220701561775](#).
- [49] Edwin Hutchins. *Cognition in the Wild*. Cambridge, MA: MIT Press, 1995. ISBN: 9780262082310.
- [50] James Hollan, Edwin Hutchins, and David Kirsh. "Distributed Cognition: Toward a New Foundation for Human-Computer Interaction Research". In: *ACM Transactions on Computer-Human Interaction* 7.2 (2000), pp. 174–196. doi: [10.1145/353485.353487](#).
- [51] Martha S. Feldman and Brian T. Pentland. "Reconceptualizing Organizational Routines as a Source of Flexibility and Change". In: *Administrative Science Quarterly* 48.1 (2003), pp. 94–118. doi: [10.2307/3556620](#).
- [52] James P. Walsh and Gerardo Rivera Ungson. "Organizational Memory". In: *Academy of Management Review* 16.1 (1991), pp. 57–91. doi: [10.2307/258607](#).
- [53] Daniel M. Wegner. "Transactive Memory: A Contemporary Analysis of the Group Mind". In: *Theories of Group Behavior*. Ed. by Brian Mullen and George R. Goethals. New York: Springer, 1987, pp. 185–208. doi: [10.1007/978-1-4612-4634-3_9](#).
- [54] Kyle Lewis. "Measuring Transactive Memory Systems in the Field: Scale Development and Validation". In: *Journal of Applied Psychology* 88.4 (2003), pp. 587–604. doi: [10.1037/0021-9010.88.4.587](#).
- [55] Ross Anderson. "Why Information Security Is Hard: An Economic Perspective". In: *Proceedings of the 17th Annual Computer Security Applications Conference (ACSAC)*. 2001, pp. 358–365. doi: [10.1109/ACSAC.2001.991552](#).
- [56] Stuart Russell and Peter Norvig. *Artificial Intelligence: A Modern Approach*. 4th ed. Hoboken, NJ: Pearson, 2020.
- [57] Erik Hollnagel and David D. Woods. *Joint Cognitive Systems: Foundations of Cognitive Systems Engineering*. Boca Raton, FL: CRC Press, 2005. doi: [10.1201/9781420038194](#).
- [58] Raja Parasuraman, Thomas B. Sheridan, and Thomas D. Wickens. "A Model for Types and Levels of Human Interaction with Automation". In: *IEEE Transactions on Systems, Man, and Cybernetics, Part A: Systems and Humans* 30.3 (2000), pp. 286–297. doi: [10.1109/3468.844354](#).
- [59] Lisanne Bainbridge. "Ironies of Automation". In: *Automatica* 19.6 (1983), pp. 775–779. doi: [10.1016/0005-1098\(83\)90046-8](#).
- [60] Mica R. Endsley. "From Here to Autonomy: Lessons Learned from Human-Automation Research". In: *Human Factors* 59.1 (2017), pp. 5–27. doi: [10.1177/0018720816681350](#).

- [61] Kathleen L. Mosier et al. "Automation Bias: Decision Making and Performance in High-Tech Cockpits". In: *International Journal of Aviation Psychology* 8.1 (1998), pp. 47–63. doi: [10.1207/s15327108ijap0801_3](https://doi.org/10.1207/s15327108ijap0801_3).
- [62] Raja Parasuraman and Dietrich H. Manzey. "Complacency and Bias in Human Use of Automation: An Attentional Integration". In: *Human Factors* 52.3 (2010), pp. 381–410. doi: [10.1177/0018720810376055](https://doi.org/10.1177/0018720810376055).
- [63] Mary T. Dzindolet et al. "The Role of Trust in Automation Reliance". In: *International Journal of Human-Computer Studies* 58.6 (2003), pp. 697–718. doi: [10.1016/S1071-5819\(03\)00038-7](https://doi.org/10.1016/S1071-5819(03)00038-7).
- [64] Steven M. Rinaldi, James P. Peerenboom, and Terrence K. Kelly. "Identifying, Understanding, and Analyzing Critical Infrastructure Interdependencies". In: *IEEE Control Systems Magazine* 21.6 (2001), pp. 11–25. doi: [10.1109/37.969131](https://doi.org/10.1109/37.969131).
- [65] David Kempe, Jon Kleinberg, and Éva Tardos. "Maximizing the Spread of Influence through a Social Network". In: *Proceedings of the Ninth ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*. 2003, pp. 137–146. doi: [10.1145/956750.956769](https://doi.org/10.1145/956750.956769).
- [66] Federal Communications Commission, Public Safety and Homeland Security Bureau. *Report and Recommendations: Hawaii Emergency Management Agency January 13, 2018 False Alert*. Tech. rep. Washington, DC: Federal Communications Commission, Apr. 2018. URL: <https://docs.fcc.gov/public/attachments/DOC-350119A1.pdf>.
- [67] Alan D. Baddeley. "The Episodic Buffer: A New Component of Working Memory?". In: *Trends in Cognitive Sciences* 4.11 (2000), pp. 417–423. doi: [10.1016/S1364-6613\(00\)01538-2](https://doi.org/10.1016/S1364-6613(00)01538-2).
- [68] Linan Huang and Quanyan Zhu. "Combating Informational Denial-of-Service (IDoS) Attacks: Modeling and Mitigation of Attentional Human Vulnerability". In: *Decision and Game Theory for Security (GameSec 2021)*. Lecture Notes in Computer Science. Cham: Springer, 2021, pp. 314–333. doi: [10.1007/978-3-030-90370-1_17](https://doi.org/10.1007/978-3-030-90370-1_17).
- [69] Nancy J. Cooke et al. "Interactive Team Cognition". In: *Cognitive Science* 37.2 (2013), pp. 255–285. doi: [10.1111/cogs.12009](https://doi.org/10.1111/cogs.12009).
- [70] Kevin Anthony Hoff and Masooda Bashir. "Trust in Automation: Integrating Empirical Evidence on Factors That Influence Trust". In: *Human Factors* 57.3 (2015), pp. 407–434. doi: [10.1177/0018720814547570](https://doi.org/10.1177/0018720814547570).
- [71] Roger C. Mayer, James H. Davis, and F. David Schoorman. "An Integrative Model of Organizational Trust". In: *Academy of Management Review* 20.3 (1995), pp. 709–734. doi: [10.2307/258792](https://doi.org/10.2307/258792).
- [72] Duncan J. Watts. "A Simple Model of Global Cascades on Random Networks". In: *Proceedings of the National Academy of Sciences* 99.9 (2002), pp. 5766–5771. doi: [10.1073/pnas.082090499](https://doi.org/10.1073/pnas.082090499).
- [73] Krishna B. Athreya and Peter E. Ney. *Branching Processes*. Berlin: Springer, 1972. doi: [10.1007/978-3-642-65371-1](https://doi.org/10.1007/978-3-642-65371-1).
- [74] Gerd Gigerenzer and Wolfgang Gaissmaier. "Heuristic Decision Making". In: *Annual Review of Psychology* 62 (2011), pp. 451–482. doi: [10.1146/annurev-psych-120709-145346](https://doi.org/10.1146/annurev-psych-120709-145346).

- [75] Daniel Kahneman and Amos Tversky. "Prospect Theory: An Analysis of Decision under Risk". In: *Econometrica* 47.2 (1979), pp. 263–291. doi: [10.2307/1914185](#).
- [76] Emily B. Cox, Quanyan Zhu, and Emily Balcetis. "Stuck on a Phishing Lure: Differential Use of Base Rates in Self and Social Judgments of Susceptibility to Cyber Risk". In: *Comprehensive Results in Social Psychology* 4.1 (2020), pp. 25–52. doi: [10.1080/23743603.2020.1756240](#).
- [77] Richard E. Petty and John T. Cacioppo. "The Elaboration Likelihood Model of Persuasion". In: *Communication and Persuasion: Central and Peripheral Routes to Attitude Change*. New York: Springer, 1986, pp. 1–24. doi: [10.1007/978-1-4612-4964-1_1](#).
- [78] Arun Vishwanath et al. "Why Do People Get Phished? Testing Individual Differences in Phishing Vulnerability within an Integrated, Information Processing Model". In: *Decision Support Systems* 51.3 (2011), pp. 576–586. doi: [10.1016/j.dss.2011.03.002](#).
- [79] Solomon E. Asch. "Studies of Independence and Conformity: I. A Minority of One against a Unanimous Majority". In: *Psychological Monographs: General and Applied* 70.9 (1956), pp. 1–70. doi: [10.1037/h0093718](#).
- [80] Robert B. Cialdini and Noah J. Goldstein. "Social Influence: Compliance and Conformity". In: *Annual Review of Psychology* 55 (2004), pp. 591–621. doi: [10.1146/annurev.psych.55.090902.142015](#).
- [81] Stéphane Doyen et al. "Behavioral Priming: It's All in the Mind, but Whose Mind?" In: *PLoS ONE* 7.1 (2012), e29081. doi: [10.1371/journal.pone.0029081](#).
- [82] Open Science Collaboration. "Estimating the Reproducibility of Psychological Science". In: *Science* 349.6251 (2015), aac4716. doi: [10.1126/science.aac4716](#).
- [83] Wendy Wood and David T. Neal. "A New Look at Habits and the Habit-Goal Interface". In: *Psychological Review* 114.4 (2007), pp. 843–863. doi: [10.1037/0033-295X.114.4.843](#).
- [84] Adam Beautelement, M. Angela Sasse, and Mike Wonham. "The Compliance Budget: Managing Security Behaviour in Organisations". In: *Proceedings of the 2008 New Security Paradigms Workshop (NSPW)*. 2008, pp. 47–58. doi: [10.1145/1595676.1595684](#).
- [85] Frank Stajano and Paul Wilson. "Understanding Scam Victims: Seven Principles for Systems Security". In: *Communications of the ACM* 54.3 (2011), pp. 70–75. doi: [10.1145/1897852.1897872](#).
- [86] Ana Ferreira, Lynne Coventry, and Gabriele Lenzini. "Principles of Persuasion in Social Engineering and Their Use in Phishing". In: *Human Aspects of Information Security, Privacy, and Trust (HAS 2015)*. Vol. 9190. Lecture Notes in Computer Science. Springer, 2015, pp. 36–47. doi: [10.1007/978-3-319-20376-8_4](#).
- [87] Stanley Milgram. "Behavioral Study of Obedience". In: *The Journal of Abnormal and Social Psychology* 67.4 (1963), pp. 371–378. doi: [10.1037/h0040525](#).
- [88] Lynn Hasher, David Goldstein, and Thomas Toppino. "Frequency and the Conference of Referential Validity". In: *Journal of Verbal Learning and Verbal Behavior* 16.1 (1977), pp. 107–112. doi: [10.1016/S0022-5371\(77\)80012-1](#).
- [89] Lisa K. Fazio et al. "Knowledge Does Not Protect against Illusory Truth". In: *Journal of Experimental Psychology: General* 144.5 (2015), pp. 993–1002. doi: [10.1037/xge0000098](#).

- [90] Christian Unkelbach et al. "Truth by Repetition: Explanations and Implications". In: *Current Directions in Psychological Science* 28.3 (2019), pp. 247–253. doi: [10.1177/0963721419827854](https://doi.org/10.1177/0963721419827854).
- [91] Dennis T. Regan. "Effects of a Favor and Liking on Compliance". In: *Journal of Experimental Social Psychology* 7.6 (1971), pp. 627–639. doi: [10.1016/0022-1031\(71\)90025-4](https://doi.org/10.1016/0022-1031(71)90025-4).
- [92] Dan M. Kahan. "Ideology, Motivated Reasoning, and Cognitive Reflection". In: *Judgment and Decision Making* 8.4 (2013), pp. 407–424. doi: [10.1017/S1930297500005271](https://doi.org/10.1017/S1930297500005271).
- [93] Diane Vaughan. *The Challenger Launch Decision: Risky Technology, Culture, and Deviance at NASA*. Chicago: University of Chicago Press, 1996.
- [94] Damon Centola. "The Spread of Behavior in an Online Social Network Experiment". In: *Science* 329.5996 (2010), pp. 1194–1197. doi: [10.1126/science.1185231](https://doi.org/10.1126/science.1185231).
- [95] Manoel Horta Ribeiro et al. "Auditing Radicalization Pathways on YouTube". In: *Proceedings of the 2020 Conference on Fairness, Accountability, and Transparency (FAT*)*. 2020, pp. 131–141. doi: [10.1145/3351095.3372879](https://doi.org/10.1145/3351095.3372879).
- [96] Brendan Nyhan et al. "Like-Minded Sources on Facebook Are Prevalent but Not Polarizing". In: *Nature* 620 (2023), pp. 137–144. doi: [10.1038/s41586-023-06297-w](https://doi.org/10.1038/s41586-023-06297-w).
- [97] Devdatta Akhawe and Adrienne Porter Felt. "Alice in Warningland: A Large-Scale Field Study of Browser Security Warning Effectiveness". In: *Proceedings of the 22nd USENIX Security Symposium*. 2013, pp. 257–272.
- [98] Arunesh Mathur et al. "Dark Patterns at Scale: Findings from a Crawl of 11K Shopping Websites". In: *Proceedings of the ACM on Human-Computer Interaction* 3.CSCW (2019), pp. 1–32. doi: [10.1145/3359183](https://doi.org/10.1145/3359183).
- [99] Joint Task Force Transformation Initiative. *Guide for Conducting Risk Assessments*. NIST Special Publication 800-30 Rev. 1. Gaithersburg, MD: National Institute of Standards and Technology, 2012. doi: [10.6028/NIST.SP.800-30r1](https://doi.org/10.6028/NIST.SP.800-30r1).
- [100] Dawn M. Cappelli, Andrew P. Moore, and Randall F. Trzeciak. *The CERT Guide to Insider Threats: How to Prevent, Detect, and Respond to Information Technology Crimes (Theft, Sabotage, Fraud)*. Upper Saddle River, NJ: Addison-Wesley, 2012.
- [101] New York State Department of Financial Services. *Twitter Investigation Report: A Report on Investigation of Twitter's July 15, 2020 Cybersecurity Incident and the Implications for Election Security*. Tech. rep. New York: New York State Department of Financial Services, Oct. 2020. URL: https://www.dfs.ny.gov/Twitter_Report.
- [102] Emilio Ferrara et al. "The Rise of Social Bots". In: *Communications of the ACM* 59.7 (2016), pp. 96–104. doi: [10.1145/2818717](https://doi.org/10.1145/2818717).
- [103] Federal Bureau of Investigation, Internet Crime Complaint Center. *Internet Crime Report 2024*. Tech. rep. Washington, DC: Federal Bureau of Investigation, 2025. URL: https://www.ic3.gov/AnnualReport/Reports/2024_IC3Report.pdf.
- [104] Federal Bureau of Investigation, Internet Crime Complaint Center. *Business Email Compromise: The \$55 Billion Scam*. Public Service Announcement I-091124-PSA. Sept. 2024. URL: <https://www.ic3.gov/PSA/2024/PSA240911>.

- [105] Rosana Montañez Rodriguez and Shouhuai Xu. "Cyber Social Engineering Kill Chain". In: *Science of Cyber Security (SciSec 2022)*. Vol. 13580. Lecture Notes in Computer Science. Springer, 2022, pp. 487–504. doi: [10.1007/978-3-031-17551-0_32](https://doi.org/10.1007/978-3-031-17551-0_32).
- [106] U.S. Department of Justice, Office of Public Affairs. *Three Individuals Charged for Alleged Roles in Twitter Hack*. Press release. July 2020. URL: <https://www.justice.gov/opa/pr/three-individuals-charged-alleged-roles-twitter-hack>.
- [107] John G. Kemeny and J. Laurie Snell. *Finite Markov Chains*. Undergraduate Texts in Mathematics. Reprint of the 1960 Van Nostrand edition. New York: Springer, 1976.
- [108] David P. Morton, Feng Pan, and Kevin J. Saeger. "Models for Nuclear Smuggling Interdiction". In: *IIE Transactions* 39.1 (2007), pp. 3–14. doi: [10.1080/07408170500488956](https://doi.org/10.1080/07408170500488956).
- [109] N. H. Mackworth. "The Breakdown of Vigilance during Prolonged Visual Search". In: *Quarterly Journal of Experimental Psychology* 1.1 (1948), pp. 6–21. doi: [10.1080/17470214808416738](https://doi.org/10.1080/17470214808416738).
- [110] Joel S. Warm, Raja Parasuraman, and Gerald Matthews. "Vigilance Requires Hard Mental Work and Is Stressful". In: *Human Factors* 50.3 (2008), pp. 433–441. doi: [10.1518/001872008X312152](https://doi.org/10.1518/001872008X312152).
- [111] Jr. Cox Louis Anthony (Tony). "What's Wrong with Risk Matrices?" In: *Risk Analysis* 28.2 (2008), pp. 497–512. doi: [10.1111/j.1539-6924.2008.01030.x](https://doi.org/10.1111/j.1539-6924.2008.01030.x).
- [112] David M. Green and John A. Swets. *Signal Detection Theory and Psychophysics*. New York: Wiley, 1966.
- [113] U.S. Senate Committee on Commerce, Science, and Transportation. *A "Kill Chain" Analysis of the 2013 Target Data Breach*. Majority Staff Report for Chairman Rockefeller. Washington, DC: United States Senate, Mar. 26, 2014. URL: <https://www.commerce.senate.gov/services/files/24d3c229-4f2f-405d-b8db-a3a67f183883>.
- [114] Michael Riley et al. "Missed Alarms and 40 Million Stolen Credit Card Numbers: How Target Blew It". In: *Bloomberg Businessweek* (Mar. 13, 2014). URL: <https://www.bloomberg.com/news/articles/2014-03-13/target-missed-warnings-in-epic-hack-of-credit-card-data>.
- [115] Philippe Artzner et al. "Coherent Measures of Risk". In: *Mathematical Finance* 9.3 (1999), pp. 203–228. doi: [10.1111/1467-9965.00068](https://doi.org/10.1111/1467-9965.00068).
- [116] Carlo Acerbi and Dirk Tasche. "On the Coherence of Expected Shortfall". In: *Journal of Banking & Finance* 26.7 (2002), pp. 1487–1503. doi: [10.1016/S0378-4266\(02\)00283-2](https://doi.org/10.1016/S0378-4266(02)00283-2).
- [117] R. Tyrrell Rockafellar and Stanislav Uryasev. "Optimization of Conditional Value-at-Risk". In: *Journal of Risk* 2.3 (2000), pp. 21–41. doi: [10.21314/JOR.2000.038](https://doi.org/10.21314/JOR.2000.038).
- [118] R. Tyrrell Rockafellar and Stanislav Uryasev. "Conditional Value-at-Risk for General Loss Distributions". In: *Journal of Banking & Finance* 26.7 (2002), pp. 1443–1471. doi: [10.1016/S0378-4266\(02\)00271-6](https://doi.org/10.1016/S0378-4266(02)00271-6).
- [119] William R. Shadish, Thomas D. Cook, and Donald T. Campbell. *Experimental and Quasi-Experimental Designs for Generalized Causal Inference*. Boston: Houghton Mifflin, 2002.
- [120] Lee J. Cronbach and Paul E. Meehl. "Construct Validity in Psychological Tests". In: *Psychological Bulletin* 52.4 (1955), pp. 281–302. doi: [10.1037/h0040957](https://doi.org/10.1037/h0040957).

- [121] Samuel Messick. "Validity of Psychological Assessment: Validation of Inferences from Persons' Responses and Performances as Scientific Inquiry into Score Meaning". In: *American Psychologist* 50.9 (1995), pp. 741–749. doi: [10.1037/0003-066X.50.9.741](https://doi.org/10.1037/0003-066X.50.9.741).
- [122] Charles A. E. Goodhart. "Problems of Monetary Management: The U.K. Experience". In: *Papers in Monetary Economics*. Vol. 1. Sydney: Reserve Bank of Australia, 1975.
- [123] Marilyn Strathern. "'Improving Ratings': Audit in the British University System". In: *European Review* 5.3 (1997), pp. 305–321. doi: [10.1002/\(SICI\)1234-981X\(199707\)5:3<305::AID-EUR0184>3.0.CO;2-4](https://doi.org/10.1002/(SICI)1234-981X(199707)5:3<305::AID-EUR0184>3.0.CO;2-4).
- [124] Donald T. Campbell. "Assessing the Impact of Planned Social Change". In: *Evaluation and Program Planning* 2.1 (1979), pp. 67–90. doi: [10.1016/0149-7189\(79\)90048-X](https://doi.org/10.1016/0149-7189(79)90048-X).
- [125] David Manheim and Scott Garrabrant. *Categorizing Variants of Goodhart's Law*. arXiv preprint arXiv:1803.04585. 2018. URL: <https://arxiv.org/abs/1803.04585>.
- [126] David B. Resnik and Peter R. Finn. "Ethics and Phishing Experiments". In: *Science and Engineering Ethics* 24.4 (2018), pp. 1241–1252. doi: [10.1007/s11948-017-9952-9](https://doi.org/10.1007/s11948-017-9952-9).
- [127] Peter Finn and Markus Jakobsson. "Designing Ethical Phishing Experiments". In: *IEEE Technology and Society Magazine* 26.1 (2007), pp. 46–58. doi: [10.1109/MTAS.2007.335565](https://doi.org/10.1109/MTAS.2007.335565).
- [128] Devanandham Henry and Jose Emmanuel Ramirez-Marquez. "Generic Metrics and Quantitative Approaches for System Resilience as a Function of Time". In: *Reliability Engineering & System Safety* 99 (2012), pp. 114–122. doi: [10.1016/j.res.2011.09.002](https://doi.org/10.1016/j.res.2011.09.002).
- [129] Bilal M. Ayyub. "Systems Resilience for Multihazard Environments: Definition, Metrics, and Valuation for Decision Making". In: *Risk Analysis* 34.2 (2014), pp. 340–355. doi: [10.1111/risa.12093](https://doi.org/10.1111/risa.12093).
- [130] Seyedmohsen Hosseini, Kash Barker, and Jose E. Ramirez-Marquez. "A Review of Definitions and Measures of System Resilience". In: *Reliability Engineering & System Safety* 145 (2016), pp. 47–61. doi: [10.1016/j.res.2015.08.006](https://doi.org/10.1016/j.res.2015.08.006).

Index

- accountability, 97
 - attribution record, 97
- AI safety, 11
- AI security, 11
- alarm management, 37
- Arup deepfake fraud, 14, 16
- asset-dependency
 - graph, 49
 - compromise-cost recursion, 50
- Associated Press Twitter hijacking (2013), 10
- attention, 33, 67
- attentional availability, 96
- attentional denial of service (ADoS), 15
- authority gradient, 72
- authority laundering, 15, 42
- authorized influence, 48
- automation bias, 42
- autonomy, 87, 96
 - violation, 96
- autonomy constraint, 20
- availability heuristic, 65

- base rate, 122
 - neglect, 67
- Bayes' rule, 122
- bounded rationality, 14, 34
- branching process, 54
- business email
 - compromise (BEC), 77

- calibration gap, 44, 96
- cognitive asset, 47
- cognitive attack, 8
- cognitive attack chain, 17, 78
 - action and effect, 79
 - cognitive exploitation, 79
 - delivery and exposure, 78
 - level switching, 79
- pretext and content development, 78
- reconnaissance and profiling, 78
- reinforcement and persistence, 79
- target and channel selection, 78
- cognitive defense chain, 17
- cognitive integrity, 95
 - integrity loss, 96
- cognitive loop, 15
 - act, 15
 - decide, 15
 - learn, 15
 - model, 15
 - sense, 15
- cognitive reliability, 11
- cognitive risk, 101
 - harmful-action rate, 101
 - loss distribution, 101
- cognitive security, 5
- Cognitive Security Cube, 16
- Cognitive Security Stack, 15
 - AI agent level, 15
 - human-AI team level, 15
 - individual level, 15
 - organization level, 15
 - society level, 15
- cognitive vulnerability, 65
 - acquired, 66
 - innate, 66
- cognitive warfare, 9
- coherent risk measure, 114
- common-mode reliance, 40
- complex contagion, 73
- compliance budget, 68
- conditional value-at-risk (CVaR), 114
- control layer, 6
- cross-level attack
- cognitive-first, 7
 - pathway, 15
 - technical-first, 7
- cybersecurity, 11

- dark pattern, 74
- decision assurance, 6
- decision quality, 20
 - admissible function, 104
- appropriate-reliance rate, 105
- cost-weighted accuracy, 105
- degradation-recovery chain, 112
 - expected loss area, 113
- dependency surface, 49
- dissent, 10
- distributed cognitive system, 39
- dual approval, 40
- dual-process theory, 33
- dual-use research, 88
- dwelt time, 80

- ego depletion, 35
- elaboration likelihood model, 68
- emotion, 34
- exploit mechanism, 66
- exposure, susceptibility, and conversion, 69, 101

- Financial Fraud Kill Chain, 77
- friction
 - asymmetric, 14
 - selective application, 98
- functional cognitive system, 41
- fundamental matrix, 82

- Goodhart's law, 120
 - regressional, 120
- habit, 68

- Hawaii false missile alert (2018), 57
- heuristics and biases, 14, 67
- human factors, 11

- illusory truth effect, 70
- impairment cascade, 53
- inattention blindness, 33
- independent cascade model, 52
- influence, 8
- information disorder, 11
- information integrity, 11
- informational denial of service, 7
- insider threat, 76
- Internet Crime Complaint Center (IC3), 77
- intrusion kill chain, 17, 78
- ironies of automation, 42

- joint cognitive system, 42

- latent condition, 73
- levels of automation, 42
- lever, 70
 - authority, 70
 - familiarity, 70
 - identity, 71
 - reciprocity, 71
 - repetition, 70
 - urgency, 71
- live-edge representation, 53
- loss area, 107

- manipulation, 8
- manipulation set, 20
- marginal value of interdiction, 83
- Markov chain
 - absorbing, 81
- measurement invariance, 119

- measurement validity, 118
- adversarial robustness, 119
- construct, 118
- external, 119
- internal, 118
- statistical conclusion, 118
- MERIDIAN, 22
 - AI triage copilot, 113
 - business email compromise, 85
 - finance approval chain, 50
 - grid control room, 37
 - MERIDIAN Assist, 22, 74
 - payment fraud, 19
 - phishing, 69
 - phishing wave, 106
 - report-rate target, 121
 - risk register, 103
 - SOC triage, 21, 43, 99
 - storm scenario, 55
 - vendor portal, 46
- Milgram obedience studies, 70
- minimum compromise cost, 49
- misaligned incentives, 40, 68
- MITRE ATLAS, 11
- MITRE ATT&CK, 11
- motivated reasoning, 71
- neurosecurity, 11
- NIST SP 800-30, 92
- normalization of deviance, 73
- organizational memory, 39
- organizational routine, 39
- out-of-the-loop problem, 42
- persuasion, 8
- phishing
 - simulation, 69, 122
 - training, 115
- phishing-resistant authentication, 80
- pluralism constraint, 20, 87
- process versus conclusion, 87
- prevalence effect, 13, 99
- privacy, 98
- prompt injection
 - indirect, 41, 74
- propagation threshold, 53
- proportional interdiction, 18
- prospect theory, 67
- protected decision process, 95
- protected property, 47
- queueing model
 - fluid approximation, 106
- recommender system, 73
- reference process, 95
- regression toward the mean, 120
- replay attack, 7
- replication, 68
- resilience curve, 21, 107
 - metrics, 107
 - trapezoidal, 109
- resilience functional, 20, 108
 - expected, 116
 - properties, 108
- risk-averse, 116
- resilience objective, 97
- resilience phases, 16, 107
 - adapt, 16
 - anticipate, 16
 - recover, 16
 - withstand, 16
- resilience triangle, 20
- risk matrix, 102
 - ranking reversal, 102
- Rockafellar-Uryasev representation, 114
- sanctioned refusal, 48
- security framing test, 9
- separation of duties, 48
- situation awareness, 36
 - distributed, 38
 - errors, 37
 - levels, 36
 - shared, 38
 - team, 38
- Situation Awareness
 - Global Assessment Technique, 36
- social bot, 76
- social proof, 68
- social-engineering kill chain, 78
- square-root allocation, 117
- stage-wise independence, 18
- state-trait distinction, 35
- statistical power, 119
- Stuxnet, 6
- surveillance, 24, 122
- systemic vulnerability, 72
- Target breach (2013), 110
- threat actor
 - automated actor, 76
- insider, 76
- opportunistic individual, 76
- organized criminal group, 75
- state actor, 76
- threat actor profile, 75
- time to act, 107
- time to alert, 107
- time to detect, 107
- time to recover, 107
- transactive memory, 39
- trust
 - calibrated, 14, 44, 96
 - distrust, 44
 - in automation, 14, 44
 - overtrust, 44
- trust network, 46
- trust transfer, 45, 73
 - proximate, 45
 - relay path, 45
- trusted boundary, 48
- selective permeability, 47
- Twitter compromise (2020), 80
- two-person rule, 57
- Ukrainian power grid attack (2015), 7
- unit of analysis, 14
- value-at-risk (VaR), 114
- verification
 - out-of-band, 16
- vigilance decrement, 97
- vigilance-fatigue trade-off, 97
- interior optimal vigilance, 99
- weakest-link model, 12
- working memory, 33